INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

DOSSIER CONSOLIDADO

Portal Vial

Documentación consolidada

Documentación consistente, clara y trazable

Índice general

El recorrido sigue el proceso del proyecto: definición, infraestructura y seguridad.

Ingeniería de Software **4**

Project Charter 5

Guía de entrevista 7

Informe de entrevista 9

Requerimientos del sistema 13

Análisis de requerimientos - Portal Vial 15

Product Backlog 19

Sprint Planning 21

Actas de reuniones 24

Sprint Review 30

Control de cambios 31

Plan e informe de pruebas - Portal Vial 32

Manual de usuario - Portal Vial 36

Declaración de compromiso ético en el uso de inteligencia artificial 40

Acta de cierre del proyecto 42

Administración de Sistemas Operativos **44**

Análisis de requerimientos de infraestructura 45

Arquitectura propuesta de infraestructura 48

Justificación tecnológica 52

Documentación de infraestructura 54

Reconstrucción de la infraestructura 58

Ciberseguridad **64**

Análisis de Ciberseguridad 65

Informe de análisis estático de seguridad (SAST) 71

Hardening de infraestructura y contenedores 82
Análisis dinámico de seguridad (DAST) 91
Informe formal de auditoría Bash 106
Registro consolidado de hallazgos y controles 115
Procedimiento técnico de respuesta a incidentes 118
Términos y condiciones 122
Política de privacidad 124
Reflexión ética 127

01 / ÁREA DOCUMENTAL

Ingeniería de Software

De la propuesta y la entrevista a los requisitos, la planificación, las pruebas y el cierre.

14 **DOCUMENTOS**

ordenados según el recorrido del proyecto

DOCUMENTO 01 | INGENIERÍA DE SOFTWARE

Project Charter

Fuente: project_charter.md | Versión 1.0 | Fecha 26/10/2026

1. Identificación

Dato	Valor
Producto	Portal Vial
Proyecto	Educación Vial IMSJ
Equipo	RC5
Cliente	Intendencia de San José - Sección Tránsito
Referente del cliente	Inspector de Tránsito
Líder del proyecto	Tomás Cabrera
Entrega prevista	29/10/2026

2. Necesidad y justificación

La Sección Tránsito necesita un canal propio para reunir noticias, materiales de estudio y preguntas frecuentes. El relevamiento identifica información distribuida entre distintos medios y una necesidad de comunicar contenidos comprensibles para la ciudadanía, especialmente adolescentes y aspirantes a la licencia de conducir.

Portal Vial centraliza esos contenidos y permite mantenerlos desde un panel administrativo. La aprobación de la Directora y el control de vigencia permiten organizar la publicación; el historial relaciona las modificaciones administrativas con sus responsables. Los simulacros ofrecen práctica y corrección, y el formulario de consultas recibe mensajes de la ciudadanía.

3. Objetivos

1. Reunir la comunicación pública de Tránsito en una plataforma accesible desde el navegador.
2. Administrar noticias, materiales y preguntas frecuentes mediante un panel de gestión.
3. Aplicar revisión de la Directora antes de publicar contenidos.
4. Ofrecer simulacros de práctica y un canal de consultas ciudadanas.
5. Proteger los datos y autorizar operaciones según la cuenta y su rol.
6. Entregar código, instalación reproducible y documentación de análisis, diseño, operación y pruebas.

4. Alcance

Alcance incluido

- Portal público con noticias, materiales de estudio, preguntas frecuentes, simulador y formulario de consultas.
- Panel administrativo para gestionar contenidos y leer las consultas recibidas.
- Aprobación de contenidos por la Directora antes de su publicación.
- Control de acceso por roles e historial de acciones administrativas.
- Gráficos asociados a las preguntas del simulador.

- Agenda de pruebas de manejo y renovaciones, franjas, cupos, reservas propias, cancelación y consultas por día, semana y mes.
- Dos frontends, API PHP nativa, esquema MySQL y entorno Docker Compose.
- Documentación de relevamiento, requisitos, planificación, diseño, infraestructura, seguridad y pruebas.

Alcance excluido

- Emisión, renovación o validación legal de la libreta de conducir desde el sistema.

5. Equipo e interesados

Participante	Responsabilidad
Tomás Cabrera	Liderazgo y backend.
Juan Robaina	Testing y documentación.
Gabriela Romero	Base de datos.
Verónica Romero	Frontend.
Juan Corrales	Frontend.
Inspector de Tránsito	Referente del cliente; aceptación de entregas y cambios de alcance en reuniones.
Directora de Tránsito	Validación de necesidades y aprobación de contenidos en el sistema.
Personal de la Intendencia	Administración de contenidos y consultas.
Ciudadanía	Consulta de información, materiales, simulacros y envío de mensajes.

La administración y el mantenimiento posteriores corresponden a la Intendencia.

6. Riesgos y tratamiento

Riesgo	Impacto	Tratamiento
Cambios de alcance	Diferencias entre la solución y las necesidades del cliente.	Registrar las solicitudes y actualizar la documentación afectada.
Interpretación incorrecta de las reservas	Confundir una reserva de franja con la emisión o renovación efectiva de la libreta.	Explicar el límite funcional en requisitos, manual y transferencia.
Pérdida de datos	Interrupción de la operación y pérdida de adjuntos.	Respaldar la base de datos, los archivos y la configuración.
Exposición de datos	Acceso o publicación indebidos.	Aplicar permisos, revisión de contenidos, controles de archivos y pruebas de seguridad.

7. Criterios de éxito

- El portal presenta contenido publicado y noticias dentro de su vigencia.
- Solo la Directora aprueba; la publicación es una acción posterior.
- Las consultas del portal llegan a la bandeja del personal.
- El simulacro corrige con las respuestas almacenadas en el servidor.
- La agenda respeta propiedad, duplicación y capacidad.
- El entorno inicia con Docker y conserva datos y archivos entre reinicios.
- Los requisitos se relacionan con historias, implementación y evidencia.

DOCUMENTO 02 | INGENIERÍA DE SOFTWARE

Guía de entrevista

Fuente: Entrevista.md | Versión 1.0 | Fecha 26/10/2026

Dato	Valor
Proyecto	Portal Vial - Educación Vial IMSJ
Fecha	09/07/2026, 16:05-16:45 (R-01).
Lugar o modalidad	Presencial - Polo Educativo Tecnológico (R-01).
Entrevistadores	Tomás Cabrera y Juan Robaina.
Entrevistado	Inspector de Tránsito, referente del cliente.

Objetivo

Conocer los procesos de la Sección Tránsito y las necesidades de información, contenidos y gestión para definir el alcance de la plataforma.

Presentación y proceso actual

- ¿Qué información necesita comunicar la Sección Tránsito a la ciudadanía?
- ¿Qué canales utiliza actualmente y cómo se actualizan?
- ¿Quiénes consultan esa información con mayor frecuencia?

Usuarios administrativos

- ¿Qué diferentes roles utilizarán el panel administrativo dentro de la IMSJ?
- ¿Hay funciones exclusivas de algunos usuarios?
- ¿Necesitan saber quién realizó cada cambio?
- ¿Cómo participa la Directora en la revisión y publicación de contenidos?

Agenda de trámites

- ¿Cómo es el proceso actualmente?
- ¿Quién administra las franjas de disponibilidad?
- ¿Las franjas se crean manualmente?
- ¿Qué duración tiene cada franja?
- ¿Cuántos cupos debe admitir cada una?
- ¿Qué datos del ciudadano son obligatorios para realizar una reserva?
- ¿Qué debería ver el usuario luego de agendarse?

Costo del trámite urgente

- ¿Es un costo fijo o depende de algún factor?

- En caso de depender de algún factor, ¿de cuáles?
- ¿Ese costo puede modificarse desde el panel administrativo?
- Si puede modificarse, ¿qué usuarios están autorizados a hacerlo?

Preguntas frecuentes

- ¿Necesitan clasificar las preguntas frecuentes por categorías?
- ¿Qué categorías utilizan?
- ¿Quién administra las preguntas y sus respuestas?
- ¿Cómo se incorporan los enlaces útiles?

Materiales de estudio

- ¿Qué formatos de archivos manejan?
- ¿Quién puede administrarlos dentro de los usuarios administrativos?
- ¿Qué público utilizará los materiales?
- ¿Los videos se publican como archivos o mediante enlaces?

Noticias

- ¿Cómo se define el período de vigencia de una noticia?
- ¿Las noticias vencidas deben seguir siendo consultables o desaparecer completamente?
- ¿Qué portada, imágenes y enlaces necesita cada noticia?
- ¿Quién prepara, aprueba y publica el contenido?

Operación y entrega

- ¿Qué versión se instalará para el cliente?
- ¿Dónde se alojará el sistema y qué dominio utilizará?
- ¿Cómo se organizarán soporte, cuentas y respaldos?
- ¿Qué manual y capacitación necesita el personal?

Registro de respuestas

Informe de entrevista y actas de reuniones.

Referencia

Registro de la entrevista y requerimientos resultantes.

DOCUMENTO 03 | INGENIERÍA DE SOFTWARE

Informe de entrevista

Fuente: informe entrevista.md | Versión 1.0 | Fecha 26/10/2026

Dato	Valor
Proyecto	Educación Vial IMSJ - Portal Vial
Instancia	Entrevista inicial
Fecha	09/07/2026, 16:05-16:45 (R-01).
Modalidad y lugar	Presencial - Polo Educativo Tecnológico (R-01).
Entrevistadores	Tomás Cabrera y Juan Robaina.
Entrevistado	Inspector de Tránsito, referente del cliente.
Registro o adjuntos	Guía de entrevista y acta R-01; informe incorporado a Git en a9401ad, 23/07/2026.

Objetivo de la entrevista

El objetivo de la entrevista fue relevar información sobre los requerimientos funcionales del sistema, identificar los usuarios que interactuarán con la aplicación y conocer las necesidades relacionadas con la gestión de contenidos, noticias, materiales de estudio y otros módulos.

Desarrollo de la entrevista

Usuarios administrativos

Pregunta: Dentro de los usuarios administrativos, ¿qué roles van a existir?

Respuesta: El sistema será administrado por el entrevistado y una compañera de equipo, quienes serán los encargados de gestionar el programa.

Pregunta: ¿La directora utilizará el sistema?

Respuesta: Sí. Se entiende que la directora también tendrá participación dentro del sistema.

Pregunta: ¿Habrá funciones exclusivas para algunos usuarios administrativos?

Respuesta: No. Actualmente no se considera necesario definir distintos niveles de permisos, ya que todos los usuarios administrativos tendrán los mismos privilegios.

Pregunta: ¿Necesitan saber quién realizó cada cambio dentro del sistema?

Respuesta: Sí. Es necesario que el sistema registre qué usuario realizó cada modificación para mantener un control de los cambios efectuados.

Agenda de trámites

Pregunta: ¿Cómo es actualmente el proceso para solicitar la licencia de conducir?

Respuesta: Actualmente la gestión se realiza por teléfono. Existe la intención de migrar este trámite a un formato web, aunque dicho desarrollo no forma parte del alcance de esta etapa del proyecto.

Preguntas frecuentes

Pregunta: ¿Las preguntas frecuentes deberán clasificarse por categorías?

Respuesta: Sí. Será necesario organizar las preguntas en distintas categorías para facilitar la búsqueda de información.

Pregunta: ¿Quién será el responsable de administrar las preguntas frecuentes?

Respuesta: Todo el equipo será responsable de crear, actualizar y gestionar las preguntas frecuentes.

Materiales de estudio

Pregunta: ¿Qué tipos de materiales utilizarán?

Respuesta: Se trabajará con distintos formatos, incluyendo documentos PDF, imágenes y videos.

La intención es elaborar manuales, normativas y leyes adaptadas a un lenguaje más sencillo y comprensible para adolescentes, evitando un enfoque excesivamente técnico.

Pregunta: ¿El objetivo principal es acercar la información a más personas?

Respuesta: Sí. El objetivo principal es llegar especialmente a los adolescentes mediante materiales de fácil comprensión.

Además, el equipo audiovisual será el encargado de producir videos explicativos para distintas situaciones relacionadas con el tránsito.

Los materiales disponibles en el sistema incluirán:

- Documentos PDF.
- Imágenes.
- Videos.

Noticias

Pregunta: ¿Cada noticia tendrá una fecha de inicio y una fecha de finalización de vigencia?

Respuesta: Sí. Cada noticia contará con un período de vigencia determinado.

Pregunta: ¿Cómo influye esa vigencia según el tipo de noticia?

Respuesta: Dependerá del contenido de la noticia. Algunas noticias permanecerán publicadas durante un período prolongado (por ejemplo, un año), mientras que la mayoría de las noticias relacionadas con el tránsito serán de carácter esporádico y permanecerán visibles únicamente durante el tiempo necesario.

Pregunta: ¿Quién decidirá la fecha de finalización de vigencia desde el panel de administración?

Respuesta: El entrevistado será el responsable de establecer la vigencia de cada noticia.

Pregunta: ¿Existen roles definidos para la publicación de noticias?

Respuesta: No existen roles diferenciados. Todo el equipo tendrá acceso a la gestión de noticias; sin embargo, las publicaciones deberán contar con la aprobación de la Dirección antes de hacerse visibles.

Pregunta: ¿Desean agregar algún nuevo requerimiento o funcionalidad respecto a este módulo?

Respuesta: Por el momento no se identifican nuevos requerimientos adicionales a los ya planteados.

Conclusiones

De la entrevista se desprenden los siguientes aspectos relevantes para el desarrollo del sistema:

- Todos los usuarios administrativos compartirán los mismos permisos de gestión.
- Será necesario implementar un registro de auditoría que permita identificar qué usuario realizó cada modificación.
- El trámite de licencia de conducir continuará siendo telefónico durante esta etapa del proyecto.
- Las preguntas frecuentes deberán organizarse por categorías y serán administradas por todo el equipo.
- El sistema permitirá almacenar documentos PDF, imágenes y videos como material de estudio.
- Los contenidos estarán orientados principalmente a adolescentes, utilizando un lenguaje claro y accesible.
- Las noticias deberán contar con fechas de inicio y fin de vigencia.
- La administración de noticias será realizada por el equipo, pero requerirá la aprobación de la Dirección antes de su publicación.
- No surgieron nuevos requerimientos adicionales durante la entrevista.

Requisitos derivados

Necesidad	Requisitos
Identificación de cambios administrativos	RNF3.
Agenda y reservas	RF3-RF4, RF11-RF16.
Categorías de preguntas frecuentes	RF19.
PDF, imágenes y videos	RF5, RF17, RF20.
Vigencia de noticias	RF8 y RNF7.
Aprobación de Dirección	RF21.

Evolución de permisos

Instancia	Regla	Fuente
Entrevista inicial	Administración compartida y aprobación de Dirección.	Respuestas de usuarios y noticias.
03/09/2026	Aprobación diferenciada por Directora y publicación posterior.	R-05 y CC-03.

Validación

Las necesidades relevadas se contrastaron con el cliente en la demostración del 03/09/2026. Los cambios solicitados quedaron incorporados y el resultado final fue aprobado en la demostración del 13/10/2026 registrada en R-06.

Referencias

Guía de preguntas, requisitos y control de cambios.

DOCUMENTO 04 | INGENIERÍA DE SOFTWARE

Requerimientos del sistema

Fuente: Requerimientos.md | Versión 1.0 | Fecha 26/10/2026

Requerimientos funcionales

Código	Requerimiento funcional
RF1	El sistema debe permitir iniciar sesión con cédula y contraseña.
RF2	El sistema debe permitir consultar anuncios y noticias de la Sección Tránsito.
RF3	El sistema debe permitir reservar una prueba de manejo.
RF4	El sistema debe permitir reservar la renovación normal o urgente de la libreta de conducir.
RF5	El sistema debe permitir acceder a materiales de estudio.
RF6	El sistema debe permitir consultar preguntas frecuentes.
RF7	El personal debe poder crear, modificar y administrar noticias.
RF8	El personal debe poder definir el período de vigencia de una noticia.
RF9	Las noticias deben admitir portada, galería de imágenes, texto y enlaces útiles.
RF10	El sistema debe permitir gestionar el estado de publicación de una noticia.
RF11	El personal debe poder cargar franjas para trámites normales.
RF12	El personal debe poder cargar franjas para trámites urgentes.
RF13	El personal debe poder cargar franjas para pruebas de manejo.
RF14	El personal debe poder consultar la agenda diaria.
RF15	El personal debe poder consultar la agenda semanal.
RF16	El personal debe poder consultar la agenda mensual.
RF17	El personal debe poder administrar materiales de estudio.
RF18	El personal debe poder mantener la sección de preguntas frecuentes.
RF19	Las preguntas frecuentes deben poder clasificarse por categorías.
RF20	Los materiales de estudio deben admitir PDF, imágenes y videos.
RF21	Los contenidos deben ser aprobados por la Directora antes de publicarse.
RF22	El sistema debe ofrecer simulacros de pruebas teóricas.
RF23	La ciudadanía debe poder enviar consultas y el personal debe poder leerlas en el panel.
RF24	El personal debe poder adjuntar material gráfico a las preguntas de los simulacros.

Requerimientos no funcionales

Código	Requerimiento no funcional
RNF1	Controlar el acceso según el tipo de usuario y su rol.
RNF2	Validar los datos recibidos antes de almacenarlos.
RNF3	Mantener un historial de acciones administrativas.
RNF4	Proteger los datos personales.
RNF5	Ofrecer una interfaz adaptable a dispositivos móviles.
RNF6	Proporcionar accesibilidad básica.
RNF7	Gestionar automáticamente la vigencia de las noticias.
RNF8	Evitar reservas duplicadas y el exceso de los cupos disponibles.
RNF9	Mostrar una confirmación visual después de reservar.
RNF10	Separar claramente los contenidos publicados de los no publicados.

DOCUMENTO 05 | INGENIERÍA DE SOFTWARE

Análisis de requerimientos - Portal Vial

Fuente: analisis_de_requerimientos.md | Versión 1.0 | Fecha 26/10/2026

1. Introducción

1.1 Propósito

Este documento describe el problema identificado junto con la Intendencia de San José - Sección Tránsito, la solución propuesta, los usuarios involucrados, el alcance y las principales restricciones de Portal Vial. La especificación detallada de los requisitos funcionales y no funcionales se mantiene en Requerimientos.md.

1.2 Cliente y partes interesadas

Parte interesada	Relación con el sistema	Necesidades principales
Intendencia de San José - Sección Tránsito	Cliente y responsable de la operación posterior	Disponer de un canal institucional centralizado, administrable y trazable.
Inspector de Tránsito	Referente del cliente	Validar necesidades, entregas y cambios de alcance.
Directora de Tránsito	Responsable de aprobación	Revisar y aprobar contenidos antes de su publicación.
Personal de la Sección Tránsito	Usuario interno	Mantener contenidos, consultas, cuentas, agenda e historial.
Ciudadanía y aspirantes	Usuarios externos	Consultar información, practicar, comunicarse y gestionar reservas.
Equipo RC5	Desarrollo y transferencia	Implementar, verificar, documentar y entregar el sistema.

2. Problema identificado

La Sección Tránsito necesita comunicar noticias, materiales de estudio y respuestas a preguntas frecuentes mediante un canal único y accesible. Sin una plataforma centralizada, la información puede quedar distribuida entre distintos medios, perder vigencia o depender de intervenciones técnicas para ser actualizada. Esta situación dificulta que la ciudadanía encuentre material confiable y que el personal mantenga una versión clara de lo publicado.

El cliente también necesita controlar el proceso previo a la publicación. El personal debe poder preparar información, pero los contenidos no deben hacerse públicos hasta que la Directora los revise y apruebe. Además, las modificaciones deben quedar asociadas a la persona que las realizó para facilitar la trazabilidad y la revisión interna.

Los aspirantes a obtener o renovar la libreta de conducir necesitan recursos de preparación, preguntas de práctica y un mecanismo claro para consultar disponibilidad. El personal, por su parte, necesita administrar franjas, cupos y reservas sin duplicaciones ni sobreasignación. Finalmente, la ciudadanía requiere un canal para enviar consultas que puedan ser recibidas y gestionadas por la Sección Tránsito.

Los grupos afectados son la ciudadanía que busca información, los aspirantes que practican o reservan, el personal que mantiene los datos y la Dirección que asume la responsabilidad de aprobación. Por eso el problema no se limita a publicar páginas: también comprende control de acceso, vigencia, integridad de cupos, trazabilidad, protección de datos y continuidad operativa.

3. Solución propuesta

Portal Vial reúne en una misma plataforma un portal público, un panel de gestión y una API conectada a una base de datos. La solución responde al problema de dispersión mediante un punto de consulta único para noticias, materiales de estudio y preguntas frecuentes.

El portal permite a la ciudadanía:

- consultar contenidos vigentes y materiales de preparación;
- resolver simulacros de pruebas teóricas con corrección del servidor;
- enviar consultas a la Sección Tránsito;
- crear una cuenta, consultar franjas disponibles y gestionar sus propias reservas.

El panel permite al personal:

- crear y mantener noticias, materiales y preguntas frecuentes;
- recibir consultas y registrar su lectura;
- administrar preguntas del simulador, usuarios, franjas, cupos y agenda;
- consultar un historial de acciones.

El circuito `Borrador → Pendiente → Aprobado → Publicado` separa la preparación de la aprobación. La Directora es el único rol autorizado para aprobar; el personal publica posteriormente el contenido aprobado. Las reglas se aplican en la API para que no dependan únicamente de los botones visibles en el navegador.

La solución se entrega en contenedores para que la Intendencia pueda reconstruirla, conservar datos y adjuntos, realizar respaldos y comprobar restauraciones sin depender del equipo donde fue desarrollada.

4. Alcance

4.1 Incluido

- Portal público con noticias, materiales de estudio y preguntas frecuentes.
- Simulacros de pruebas teóricas con material gráfico opcional.
- Consultas ciudadanas y bandeja interna con estado de lectura.
- Panel de gestión, roles, aprobación de contenidos e historial.
- Registro de ciudadanos e inicio y cierre de sesión.
- Agenda de trámites, franjas, cupos, reservas y cancelación propia.
- Consultas de agenda diaria, semanal y mensual.
- API PHP, persistencia MySQL y ejecución mediante Docker Compose.
- Procedimientos de instalación, operación, backup y restauración.

4.2 Excluido

- Emisión, renovación o validación legal de la libreta de conducir dentro del sistema.
- Pagos en línea y conexión con sistemas externos de expedientes.
- Envío automático de correos o mensajes de texto.
- Publicación en Internet sin dominio institucional, HTTPS y políticas operativas aprobadas.

5. Usuarios y funciones principales

Actor	Funciones principales
Visitante	Consultar noticias, materiales y FAQ; realizar simulacros; enviar consultas.
Ciudadano registrado	Iniciar sesión, reservar franjas, consultar y cancelar sus reservas.
Personal IMSJ	Gestionar contenidos, consultas, usuarios, preguntas, franjas, agenda e historial.
Directora	Realizar las funciones del personal y aprobar contenidos antes de su publicación.

6. Casos de uso principales

Caso de uso	Actor principal	Resultado esperado
Consultar contenidos publicados	Visitante	Obtiene información vigente sin autenticarse.
Resolver un simulacro	Visitante	Recibe la corrección calculada por el servidor.
Enviar una consulta	Visitante	El mensaje queda disponible en la bandeja interna.
Gestionar una reserva	Ciudadano registrado	Reserva o cancela una franja propia sin exceder cupos.
Preparar contenido	Personal IMSJ	Guarda un borrador y lo envía a revisión.
Aprobar contenido	Directora	Autoriza un contenido pendiente para su publicación posterior.
Publicar contenido	Personal IMSJ	Hace visible un contenido previamente aprobado.
Administrar agenda	Personal IMSJ	Mantiene franjas y consulta reservas por intervalo.
Consultar historial	Personal IMSJ	Revisa las acciones administrativas registradas.

7. Requerimientos y trazabilidad

El sistema cuenta con 24 requerimientos funcionales y 10 requerimientos no funcionales. Cada requisito se relaciona con historias del Product Backlog y escenarios del plan e informe de pruebas.

Grupo	Contenido
Funcionales	Acceso, noticias, materiales, preguntas frecuentes, simulacros, consultas, aprobación de contenidos, usuarios, agenda y reservas.
No funcionales	Roles, validación, auditoría, protección de datos, adaptación móvil, accesibilidad, vigencia e integridad de reservas.

8. Restricciones y supuestos

- La operación institucional requiere un servidor administrado, dominio y HTTPS antes de publicar el servicio en Internet.
- MySQL no se expone directamente a la red; el acceso a los datos se realiza mediante la API.
- Los videos se almacenan como enlaces y dependen de la disponibilidad del proveedor externo.
- La infraestructura parte de 2 vCPU, 4 GB de RAM y 30 GB SSD/NVMe para un objetivo de hasta 90 sesiones simultáneas. Debe validarse con una prueba de carga y ampliarse si CPU, RAM o disco superan de forma sostenida el 70 %.
- La política de conservación de datos y la responsabilidad permanente de los respaldos deben ser definidas por la Intendencia.

9. Arquitectura de referencia

El sistema se ejecuta con Docker Compose sobre Ubuntu Server. Apache sirve los frontends y dirige las solicitudes de `/api` al backend PHP; la API valida acceso y datos, aplica las reglas mediante servicios y utiliza repositorios PDO para comunicarse con MySQL.

Flujo principal: usuario → navegador/frontend → Apache → router de la API → controlador → servicio → repositorio → MySQL → respuesta HTTP → frontend.

La infraestructura y el recorrido completo se desarrollan en arquitectura propuesta; el modelo de datos y clases se encuentra en Diagramas.

DOCUMENTO 06 | INGENIERÍA DE SOFTWARE

Product Backlog

Fuente: backlog.md | Versión 1.0 | Fecha 26/10/2026

Épicas

ID	Épica	Requisitos
EP1	Acceso y control de roles	RF1, RNF1
EP2	Comunicación pública y noticias	RF2, RF7-RF10, RNF7, RNF10
EP3	Reservas ciudadanas	RF3-RF4, RNF8-RNF9
EP4	Gestión de agenda	RF11-RF16
EP5	Materiales de estudio	RF5, RF17, RF20
EP6	Preguntas frecuentes	RF6, RF18-RF19
EP7	Calidad y requisitos transversales	RNF2-RNF6
EP8	Simulacros de pruebas teóricas	RF22, RF24
EP9	Consultas ciudadanas	RF23

Historias de usuario

ID	Historia de usuario	Requisito	Estado
US1	Como usuario, quiero iniciar sesión con cédula y contraseña para acceder al sistema.	RF1	Implementada
US2	Como personal de IMSJ, quiero que haya control de roles y permisos para diferenciar usuarios.	RNF1	Implementada
US3	Como ciudadano, quiero consultar anuncios y noticias para mantenerme informado.	RF2	Implementada
US4	Como personal de IMSJ, quiero publicar y administrar noticias visibles para el público.	RF7	Implementada
US5	Como personal de IMSJ, quiero definir el período de vigencia de cada noticia.	RF8	Implementada
US6	Como personal de IMSJ, quiero agregar portada, galería, texto y enlaces a las noticias.	RF9	Implementada
US7	Como personal de IMSJ, quiero gestionar el estado de publicación de una noticia.	RF10	Implementada
US8	Como personal de IMSJ, quiero que se gestione automáticamente la vigencia de las noticias.	RNF7	Implementada
US9	Como personal de IMSJ, quiero distinguir los contenidos publicados de los no publicados.	RNF10	Implementada
US10	Como ciudadano, quiero reservar una prueba de manejo.	RF3	Implementada
US11	Como ciudadano, quiero reservar la renovación normal de la libreta.	RF4	Implementada
US12	Como ciudadano, quiero reservar la renovación urgente de la libreta.	RF4	Implementada
US13	Como personal de IMSJ, quiero evitar reservas duplicadas y excesos de cupo.	RNF8	Implementada
US14	Como ciudadano, quiero recibir una confirmación visual de mi reserva.	RNF9	Implementada
US15	Como personal de IMSJ, quiero cargar franjas para trámites normales.	RF11	Implementada
US16	Como personal de IMSJ, quiero cargar franjas para trámites urgentes.	RF12	Implementada
US17	Como personal de IMSJ, quiero cargar franjas para pruebas de manejo.	RF13	Implementada
US18	Como personal de IMSJ, quiero consultar la agenda diaria.	RF14	Implementada
US19	Como personal de IMSJ, quiero consultar la agenda semanal.	RF15	Implementada
US20	Como personal de IMSJ, quiero consultar la agenda mensual.	RF16	Implementada
US21	Como ciudadano, quiero acceder a materiales de estudio.	RF5	Implementada
US22	Como personal de IMSJ, quiero administrar los materiales de estudio.	RF17, RF20	Implementada
US23	Como ciudadano, quiero consultar las preguntas frecuentes.	RF6	Implementada
US24	Como personal de IMSJ, quiero mantener la sección de preguntas frecuentes.	RF18	Implementada
US25	Como personal de IMSJ, quiero consultar el historial de acciones administrativas.	RNF3	Implementada
US26	Como usuario, quiero que mis datos personales estén protegidos.	RNF4	Implementada
US27	Como ciudadano, quiero utilizar el sistema desde un dispositivo móvil.	RNF5	Implementada
US28	Como ciudadano, quiero contar con accesibilidad básica al utilizar el sistema.	RNF6	Implementada
US29	Como ciudadano, quiero consultar preguntas frecuentes por categoría.	RF19	Implementada
US30	Como Directora, quiero aprobar los contenidos antes de su publicación.	RF21	Implementada
US31	Como aspirante, quiero resolver un simulacro y revisar su corrección.	RF22	Implementada
US32	Como ciudadano, quiero enviar una consulta para que el personal pueda leerla.	RF23	Implementada
US33	Como personal, quiero adjuntar material gráfico a las preguntas del simulacro.	RF24	Implementada
US34	Como usuario, quiero que las entradas inválidas sean rechazadas.	RNF2	Implementada

DOCUMENTO 07 | INGENIERÍA DE SOFTWARE

Sprint Planning

Fuente: sprint_planning.md | Versión 1.0 | Fecha 26/10/2026

Puntos de esfuerzo

Los puntos de esfuerzo expresan el tamaño relativo de un trabajo. Consideran la cantidad de tareas, la complejidad técnica, las dependencias con otros componentes y la incertidumbre para implementarlo y verificarlo. Permiten comparar trabajos dentro del proyecto; no equivalen a horas, días ni cantidad de personas.

Las tablas utilizan los siguientes valores:

Puntos	Esfuerzo relativo	Interpretación
3	Bajo	Trabajo acotado y conocido, con pocas dependencias, como actualizar documentación o unificar estilos existentes.
5	Medio	Trabajo con varias tareas o componentes relacionados, que requiere coordinación y comprobaciones, como maquetar un conjunto de pantallas o integrar el acceso.
8	Alto	Trabajo con mayor complejidad, interacción o incertidumbre, como incorporar operaciones con JavaScript o integrar módulos completos con la API y sus validaciones.

El total de cada sprint es la suma de los puntos asignados a sus trabajos y representa su carga relativa estimada. Por ejemplo, el Sprint 1 suma **5 + 3 + 3 = 11 puntos**. Estos totales no miden horas efectivamente trabajadas ni demuestran por sí solos que las tareas estén terminadas.

Sprint 1 - Maquetación de los frontends

Período: 10/07-23/07/2026.

Objetivo: dar forma a las pantallas principales y ordenar los requisitos relevados.

Trabajo	Puntos
Maquetar el panel IMSJ: noticias, agenda, franjas, materiales y preguntas frecuentes.	5
Avanzar en el ingreso y las noticias del portal público.	3
Documentar la entrevista y ordenar los requerimientos.	3
Total	**11**

Sprint 2 - Pantallas e interacción con JavaScript

Período: 24/07-06/08/2026.

Objetivo: ampliar las pantallas y permitir operar el panel con datos de ejemplo.

Trabajo	Puntos
Completar las pantallas públicas de materiales, agenda, reservas, preguntas frecuentes y renovación.	5

Trabajo	Puntos
Agregar JavaScript al panel para formularios, listados y operaciones con datos locales.	8
Actualizar las historias de usuario y la propuesta de arquitectura.	3
Total	**16**

Sprint 3 - Unificación visual y preparación de la integración

Período: 07/08-20/08/2026.

Objetivo: unificar la presentación del portal y preparar su estructura para conectarla con el backend.

Trabajo	Puntos
Incorporar la segunda versión del portal público y renovar el acceso.	5
Unificar encabezados, pie de página, iconos y estilos.	3
Documentar las clases, atributos y métodos previstos.	3
Total	**11**

Sprint 4 - Backend e integración

Período: 21/08-03/09/2026.

Objetivo: conectar los frontends con la API y preparar una versión local para revisar con el cliente.

Trabajo	Puntos
Preparar el backend y la estructura de la base de datos.	5
Integrar el acceso y los roles con los frontends.	5
Implementar e integrar noticias, materiales y preguntas frecuentes mediante la API.	8
Implementar e integrar franjas, reservas y consulta de agenda.	8
Incorporar el simulacro y la gestión del banco de preguntas.	8
Incorporar la administración de personal y la consulta del historial.	5
Agregar pruebas automatizadas y herramientas de ejecución con Docker.	5
Total	**44**

Sprint 5 - Cambios solicitados por el cliente

Período: 04/09-13/10/2026.

Objetivo: incorporar los cambios solicitados por el cliente y presentar la versión actualizada.

Trabajo	Puntos
Incorporar el formulario de consultas y la bandeja de lectura en el panel IMSJ.	5
Implementar la aprobación de contenidos por la Directora antes de su publicación.	8
Permitir material gráfico en las preguntas del simulador.	3
Integrar los cambios y preparar la demostración al cliente.	3

Trabajo	Puntos
Total	**19**

DOCUMENTO 08 | INGENIERÍA DE SOFTWARE

Actas de reuniones

Fuente: actas_reuniones.md | Versión 1.0 | Fecha 26/10/2026

Proyecto: Educación Vial IMSJ - Portal Vial.

R-01 - 09/07/2026

Dato	Valor
Fecha	09/07/2026
Horario	16:05-16:45
Modalidad y lugar	Presencial - Polo Educativo Tecnológico
Tipo	Cliente

Participantes

Participante	Rol	Asistencia
Tomás Cabrera	Líder	Sí
Juan Robaina	Co-líder	Sí
Inspector de Tránsito	Cliente	Sí
Gabriela Romero	Desarrolladora	No
Verónica Romero	Desarrolladora	No
Juan Corrales	Desarrollador	No

Objetivo

Realizar la entrevista inicial y organizar las preguntas del relevamiento.

Temas tratados

- Usuarios administrativos y funciones de gestión.
- Agenda de trámites, franjas y costo urgente.
- Noticias, preguntas frecuentes y materiales de estudio.

Desarrollo

Se trabajó sobre las preguntas para la entrevista con el cliente y su puesta en limpio. La guía se organizó por módulos para abordar usuarios, funcionamiento de trámites, gestión de contenidos y condiciones de publicación.

El instrumento de relevamiento reúne preguntas sobre permisos, identificación de cambios, duración y cupos de franjas, datos de reservas y costo urgente. En contenidos se consideran categorías de preguntas frecuentes, formatos de materiales y vigencia de noticias.

Resultado

Quedó preparada una guía de entrevista por módulos con las necesidades relevadas sobre usuarios, trámites y contenidos.

R-02 - 22/07/2026

Dato	Valor
Fecha	22/07/2026
Horario	4:15-5:15
Modalidad y lugar	Presencial - UTU, hora libre
Tipo	Equipo

Participantes

Participante	Rol	Asistencia
Tomás Cabrera	Líder	Sí
Juan Robaina	Co-Líder	Sí
Gabriela Romero	Desarrolladora	Sí
Verónica Romero	Desarrolladora	Sí
Juan Corrales	Desarrollador	Sí

Objetivo

Revisar la concordancia de requerimientos, épicas y alcance del Project Charter.

Temas tratados

- Alcance posterior a la entrevista.
- Requerimientos y épicas.
- Project Charter.

Desarrollo

El equipo revisó los requerimientos y las épicas en relación con el alcance del Project Charter. El trabajo se centró en la correspondencia entre el problema relevado, las funciones descritas y la organización del producto.

El charter reúne objetivos, interesados y alcance; el catálogo identifica las funciones y condiciones de calidad; el backlog agrupa las historias en épicas de acceso, comunicación pública, agenda, materiales, preguntas frecuentes y calidad.

Resultado

Se estableció la correspondencia entre el alcance del Project Charter, los requerimientos y las épicas del backlog.

R-03 - 28/07/2026

Dato	Valor
Fecha	28/07/2026
Horario	4:45-7:00
Modalidad y lugar	Presencial - UTU, clase de SSOO
Tipo	Equipo

Participantes

Participante	Rol	Asistencia
Tomás Cabrera	Líder	Sí
Juan Robaina	Co-lider	Sí
Gabriela Romero	Desarrolladora	Sí
Verónica Romero	Desarrolladora	Sí
Juan Corrales	Desarrollador	Sí

Objetivo

Analizar las historias de usuario a partir de las épicas y los requerimientos.

Temas tratados

- Historias de usuario.
- Relación entre épicas y requerimientos.
- Organización del backlog.

Desarrollo

El equipo analizó las historias de usuario tomando como base las épicas y los requerimientos. Se trabajó sobre la relación entre las necesidades del proyecto y las operaciones que utilizan la ciudadanía y el personal de la Intendencia.

La organización del backlog vincula acceso y permisos, consulta y administración de contenidos, agenda y condiciones de calidad. Cada historia mantiene un identificador para relacionar su necesidad con los requisitos y las comprobaciones del sistema.

Resultado

Las historias de usuario quedaron organizadas en el backlog y vinculadas con sus épicas y requerimientos.

R-04 - 11/08/2026

Dato	Valor
Fecha	11/08/2026
Horario	4:10-5:00
Modalidad y lugar	Virtual - WhatsApp
Tipo	Equipo

Participantes

Participante	Rol	Asistencia
Tomás Cabrera	Líder	Sí
Juan Robaina	Co-lider	Sí
Gabriela Romero	Desarrolladora	Sí
Verónica Romero	Desarrolladora	Sí
Juan Corrales	Desarrollador	Sí

Objetivo

Identificar clases, atributos y métodos a partir de la documentación del proyecto.

Temas tratados

- Entidades y datos del dominio.
- Operaciones de los módulos.
- Documento de clases, atributos y métodos.

Desarrollo

El equipo analizó la documentación para distinguir las clases del sistema, sus atributos y los métodos asociados a sus operaciones. Luego se organizó el material en un documento utilizando asistencia de IA.

El trabajo de modelado relaciona los datos de usuarios, contenidos, franjas y reservas con las operaciones de consulta, alta, modificación y eliminación. La justificación de clases desarrolla las responsabilidades de los componentes y su relación con la persistencia.

Resultado

Quedó elaborado el documento de clases, atributos y métodos del sistema.

R-05 - 03/09/2026

Dato	Valor
Fecha	03/09/2026
Horario	4:10-5:00
Modalidad y lugar	Presencial - UTU
Tipo	Cliente

Participantes

Participante	Rol	Asistencia
Tomás Cabrera	Líder	Sí
Juan Robaina	Co-lider	Sí
Gabriela Romero	Desarrollador	Sí
Verónica Romero	Desarrolladora	Sí
Juan Corrales	Desarrollador	Sí
Directora de Tránsito	Cliente	Sí
Inspector de Tránsito	Cliente	Sí

Objetivo

Presentar el sistema y contrastar la solución con las necesidades del cliente.

Temas tratados

- Demostración funcional.
- Consultas sobre el comportamiento del sistema.
- Cambios en consultas ciudadanas, aprobación y simulacros.

Desarrollo

El equipo presentó el sistema a la Directora y al Inspector de Tránsito para revisar la interpretación de lo planteado en la entrevista inicial. Durante la demostración se realizaron consultas sobre el funcionamiento y se solicitaron ampliaciones de la solución.

Se planteó incorporar un formulario de consultas en el pie del portal y un apartado en el panel para desplegar y leer los mensajes. También se solicitó que los contenidos pasaran por validación de la Directora antes de publicarse, separando ambas acciones.

En el simulador se solicitó admitir material gráfico asociado a las preguntas.

Resultado

Se solicitaron tres ampliaciones:

- Formulario público de consultas y lectura de los mensajes en el panel IMSJ.
- Validación de contenidos por la Directora antes de su publicación.
- Incorporación de material gráfico en las preguntas del simulador.

R-06 - 13/10/2026

Dato	Valor
Fecha	13/10/2026
Tipo	Cliente

Participantes

Participante	Rol	Asistencia
Tomás Cabrera	Líder	Sí
Juan Robaina	Co-líder	Sí
Gabriela Romero	Desarrolladora	Sí
Verónica Romero	Desarrolladora	Sí
Juan Corrales	Desarrollador	Sí
Nacho	Cliente	Sí

Objetivo

Presentar la demostración del sistema con los cambios realizados.

Temas tratados

- Demostración de los cambios.
- Revisión del resultado.
- Aprobación del cliente.

Desarrollo

El equipo presentó a Nacho la demostración del sistema con los cambios realizados. Luego de revisar el funcionamiento, aprobó el resultado y manifestó que le gustó la solución presentada.

Resultado

Nacho aprobó el resultado de la demostración.

DOCUMENTO 09 | INGENIERÍA DE SOFTWARE

Sprint Review

Fuente: actas_sprint_review.md | Versión 1.0 | Fecha 26/10/2026

Sprint	Período	Incremento	Resultado y ajustes
Sprint 1	10/07-23/07/2026	Maquetación del panel IMSJ, acceso y noticias del portal público.	Se continuó con las pantallas restantes y la interacción mediante JavaScript.
Sprint 2	24/07-06/08/2026	Pantallas públicas, formularios y operaciones con datos locales.	Se avanzó con la unificación visual y la preparación de la integración.
Sprint 3	07/08-20/08/2026	Segunda versión del portal, nuevo acceso, estilos compartidos y documentación de clases.	Se preparó la conexión con el backend y la incorporación del simulacro.
Sprint 4	21/08-03/09/2026	Integración del backend, base de datos, contenidos, agenda y simulacro.	La demostración al cliente originó las solicitudes de consultas, aprobación de contenidos y gráficos para el simulador.
Sprint 5	04/09-13/10/2026	Implementación de los cambios solicitados por el cliente.	Nacho revisó la demostración, aprobó el resultado y manifestó conformidad con la solución.

DOCUMENTO 10 | INGENIERÍA DE SOFTWARE

Control de cambios

Fuente: control_cambios.md | Versión 1.0 | Fecha 26/10/2026

Código	Cambio	Motivo	Solicitante	Estado
CC-01	Incorporar simulacros de pruebas teóricas.	Permitir que los aspirantes practiquen y revisen la corrección dentro del mismo portal.	Equipo RC5; incorporado al alcance validado.	Completado
CC-02	Incorporar un formulario público de consultas y una bandeja de lectura en el panel IMSJ.	Permitir que la ciudadanía envíe consultas y que el personal pueda leerlas.	Directora e Inspector de Tránsito.	Completado
CC-03	Separar la aprobación de contenidos de su publicación.	Permitir que la Directora revise y apruebe los contenidos antes de que sean publicados.	Directora e Inspector de Tránsito.	Completado
CC-04	Permitir material gráfico en las preguntas del simulador.	Representar situaciones de tránsito mediante imágenes.	Directora e Inspector de Tránsito.	Completado
CC-05	Sustituir Laravel por PHP nativo.	Facilitar la documentación y comprensión del backend.	Equipo del proyecto.	Completado

DOCUMENTO 11 | INGENIERÍA DE SOFTWARE

Plan e informe de pruebas - Portal Vial

Fuente: plan_informe_pruebas.md | Versión 1.0 | Fecha 26/10/2026

Proyecto: Educación Vial IMSJ. **Fecha documental:** 21/10/2026. **Línea de implementación:** 1a43229.

1. Objetivo y alcance

Comprobar que la API aplica el contrato HTTP, persiste los datos esperados, protege las operaciones por cuenta y rol y mantiene la integridad ante errores y concurrencia. El alcance incluye autenticación, noticias, materiales, FAQ, simulacros, consultas, usuarios, historial y agenda.

La verificación combina una suite de integración HTTP/MySQL, auditoría Bash de seguridad, análisis estático y exploración dinámica del portal local. La matriz relaciona requisitos e historias con escenarios concretos y conserva el alcance de cada resultado.

2. Organización y entorno

Elemento	Configuración
Coordinación de testing y documentación	Juan Robaina, según los roles del equipo.
Backend	Tomás Cabrera.
Base de datos	Gabriela Romero.
Frontend	Verónica Romero y Juan Corrales.
Suite de integración	integracion.py; Python estándar y cliente MySQL.
Runtime registrado	PHP 8.5.11 y MySQL 8.4.11.
Base aislada	`imsj_test_final_20261021`.
Concurrencia	Dos procesos HTTP independientes conectados a la misma base.
Auditoría API	security_api.sh, contra `http://127.0.0.1:8000`.
SAST	Semgrep 1.180.0; JSON registrado.
DAST	ZAP 2.17.0; baseline del portal local.
Puertos	Nmap 7.98; registro de 8000/tcp.

Los nombres de responsables describen las áreas del equipo. El resultado automatizado identifica su entorno, fecha y artefactos mediante el registro de ejecución.

3. Preparación y ejecución

Integración

1. Preparar una base vacía cuyo nombre comience con `imsj_test_` y una configuración separada de la instalación del equipo.
2. Definir `DB_HOST`, `DB_PORT`, `DB_DATABASE`, `DB_USERNAME`, `DB_PASSWORD` e `IMSJ_TEST_MYSQL` para ese entorno.

3. Iniciar dos procesos PHP contra la misma base y definir sus direcciones en `IMSJ_TEST_URL` e `IMSJ_TEST_URL_2`.
4. Definir `IMSJ_TEST_REPORT` con la ruta del informe de la nueva ejecución.
5. Ejecutar `python tests/integracion.py` desde `backend`.
6. Conservar la salida, revisar el resultado y comparar los hashes de los PHP con la versión evaluada.

La suite crea el esquema y sus datos sintéticos. Comprueba que la base esté vacía antes de importar tablas. Los escenarios de rollback introducen un trigger de fallo en esa base y lo retiran tras comprobar el comportamiento.

Seguridad de API

Ejecutar el script Bash sobre una instancia de prueba autorizada. Para los escenarios autenticados utilizar cuentas descartables de los perfiles público, personal y Directora. Las opciones de escritura, token vencido y límite de intentos se describen en la guía de ejecución.

Con `IMSJ_SECURITY_REQUIRE_FULL=1`, cualquier prueba omitida impide considerar completa la ejecución. Conservar por separado los resultados de cada perfil y de la ejecución final.

Criterios de evaluación

- Una comprobación de integración pasa si coincide el estado HTTP esperado, el contrato de respuesta y las verificaciones de persistencia que contiene el escenario.
- La integración finaliza con resultado OK cuando todas sus aserciones se cumplen y se cubren las declaraciones de ruta extraídas del router.
- La auditoría distingue aprobadas, fallidas y omitidas. Una omisión conserva ese estado hasta una ejecución que cubra el escenario.
- Un aviso SAST o DAST requiere análisis de su ruta, contexto y alcance. Su registro conserva la severidad original de la herramienta.
- Una prueba de API demuestra el comportamiento del servidor evaluado; la aceptación de una pantalla requiere recorrer además su interfaz.

4. Matriz de trazabilidad y escenarios

ID	Requisitos / historias	Escenario y resultado comprobado	Evidencia
PT-01	RF1, RNF1; US1-US2	Login y registro, identidad, rechazo de acceso sin token y de rol público en administración.	Integración y auditoría API.
PT-02	RF2, RF7-RF10, RNF7, RNF10; US3-US9	CRUD de noticias, fechas, borradores ocultos y publicación visible; portada, galería y enlaces mediante API.	Integración.
PT-03	RF21; US30; CC-03	Personal envía a revisión y recibe 403 al aprobar; Directora aprueba; el personal publica después.	Integración y auditoría API.
PT-04	RF5, RF17, RF20; US21-US22	VIDEO por URL, PDF cargado y descargado, actualización multipart y rechazo de falso PDF.	Integración.
PT-05	RF6, RF18; US23-US24	Alta y edición de FAQ, ocultamiento previo a publicar y consulta pública posterior.	Integración.
PT-06	RF22, RF24; US31, US33; CC-01, CC-04	Pregunta con imagen descargable, respuesta correcta ausente en consulta pública y corrección del servidor; rechazo de respuesta duplicada.	Integración.
PT-07	RF23; US32; CC-02	Mensaje público guardado, recepción en bandeja sin leer y marca de lectura persistida.	Integración.
PT-08	RF3, RF13, RNF8-RNF9; US10, US13-US14, US17	Franja de prueba de manejo, reserva propia, duplicación rechazada, franja ocupada protegida y cancelación propia 204.	Integración.
PT-09	RF14-RF16; US18-US20	Consulta de agenda en vistas día, semana y mes; rechazo de vista anual inválida.	Integración.
PT-10	RNF8; US13	Dos solicitudes simultáneas para un único cupo: 201 y 422; exactamente una fila en MySQL.	Integración.
PT-11	RNF3; US25	Historial con acciones persistidas; fallo provocado de auditoría revierte el material y elimina el archivo nuevo.	Integración.
PT-12	RNF1, RNF4; US2, US26	Token hash, vencimiento, revocación, desactivación y rechazo de cancelación ajena.	Integración y auditoría API.
PT-13	RNF2; US34	JSON inválido, validación de campos, archivos disfrazados, entradas SQLi/XSS controladas y respuestas sin error interno en esos escenarios.	Integración y auditoría API.
PT-14	RNF4; US26	Acceso privado bloqueado, CORS permitido/ajeno, cabeceras y rate limit.	Auditoría API.
PT-15	RF9; US6	Portada, galería, texto y enlaces persistidos por la API y presentados en el portal público.	Controlador y vista pública.
PT-16	RF4, RF11-RF12; US11-US12, US15-US16	Franjas y reservas disponibles para renovación normal y urgente.	Controlador de reservas y servicio.
PT-17	RF19; US29	Alta, edición, listado y filtro de preguntas frecuentes por categoría.	Controlador y vista pública.
PT-18	RNF5-RNF6; US27-US28	Interfaces adaptables, navegación mediante teclado, foco visible y etiquetas en formularios.	Estilos públicos y estilos del panel.

5. Informe de integración del 21/10

Métrica	Resultado registrado
Fecha y hora UTC	2026-10-21T14:47:36.610545+00:00
Resultado	OK
Comprobaciones	192
Combinaciones distintas de método y ruta solicitada	60
Declaraciones de endpoint cubiertas	46
Último cupo concurrente	201 y 422; una reserva persistida.
Archivos PHP identificados por SHA-256	43

Registro: integracion-final.json.

Las 192 comprobaciones incluyen estados HTTP, claves de respuestas JSON, respuestas 204 sin cuerpo y verificaciones específicas de datos y archivos. La cobertura de 46 declaraciones de ruta se calcula normalizando identificadores numéricos. Esta medida describe cobertura de rutas; la suite no calcula cobertura de líneas de código.

6. Informe de seguridad

La ejecución completa, del 21/10 a las 14:42:08 UTC, registra **43 aprobadas, 0 fallidas y 0 omitidas**. Las ejecuciones por perfil se conservan en el registro de verificación.

Semgrep registra seis avisos y un diagnóstico de análisis parcial del Dockerfile. ZAP conserva cinco tipos de alerta en su JSON y el resumen de baseline registra 0 FAIL, 4 WARN y 63 PASS. El contexto de cada hallazgo y su relación con el código se desarrolla en el registro consolidado.

7. Alcance de las conclusiones

La integración respalda el funcionamiento de los escenarios de API sobre la base aislada. La auditoría respalda las comprobaciones ejecutadas contra la instancia local. La prueba de concurrencia evalúa dos solicitudes por el último cupo y no sustituye una prueba de carga. La infraestructura inicial de 2 vCPU, 4 GB de RAM y 30 GB SSD/NVMe se propone para un objetivo de 90 sesiones simultáneas; ese objetivo debe validarse antes de presentarlo como capacidad operativa demostrada.

Las historias US1-US34 y los requisitos RF1-RF24 y RNF1-RNF10 figuran implementados. Los resultados de integración y de seguridad respaldan los escenarios incluidos en sus respectivas matrices.

Evaluación de entrega	Registro
Recorrido manual de la versión final	Se ejecutará sobre el candidato exacto después del congelamiento de la entrega.
Restauración de un respaldo completo	Pendiente de ejecutar y comprobar en Ubuntu Server 26.04 LTS antes de la entrega.
Carga de 90 usuarios simultáneos	Pendiente de ejecutar sobre el entorno objetivo mientras se registran solicitudes por segundo, latencia, errores, CPU, memoria e I/O; revisar recursos ante un consumo sostenido superior al 70 %.
Aceptación del cliente	La reunión R-06 registra la demostración del 13/10 y la aprobación del resultado.

DOCUMENTO 12 | INGENIERÍA DE SOFTWARE

Manual de usuario - Portal Vial

Fuente: manual_usuario.md | Versión 1.0 | Fecha 26/10/2026

Proyecto: Educación Vial IMSJ. **Equipo:** RC5.

1. Acceso y navegación

Portal Vial reúne noticias de Tránsito, materiales de estudio, preguntas frecuentes y práctica de pruebas teóricas. Desde el pie de las páginas se pueden enviar consultas al personal de la Intendencia de San José.

Para ingresar, abrir en el navegador la dirección del Portal Vial proporcionada por el responsable del sistema. La dirección técnica, el dominio y los puertos se configuran durante la instalación y no requieren intervención de los usuarios finales.

El menú permite cambiar de sección. En pantallas pequeñas se despliega mediante el botón de menú. Los mensajes de carga, confirmación y error aparecen junto a la operación correspondiente.

Perfil	Funciones
Visitante	Noticias, materiales, FAQ, simulacro y envío de consultas.
Ciudadano con cuenta	Funciones públicas, consulta de disponibilidad y gestión de reservas propias.
Personal IMSJ	Gestión de contenidos, banco de preguntas, consultas, cuentas, historial y agenda.
Directora	Funciones del personal y aprobación de noticias, materiales y FAQ.

2. Noticias, materiales y preguntas frecuentes

Noticias

1. Seleccionar **Noticias** en la navegación del portal.
2. Consultar los títulos, imágenes y textos disponibles.
3. Volver a la sección para consultar otra publicación.

El portal presenta noticias publicadas dentro de su período de vigencia. Una noticia que se encuentra en preparación, revisión o aprobación permanece en el panel interno.

Materiales de estudio

1. Seleccionar **Materiales de estudio**.
2. Identificar el recurso por su nombre y tipo.
3. Seleccionar **Abrir material**.

Los PDF e imágenes se abren desde el almacenamiento del sistema. Los videos se consultan mediante el enlace cargado por el personal y necesitan acceso al sitio donde están alojados. La apertura en otra pestaña depende de la configuración del navegador.

Preguntas frecuentes

Seleccionar **Preguntas frecuentes** y leer la pregunta junto a su respuesta. Esta sección presenta las FAQ publicadas por el personal mediante el circuito de aprobación.

3. Realizar un simulacro

1. Abrir la sección del simulacro de prueba teórica.
2. Esperar la carga de las preguntas. Cada sesión presenta hasta diez, según el banco disponible.
3. Leer el enunciado y observar su imagen cuando la tenga.
4. Marcar una de las cuatro opciones de cada pregunta.
5. Utilizar el botón de corrección del formulario.
6. Revisar el total de aciertos y las opciones señaladas como correctas o incorrectas.
7. Utilizar el botón de nueva simulación para comenzar otra práctica.

El formulario exige responder todas las preguntas presentadas. La corrección se obtiene del servidor después del envío. La práctica muestra aciertos sobre el total y permite revisar las respuestas; funciona sin temporizador ni calificación mínima de aprobación.

Si aparece **Todavía no hay preguntas disponibles**, el banco de preguntas está vacío. El personal puede incorporar preguntas desde su panel.

4. Enviar una consulta

1. Ir al pie de una página del portal y localizar **¿Tenés una consulta?**.
2. Completar nombre, correo electrónico y mensaje.
3. Seleccionar **Enviar consulta**.
4. Esperar el mensaje **Consulta enviada correctamente**.

El nombre admite hasta 120 caracteres y el mensaje hasta 2000. El correo debe tener un formato válido. La confirmación indica que el mensaje fue guardado para su lectura por el personal. Si aparece un error, conservar el texto y corregir el campo indicado antes de reenviar.

5. Iniciar y cerrar sesión

En la pantalla de acceso, elegir **Ciudadano** o **Personal IMSJ** según la cuenta. Ingresar cédula y contraseña y seleccionar **Ingresar**. Cada pestaña comprueba que la cuenta pertenezca al perfil correspondiente.

Para crear una cuenta ciudadana, elegir **Ciudadano** → **Registrarme**, completar cédula, contraseña y confirmación, y seleccionar **Crear cuenta**. La contraseña debe tener al menos seis caracteres; las dos entradas deben coincidir.

La sesión dura hasta ocho horas. Un nuevo ingreso con la misma cuenta reemplaza la sesión anterior. Utilizar **Cerrar sesión** al finalizar, especialmente en equipos compartidos. Cuando la sesión vence o se revoca, ingresar nuevamente para continuar con operaciones protegidas.

Ante el mensaje de demasiados intentos, esperar el intervalo indicado antes de volver a intentar. Las contraseñas distinguen los espacios ingresados.

6. Reservas

Las pantallas de agenda permiten consultar y reservar franjas disponibles para pruebas de manejo y renovaciones. La reserva organiza la disponibilidad, pero no emite ni renueva por sí misma la libreta de conducir.

Reservar un horario

1. Abrir **Agenda** para una prueba de manejo o **Renovar licencia** para una renovación.
2. En renovación, elegir modalidad normal o urgente.
3. Consultar fecha, horario y cupos disponibles.
4. Seleccionar **Reservar** en la franja elegida.

5. Si la pantalla solicita ingreso, utilizar una cuenta ciudadana y volver a la agenda.
6. Esperar la confirmación con fecha y hora.

El sistema vuelve a comprobar la disponibilidad al confirmar. Si otra persona ocupa el último cupo o la cuenta ya tiene esa franja reservada, muestra el error correspondiente. La modalidad urgente identifica el tipo de reserva en esta versión.

Consultar y cancelar

1. Seleccionar **Ver mis reservas** o **Consultar reserva**.
2. Revisar las reservas actuales y futuras asociadas a la cuenta.
3. Para retirar una, seleccionar **Cancelar reserva**.
4. Confirmar la pregunta de la pantalla.
5. Comprobar que desaparezca de la lista.

La cancelación libera el cupo. Para elegir otro horario se realiza una nueva reserva. Cada cuenta puede cancelar sus propias reservas.

7. Acceder al panel IMSJ

Ingresar desde **Personal IMSJ** mediante la dirección proporcionada por el responsable del sistema. La barra lateral permite cambiar entre noticias, materiales, FAQ, preguntas del simulador, consultas, usuarios y agenda.

La primera cuenta de personal se crea durante la configuración inicial del sistema. Las cuentas siguientes se crean desde la sección de usuarios. El panel comunica la clave inicial al completar el alta.

Preparar una noticia

1. Abrir **Noticias** y seleccionar **Nueva noticia**.
2. Completar título, cuerpo y fin de vigencia.
3. Seleccionar una portada si corresponde: JPG, PNG o WEBP de hasta 2 MB.
4. Seleccionar **Guardar borrador**.
5. Revisar la noticia en la lista y enviarla a revisión.

El formulario fija el inicio de vigencia al crear la noticia y conserva ese dato al editarla. El botón **Editar** permite modificar los campos de la pantalla. La búsqueda filtra por título, texto o estado.

Aprobar y publicar contenidos

Estado	Operación disponible	Resultado
Borrador	**Enviar a revisión**	Pendiente.
Pendiente, con cuenta Directora	**Aprobar**	Aprobado.
Aprobado	**Publicar**	Publicado.
Publicado	**Retirar**	Borrador.

Este circuito se aplica a noticias, materiales y FAQ. Una cuenta de personal observa **Pendiente de Directora** durante la revisión. La aprobación deja el contenido preparado para publicar; luego se utiliza **Publicar**. Al editar un contenido aprobado o publicado, vuelve a borrador y recorre nuevamente el circuito.

Gestionar materiales

1. Abrir **Materiales** y utilizar el alta de material.
2. Completar el nombre y elegir PDF, imagen o video.
3. Para PDF, seleccionar un archivo de hasta 10 MB. Para imagen, seleccionar JPG, PNG o WEBP de hasta 5 MB.
4. Para video, completar una URL HTTP o HTTPS.

5. Guardar y seguir el circuito de revisión, aprobación y publicación.

En una edición, la pantalla permite conservar el archivo actual si se mantiene su tipo. **Abrir recurso** permite comprobar el material cargado. Antes de eliminar, la pantalla solicita confirmación.

Gestionar preguntas frecuentes

Abrir la sección de preguntas frecuentes, crear o editar el enunciado y la respuesta, guardar y seguir el circuito de publicación. La búsqueda ayuda a localizar preguntas existentes. La eliminación requiere confirmar la acción.

Gestionar preguntas del simulador

1. Abrir el banco de preguntas del simulador y crear una pregunta.
2. Completar el enunciado y las cuatro opciones A, B, C y D.
3. Seleccionar la respuesta correcta.
4. Adjuntar, si corresponde, una imagen JPG, PNG o WEBP de hasta 2 MB.
5. Guardar y comprobar la fila del banco.

Al editar una pregunta con imagen se puede conservarla, sustituirla o marcar su eliminación. El banco del simulador tiene acciones propias de alta, edición y eliminación; sus preguntas se utilizan en la práctica pública.

Leer consultas ciudadanas

Abrir **Consultas**, buscar por nombre, correo o texto y desplegar el mensaje. Al abrir una consulta nueva se registra su lectura y se actualiza el contador de no leídas. **Escribir a** abre el programa de correo configurado en el equipo; el envío se realiza desde ese programa.

Administrar cuentas e historial

En **Usuarios**, completar nombre, cédula y rol para crear acceso. El panel muestra la clave inicial al terminar. **Quitar acceso** desactiva la cuenta seleccionada y sus sesiones, conservando sus relaciones históricas. La pantalla identifica la cuenta propia como **Tu cuenta**.

La campana abre **Historial de acciones** y consulta las veinte acciones más recientes. Allí se identifica a la persona, operación, elemento y fecha registrados por el sistema.

Administrar agenda

En **Franjas de disponibilidad**, cargar fecha, hora de inicio, hora de fin, trámite y cupos. Revisar que el horario final sea posterior al inicial. Una franja con reservas conserva sus relaciones y el sistema impide eliminarla mientras las tenga.

En **Agenda**, seleccionar fecha y vista diaria, semanal o mensual. Las consultas reúnen las reservas vigentes y futuras del intervalo elegido.

8. Documentos relacionados

Requisitos y procedimiento de instalación en Linux con Docker.

DOCUMENTO 13 | INGENIERÍA DE SOFTWARE

Declaración de compromiso ético en el uso de inteligencia artificial

Fuente: declaracion_etica_ia.md | Versión 1.0 | Fecha 26/10/2026

Nombre del proyecto: Educación Vial IMSJ - Portal Vial

Equipo: Tomás Cabrera, Juan Robaina, Gabriela Romero, Verónica Romero y Juan Corrales

Fecha: 23/10/2026

Declaración

Declaramos que el análisis del problema, el relevamiento con el cliente, las decisiones de alcance, los criterios de aceptación y las conclusiones del proyecto fueron evaluados y asumidos por el equipo RC5. Las herramientas de inteligencia artificial se utilizaron como apoyo para investigar alternativas, ordenar información, mejorar la claridad de textos elaborados por el equipo, revisar código y preparar comprobaciones técnicas.

La asistencia recibida no sustituye la responsabilidad del equipo. Cada propuesta fue contrastada con las necesidades comunicadas por la Intendencia de San José - Sección Tránsito, con la implementación existente y con resultados verificables. El equipo revisó y adaptó los aportes antes de incorporarlos y se compromete a explicar y defender las decisiones, el código, la documentación y las evidencias entregadas.

No se utilizaron herramientas de IA para inventar entrevistas, aprobaciones del cliente, integrantes, fechas, incidentes, resultados de pruebas ni fuentes. Cuando faltó una confirmación, el dato se documentó como supuesto, condición o pendiente en lugar de presentarlo como un hecho.

Detalle de herramientas de IA utilizadas

Herramienta	Etapa o documento	Tipo de uso	Responsable de revisión
Asistente de IA generativa	Organización y revisión de documentos	Propuestas de estructura, claridad, ortografía, consistencia y detección de contradicciones.	Equipo RC5
Asistente de IA generativa	Investigación técnica	Comparación de alternativas de infraestructura, seguridad, API y operación; las decisiones finales fueron tomadas por el equipo.	Responsables de cada área
Asistente de IA generativa	Desarrollo PHP y JavaScript	Apoyo para revisar implementación, explicar errores y proponer correcciones posteriormente inspeccionadas y probadas.	Tomás Cabrera, Verónica Romero y Juan Corrales
Asistente de IA generativa	Base de datos	Revisión de estructura, relaciones, restricciones y consultas; validación contra el esquema utilizado.	Gabriela Romero y Tomás Cabrera
Asistente de IA generativa	Pruebas y seguridad	Apoyo para diseñar casos, listas de comprobación y lectura de resultados; los valores declarados proceden de ejecuciones guardadas.	Juan Robaina y Tomás Cabrera
Correctores automáticos	Documentación final	Corrección ortográfica y de estilo sin sustituir las decisiones ni conclusiones del equipo.	Equipo RC5

Criterios aplicados

- Se verificó la correspondencia entre lo documentado, el código y las evidencias disponibles.

- Se conservaron referencias a entrevistas, reuniones y resultados únicamente cuando existe un registro que las respalda.
- Las sugerencias técnicas se sometieron a pruebas antes de declararlas implementadas.
- Los datos personales, credenciales y configuraciones sensibles no se incluyeron en solicitudes ni archivos públicos.
- El equipo mantiene la autoría, responsabilidad y capacidad de explicación sobre la versión entregada.

Firmas

Integrante	Firma	Fecha
Tomás Cabrera		
Juan Robaina		
Gabriela Romero		
Verónica Romero		
Juan Corrales		

DOCUMENTO 14 | INGENIERÍA DE SOFTWARE

Acta de cierre del proyecto

Fuente: acta_cierre.md | Versión 1.0 | Fecha 26/10/2026

Dato	Valor
Proyecto	Educación Vial IMSJ - Portal Vial
Cliente	Intendencia de San José - Sección Tránsito
Responsable del proyecto	Tomás Cabrera
Fecha de inicio	09/07/2026
Fecha de cierre	13/10/2026
Motivo del cierre	Objetivos alcanzados y resultado aprobado por el cliente.

1. Objetivo y resultado

Objetivo acordado: desarrollar una plataforma web para centralizar noticias, materiales de estudio, preguntas frecuentes y otras funciones de educación vial, con un panel para su administración.

Resultado obtenido: se completaron el portal público, el panel IMSJ, los simulacros, las consultas ciudadanas, la aprobación de contenidos y las funciones académicas de agenda. El resultado fue presentado a Nacho el 13/10/2026 y quedó aprobado.

2. Entregables

Entregable	Estado	Observación
Portal público	Completado	Noticias, materiales, preguntas frecuentes, simulacros y consultas.
Panel IMSJ	Completado	Gestión de contenidos, aprobación, consultas, usuarios e historial.
Sistema de agenda de tramites	Completado	Franjas, cupos, reservas, cancelación y vistas de agenda.
Backend y base de datos	Completado	API PHP nativa y persistencia MySQL.
Documentación del proyecto	Completado	Análisis, requisitos, backlog, sprints, actas y manuales.

3. Balance del proyecto

Aspecto	Planificado	Resultado final	Observación
Alcance	Portal, administración de contenidos y agenda académica.	Funciones implementadas.	Alcance completado.
Plazo	Cinco sprints.	Cinco sprints finalizados.	Cumplido.
Calidad	Cumplimiento de RF y RNF.	RF1-RF24 y RNF1-RNF10 implementados.	Resultado aprobado en la demostración.

4. Pendientes y continuidad

No quedan funcionalidades pendientes dentro del alcance acordado. El despliegue en infraestructura institucional corresponde al equipo informatico de la intendencia.

5. Lecciones aprendidas

El equipo desarrolló mejores habilidades de comunicación y organización de equipo. Temas como designar tareas, aclarar y ayudar a solucionar errores del otro fueron muy convenientes para el desarrollo y eficiencia del sistema. No encontramos problemas con los roles designados del equipo ya que todas las discordancias siempre terminaron en buenos acuerdos que solucionaban las mismas. Aprendimos a aceptar sugerencias del otro y escuchar el resto del equipo. También aprendimos a emplear de manera efectiva las herramientas actuales y acoplarlas con las debilidades de cada integrante del equipo.

6. Declaración de aceptación

El cliente confirma que revisó el resultado presentado y aprobó el cierre del proyecto. Cualquier trabajo posterior se gestionará como mantenimiento o una nueva etapa.

Rol	Nombre	Conformidad	Fecha
Cliente	Inspector de Tránsito (Nacho)	Aprobado	13/10/2026

02 / ÁREA DOCUMENTAL

Administración de Sistemas Operativos

De los requisitos de infraestructura a la arquitectura, operación y reconstrucción.

5 **DOCUMENTOS**

ordenados según el recorrido del proyecto

DOCUMENTO 15 | SSOO

Análisis de requerimientos de infraestructura

Fuente: analisis-requerimientos.md | Versión 1.0 | Fecha 26/10/2026

Proyecto: Educación Vial IMSJ - Portal Vial

Plataforma: Ubuntu Server 26.04 LTS

1. Objetivo

Definir la infraestructura necesaria para ejecutar el portal público, el panel IMSJ, la API PHP y la base MySQL en un servidor Linux administrable, recuperable y accesible desde la red autorizada.

2. Carga de trabajo

Dato	Valor utilizado
Usuarios simultáneos	90
Aplicaciones web	1
Bases de datos	1
Contenedores auxiliares	0
Perfil	Pequeña producción
Datos iniciales	1 GB estimado
Crecimiento mensual	10 % estimado
Proyección	12 meses
Backups completos	1 por día
Retención local en la VM base	2 días
Retención externa inicial	7 copias diarias
Administración	Cockpit
Umbral de revisión	70 % sostenido de CPU, RAM o disco
Copia externa	Sí
RAID1	No, por tratarse de una VM con backup externo

La estimación de 90 usuarios simultáneos contempla una situación de difusión concentrada, por ejemplo compartir el portal mediante un código QR durante una charla en un liceo. Dos clases pueden aportar aproximadamente 60 accesos al mismo tiempo; el resto de la capacidad permite atender a ciudadanos y personal que ya estén utilizando el sitio. Este valor describe sesiones con el portal abierto, no 90 solicitudes PHP ejecutándose de forma permanente.

El portal entrega principalmente HTML, CSS, JavaScript e imágenes estáticas. PHP y MySQL intervienen en solicitudes breves de consulta, autenticación, reserva y administración. Por esa razón, el dimensionamiento se basa en el tipo y la duración de las operaciones, los dos contenedores desplegados y un margen operativo, en lugar de asignar una cantidad fija de memoria por usuario. La concurrencia y el crecimiento deberán contrastarse con métricas reales.

3. Dimensionamiento

Se adopta una configuración inicial que cubre Ubuntu Server, Docker, Cockpit, Apache/PHP y MySQL, y que puede ampliarse después de medir el entorno objetivo:

Recurso	Fundamento	Configuración inicial
CPU	Operaciones HTTP y SQL breves, sin procesamiento intensivo	**2 vCPU**
Memoria	SO, Docker, Apache/PHP, MySQL, Cockpit y margen para picos	**4 GB RAM**
Disco útil	SO, imágenes Docker, aplicación, datos, adjuntos, logs y las dos copias diarias más recientes	**30 GB SSD/NVMe**
Disco con 7 copias completas locales	Mayor retención dentro de la misma VM	**40-50 GB SSD/NVMe**

Los videos se conservan como enlaces externos y no ocupan almacenamiento local. Los elementos de mayor tamaño son los PDF y las imágenes cargados por el personal. La configuración de 30 GB requiere trasladar cada respaldo válido a un medio externo y limitar la retención dentro de la VM a dos días. Si se mantienen siete copias completas en la VM, se deben asignar entre 40 y 50 GB.

La configuración es un punto de partida, no una capacidad garantizada. Una prueba de carga de 90 sesiones deberá registrar solicitudes por segundo, latencia, errores, CPU, memoria e I/O. Si un recurso supera de forma sostenida el 70 %, se ajustará la VM.

4. Requerimientos del servidor

Código	Requerimiento
RS-01	Utilizar Ubuntu Server 26.04 LTS de 64 bits.
RS-02	Asignar inicialmente 2 vCPU, 4 GB de RAM y 30 GB de disco SSD/NVMe.
RS-03	Configurar un usuario administrativo con `sudo`, sin trabajar habitualmente como `root`.
RS-04	Habilitar OpenSSH Server para la administración remota.
RS-05	Configurar una IP fija mediante Netplan.
RS-06	Aplicar UFW con denegación de entradas por defecto y permitir solo SSH, aplicación y Cockpit desde redes autorizadas.
RS-07	Instalar Docker Engine desde el repositorio oficial y Docker Compose v2.
RS-08	Ejecutar la aplicación y MySQL mediante `compose.yaml`.
RS-09	Mantener MySQL sin puerto publicado hacia el host.
RS-10	Conservar base, adjuntos y caché en volúmenes persistentes.
RS-11	Reiniciar los contenedores automáticamente después de reiniciar el servidor.
RS-12	Limitar el tamaño y la cantidad de archivos de log de Docker.
RS-13	Realizar un backup diario de base, adjuntos, código y configuración.
RS-14	Mantener localmente las dos copias diarias más recientes y al menos siete copias diarias en un medio externo protegido; usar 40-50 GB si se requieren siete copias completas dentro de la VM.
RS-15	Probar la restauración sobre una instalación aislada antes de considerar válido un backup.
RS-16	Supervisar CPU, RAM, disco, logs, contenedores y estado de los servicios.
RS-17	Validar la configuración con 90 sesiones simultáneas y ampliar recursos si CPU, RAM o disco superan de forma sostenida el 70 %.

5. Servicios y puertos

Servicio	Puerto	Exposición
SSH	22/TCP	Solo administración autorizada
Portal, panel y API	8000/TCP	Red autorizada
Cockpit	9090/TCP	Solo administración autorizada
MySQL	3306/TCP	Únicamente dentro de Docker

La demostración utiliza HTTP en una red controlada. Una publicación en Internet requiere dominio, HTTPS y un proxy inverso administrado por la institución.

6. Criterios de aceptación

- Ubuntu informa una versión 26.04 LTS actualizada.
- La IP del servidor permanece estable después de reiniciar.
- SSH, UFW, Docker y Cockpit se encuentran activos.
- app y db aparecen saludables en Docker Compose.
- El portal responde desde otra computadora autorizada de la red.
- MySQL no acepta conexiones directas desde la red.
- Los datos y adjuntos permanecen después de recrear los contenedores.
- El backup genera archivos verificables mediante SHA-256.
- Una restauración aislada recupera cuentas, contenidos, adjuntos, consultas y reservas.
- Una prueba de carga de 90 sesiones simultáneas confirma tiempos de respuesta y consumo de CPU, memoria e I/O aceptables antes de la publicación institucional.

Referencias

- Calculadora didáctica de requerimientos
- Servidor Linux con Docker
- Ciclo de soporte de Ubuntu
- Instalación oficial de Docker Engine en Ubuntu

DOCUMENTO 16 | SSOO

Arquitectura propuesta de infraestructura

Fuente: arquitectura_propuesta.md | Versión 1.0 | Fecha 26/10/2026

Proyecto: Educación Vial IMSJ - Portal Vial

Servidor: Ubuntu Server 26.04 LTS, 2 vCPU, 4 GB RAM y 30 GB SSD/NVMe

1. Vista general

MERMAID

```
flowchart TB
    Admin[Equipo administrador] -->|SSH 22| UFW[UFW]
    Admin -->|Cockpit 9090| UFW
    Usuarios[Usuarios autorizados] -->|HTTP 8000| UFW

    UFW --> Host[Ubuntu Server 26.04 LTS]
    Host --> Docker[Docker Engine y Compose v2]
    Host --> Cockpit[Cockpit]
    Host --> Backup[Backup Bash y cron]

    Docker --> App[app: Apache y PHP 8.5]
    App --> DB[db: MySQL 8.4]
    App --- Portal[frontend-publico]
    App --- Panel[frontend-imsj]

    DB --- DBData[(db_data)]
    App --- Uploads[(app_uploads)]
    App --- Cache[(cache)]

    Backup --> Local[(2 copias locales)]
    Local -. copia .-> Externo[(7 copias diarias protegidas)]
```

El servidor concentra la administración del sistema operativo y Docker. Los usuarios solo acceden a Apache; MySQL permanece en la red interna de Compose.

2. Servidor anfitrión

Elemento	Definición
Sistema operativo	Ubuntu Server 26.04 LTS de 64 bits
Recursos	2 vCPU, 4 GB RAM y 30 GB SSD/NVMe
Capacidad de referencia	Objetivo inicial de 90 sesiones simultáneas, sujeto a prueba de carga y ampliación si un recurso supera 70 % sostenido
Nombre sugerido	`srv-imsj`
Red	IP fija configurada mediante Netplan
Administración	OpenSSH y Cockpit
Firewall	UFW con entradas denegadas por defecto
Contenedores	Docker Engine y Docker Compose v2
Automatización	Bash y cron

3. Componentes Docker

Componente	Responsabilidad
`app`	Ejecutar Apache, PHP, la API y servir los dos frontends.
`db`	Mantener la base MySQL sin publicar el puerto 3306.
`db_data`	Conservar tablas, cuentas, contenidos, consultas, reservas e historial.
`app_uploads`	Conservar PDF e imágenes cargados.
`cache`	Conservar contadores compartidos de intentos de autenticación.

Los contenedores utilizan `restart: unless-stopped`, límites de logs y controles de salud. `app` se ejecuta como `www-data`; `db`, como `mysql`. Ambos usan raíz de solo lectura, `no-new-privileges` y capacidades reducidas.

4. Red y acceso

Origen	Destino	Puerto	Regla
Red administrativa	Ubuntu Server	22/TCP	SSH
Red administrativa	Ubuntu Server	9090/TCP	Cockpit
Red autorizada	Aplicación	8000/TCP	Portal, panel y API
app	db	3306/TCP	Red interna Docker

Compose publica la aplicación en `0.0.0.0:8000`. UFW determina qué redes pueden acceder. No se publica MySQL.

Para una demostración controlada se utiliza HTTP. Si el sistema se publica en Internet, se debe colocar un proxy inverso con HTTPS en 443/TCP, mantener la aplicación y MySQL detrás de él y reemplazar las URL de `.env` por el dominio institucional.

5. Recorrido de una petición

MERMAID

```
sequenceDiagram
    actor Usuario
    participant Frontend as Navegador / Frontend
    participant Apache
    participant Router as public/index.php
    participant Auth as Autenticación y validación
    participant Controller as Controlador
    participant Service as Servicio
    participant Repository as Repositorio PDO
    participant DB as MySQL

    Usuario->>Frontend: Ejecuta una acción
    Frontend->>Apache: Solicitud HTTP a /api
    Apache->>Router: Reescritura y entrada única
    Router->>Controller: Despacha método y ruta
    opt Ruta protegida
        Controller->>Auth: Verifica sesión, cuenta y rol
        Auth-->>Controller: Usuario autorizado o error HTTP
    end
    Controller->>Controller: Valida los datos de entrada
    Controller->>Service: Entrega datos validados
    Service->>Repository: Aplica reglas y solicita persistencia
    Repository->>DB: Consulta o transacción SQL preparada
    DB-->>Repository: Filas o resultado
    Repository-->>Service: Datos del dominio
    Service-->>Controller: Resultado del caso de uso
    Controller-->>Frontend: Respuesta JSON o 204
    Frontend-->>Usuario: Actualiza la interfaz
```

Los frontends consumen `/api` desde el mismo origen. Apache sirve los archivos públicos y dirige las rutas de API a `public/index.php`; el router identifica método y URL y selecciona el controlador. En las operaciones protegidas, el controlador solicita a `Auth` la verificación de sesión, cuenta y rol antes de modificar o exponer datos. El controlador valida la entrada específica, el servicio aplica reglas y transacciones, y el repositorio concentra las consultas PDO preparadas. La respuesta vuelve por esas capas hasta el navegador. Las rutas públicas omiten el paso de autenticación. El resto del backend permanece fuera de `DocumentRoot`.

6. Persistencia y recuperación

El backup diario reúne:

- dump comprimido de MySQL;
- adjuntos del volumen `app_uploads`;
- copia del proyecto;
- configuración necesaria para reconstruir la instalación;
- manifiesto, versión y hashes SHA-256.

La VM base conserva dos copias diarias locales y mantiene al menos siete copias diarias en un medio externo protegido. Si la política exige conservar siete backups completos dentro de la VM, el disco se amplía a 40-50 GB. La restauración se prueba con otro nombre de proyecto Compose y otro puerto para no tocar la instalación principal.

7. Monitoreo

Nivel	Herramientas
Host	Cockpit, `uptime`, `free -h`, `df -h`, `ss -tulpn`
Servicios	`systemctl status docker`, `journalctl -u docker`
Contenedores	`docker compose ps`, `docker stats`, `docker compose logs`
Aplicación	`/api/health` y control de salud interno de Compose
Backups	`SHA256SUMS`, manifiesto y prueba de restauración

8. Límites

- Los datos iniciales y su crecimiento son estimaciones y deben reemplazarse por mediciones reales.
- La capacidad de 90 usuarios simultáneos es un objetivo de dimensionamiento; debe confirmarse mediante una prueba de carga y observación en Cockpit antes de asumirla como capacidad operativa demostrada.
- Los 90 usuarios representan sesiones con períodos de lectura, no 90 solicitudes PHP activas permanentemente.
- Si CPU, memoria o disco superan de forma sostenida el 70 %, se deben ampliar los recursos o revisar la carga antes de la publicación.
- La instalación en red controlada no representa una publicación institucional con dominio y HTTPS.
- El backup no se considera válido hasta completar una restauración aislada.

Documentos relacionados

Análisis de requerimientos, justificación tecnológica, infraestructura y reconstrucción.

DOCUMENTO 17 | SSOO

Justificación tecnológica

Fuente: justificacion-tecnologica.md | Versión 1.0 | Fecha 26/10/2026

Proyecto: Educación Vial IMSJ - Portal Vial

Decisiones de infraestructura

Tecnología	Justificación	Condición
Ubuntu Server 26.04 LTS	Es la versión LTS vigente, con mantenimiento estándar previsto hasta 2031 y soporte oficial para Docker Engine. Permite administración por terminal mediante Netplan, UFW y systemd.	Debe mantenerse actualizado y administrarse con un usuario `sudo`.
Docker Engine	Aísla la aplicación y la base del sistema anfitrión y permite reconstruir el entorno de forma repetible.	Se instala desde el repositorio oficial de Docker para Ubuntu.
Docker Compose v2	Define servicios, volúmenes, variables, dependencias y controles de salud en un solo archivo.	La configuración sensible permanece en `.env`, fuera de Git.
Apache y PHP 8.5	Ejecutan la API PHP y publican el portal y el panel desde el mismo origen.	Solo `public/` y los alias de frontend quedan expuestos.
MySQL 8.4	Conserva las relaciones, restricciones y transacciones del sistema.	El puerto 3306 permanece dentro de Docker.
Volúmenes Docker	Separan datos, adjuntos y caché del ciclo de vida de los contenedores.	Deben formar parte del backup y de la prueba de restauración.
Netplan	Mantiene una dirección estable para que los clientes localicen el servidor.	La interfaz, IP, gateway y DNS dependen de la red real.
UFW	Limita las conexiones entrantes a los servicios autorizados.	SSH debe permitirse antes de activar el firewall.
OpenSSH	Permite administrar el servidor sin interfaz gráfica.	Se utiliza un usuario administrativo distinto de `root`.
Cockpit	Permite observar servicios, recursos y registros desde una interfaz de administración.	El puerto 9090 se restringe a la red administrativa.
Bash y cron	Automatizan backups diarios y tareas operativas con herramientas nativas de Linux.	Los scripts generan hashes de integridad.

Dimensionamiento

La estimación considera 90 sesiones simultáneas, una aplicación PHP, una base MySQL, dos contenedores, Cockpit, archivos cargados por el personal y backups diarios. Una sesión abierta no equivale a una solicitud activa de forma permanente: los usuarios alternan solicitudes breves con períodos de lectura.

El portal sirve principalmente recursos estáticos. PHP y MySQL participan en consultas, autenticación, reservas y operaciones administrativas de corta duración, sin cálculos intensivos. Para esta carga se propone iniciar con **2 vCPU y 4 GB de RAM**, capacidad que incluye el sistema operativo, Docker, Apache/PHP, MySQL, Cockpit y margen para picos transitorios.

Se asignan **30 GB SSD/NVMe** para el sistema, las imágenes Docker, la aplicación, la base, los adjuntos, los logs y las dos copias diarias más recientes. Los videos se almacenan como enlaces externos. Las copias válidas se trasladan a un medio

externo protegido; si deben conservarse siete backups completos dentro de la VM, el disco recomendado pasa a **40-50 GB**.

La configuración inicial es **2 vCPU, 4 GB de RAM y 30 GB SSD/NVMe**. Antes de afirmar su capacidad operativa se ejecutará una prueba con 90 sesiones y se medirán solicitudes por segundo, latencia, errores, CPU, memoria e I/O. Un consumo sostenido superior al 70 % activa la revisión o ampliación del recurso afectado.

Organización de los servicios

El despliegue mantiene dos contenedores:

- `app`: Apache, PHP, API y frontends;
- `db`: MySQL.

Esta separación permite actualizar la aplicación sin reemplazar los datos. MySQL no se expone hacia la red y solo `app` publica el puerto de la aplicación.

No se incorpora Portainer porque no es necesario para operar dos servicios y su acceso al socket de Docker amplía privilegios. Cockpit y la terminal permiten realizar las tareas administrativas requeridas.

Disponibilidad y operación

`restart: unless-stopped` permite recuperar los servicios después de reiniciar Ubuntu. Los healthchecks verifican aplicación y base; los logs se rotan para evitar crecimiento indefinido. La persistencia depende de los volúmenes, no de los contenedores.

Backup y recuperación

El backup incluye código, dump MySQL, adjuntos, configuración protegida, manifiesto y hashes. Se ejecuta una vez por día; la VM base conserva dos días y el medio externo protegido mantiene al menos siete copias diarias. La restauración se prueba sobre una instalación aislada.

Copiar únicamente el repositorio no recupera los datos. Copiar únicamente un volumen MySQL mientras está escribiendo tampoco sustituye un dump lógico consistente.

Seguridad

- Administración mediante usuario `sudo`, no mediante uso habitual de `root`.
- UFW con denegación de entradas por defecto.
- MySQL sin puerto publicado.
- Contraseñas únicamente en `.env` protegido.
- Contenedores con usuarios de servicio, raíz de solo lectura y capacidades reducidas.
- HTTPS obligatorio antes de una publicación en Internet.

DOCUMENTO 18 | SSOO

Documentación de infraestructura

Fuente: documentacion-infraestructura.md | Versión 1.0 | Fecha 26/10/2026

Proyecto: Educación Vial IMSJ - Portal Vial

Entorno objetivo: Ubuntu Server 26.04 LTS

1. Inventario del servidor

Elemento	Configuración
CPU	2 vCPU iniciales
Memoria	4 GB RAM
Disco	30 GB SSD/NVMe; 40-50 GB con siete backups completos locales
Red	IP fija con Netplan
Administración	OpenSSH y Cockpit
Firewall	UFW
Contenedores	Docker Engine y Docker Compose v2
Automatización	Bash y cron

2. Archivos operativos

Archivo	Función
`backend/Dockerfile`	Construye la imagen Apache/PHP e instala las extensiones necesarias.
`backend/compose.yaml`	Define aplicación, base, volúmenes, reinicio, salud, logs y exposición de red.
`backend/apache.conf`	Configura la API y los alias de los frontends.
`backend/.env.example`	Plantilla sin secretos para crear `.env`.
`backend/database.sql`	Crea el esquema inicial cuando el volumen de MySQL está vacío.
`backend/scripts/migrar.php`	Aplica cambios incrementales de esquema sin borrar datos.
`backend/scripts/crear_admin.php`	Crea la primera cuenta de personal.
`backend/scripts/salud.php`	Comprueba aplicación, base y portal.
`backend/scripts/backup.sh`	Genera backup completo, manifiesto y hashes.
`backend/scripts/restore.sh`	Restaura base y adjuntos en una instalación confirmada.

3. Servicios Docker

Servicio	Imagen	Usuario	Exposición	Persistencia
app	Construida desde php:8.5-apache	www-data	APP_BIND:APP_PORT hacia 80	app_uploads, cache
db	mysql:8.4	mysql	Sin puerto publicado	db_data

Ambos servicios utilizan `restart: unless-stopped`, raíz de solo lectura, `no-new-privileges`, capacidades reducidas y rotación de logs. app espera que db esté saludable.

4. Volúmenes

Volumen	Contenido	Incluido en backup
db_data	Datos internos de MySQL	Mediante dump lógico comprimido
app_uploads	PDF e imágenes cargados	Sí, como archivo comprimido
cache	Contadores temporales de autenticación	No; puede reconstruirse

5. Variables de configuración

Variable	Uso
APP_ENV	production en el servidor.
APP_BIND	0.0.0.0 para escuchar en las interfaces del servidor.
APP_PORT	Puerto publicado, 8000 por defecto.
APP_URL	URL completa con IP fija o dominio.
FRONTEND_ORIGIN	Origen permitido para el navegador.
DB_DATABASE	Nombre de la base.
DB_USERNAME	Usuario de aplicación.
DB_PASSWORD	Contraseña del usuario de aplicación.
DB_ROOT_PASSWORD	Contraseña administrativa de MySQL.
INITIAL_ADMIN_*	Datos temporales para crear la primera cuenta.

.env debe pertenecer al administrador y utilizar permisos 600. No se guarda en Git.

6. Red y firewall

La IP se configura mediante Netplan con los datos reales de la red. UFW aplica:

- denegar conexiones entrantes por defecto;
- permitir salidas;
- permitir 22/TCP desde la red administrativa;
- permitir 8000/TCP desde la red autorizada;
- permitir 9090/TCP únicamente desde la red administrativa;
- no permitir 3306/TCP desde el host.

El puerto publicado por Compose escucha en 0.0.0.0, pero la autorización efectiva queda en UFW.

7. Operación

```bash
cd /srv/imsj/Proyecto-IMSJ/backend
docker compose config
docker compose up -d --build
docker compose ps
docker compose logs --tail 100 app db
```

Para detener sin borrar datos:

```bash
docker compose stop
```

No se utiliza `docker compose down -v` durante la operación normal porque elimina los volúmenes persistentes.

8. Monitoreo

```bash
hostnamectl
ip -br address
uptime
free -h
df -h
ss -tulpn
systemctl status docker
docker compose ps
docker stats --no-stream
docker system df
```

Cockpit complementa estas comprobaciones desde el puerto 9090 restringido a administración.

9. Backup

Ejecución manual:

```bash
cd /srv/imsj/Proyecto-IMSJ/backend
chmod +x scripts/backup.sh scripts/restore.sh
./scripts/backup.sh /srv/backups/imsj
```

Cada backup contiene:

```text
backup-AAAA-MM-DD_HH-MM-SS/
├── base.sql.gz
├── adjuntos.tar.gz
├── proyecto.tar.gz
├── config/
│   ├── .env
│   ├── compose.yaml
│   ├── Dockerfile
│   └── apache.conf
├── MANIFIESTO.txt
└── SHA256SUMS
```

La carpeta contiene configuración sensible y debe almacenarse con acceso restringido. La VM de 30 GB conserva dos días de copias locales; las copias válidas se trasladan a un medio externo protegido, donde se mantienen al menos siete copias diarias. Para conservar siete backups completos dentro de la propia VM se amplía el disco a 40-50 GB.

10. Restauración

La restauración se realiza sobre una instalación aislada y requiere confirmación explícita:

```bash
IMSJ_RESTORE_CONFIRM=YES ./scripts/restore.sh /srv/backups/imsj/backup-FECHA
```

Después se comprueban portal, ingreso, contenidos, adjuntos, consultas, reservas y conteos de la base.

Documentos relacionados

Análisis, arquitectura, justificación y reconstrucción.

DOCUMENTO 19 | SSOO

Reconstrucción de la infraestructura

Fuente: reconstruccion-infraestructura.md | Versión 1.0 | Fecha 26/10/2026

Proyecto: Educación Vial IMSJ - Portal Vial

Sistema objetivo: Ubuntu Server 26.04 LTS

1. Preparar el servidor

Crear una máquina virtual o servidor con:

- 2 vCPU;
- 4 GB de RAM;
- 30 GB de disco SSD/NVMe, o 40-50 GB si se conservarán siete backups completos dentro de la VM;
- adaptador de red con acceso desde los equipos autorizados;
- ISO de Ubuntu Server 26.04 LTS.

Durante la instalación seleccionar Ubuntu Server, habilitar OpenSSH Server, crear un usuario administrativo distinto de `root` y utilizar el nombre `srv-imsj` o uno equivalente.

2. Actualizar Ubuntu

```bash
sudo apt update
sudo apt full-upgrade -y
sudo timedatectl set-timezone America/Montevideo
sudo reboot
```

Después del reinicio:

```bash
hostnamectl
free -h
df -h
ip -br address
ip route
```

La salida debe identificar Ubuntu 26.04 LTS y los recursos asignados.

3. Configurar la IP fija

Identificar la interfaz y los datos entregados por la red:

```bash
ip -br address
ip route
```

Editar el archivo de Netplan disponible en `/etc/netplan/`. Ejemplo:

```yaml
network:
  version: 2
  ethernets:
    INTERFAZ:
      dhcp4: false
      addresses:
        - IP_SERVIDOR/PREFIJO
      routes:
        - to: default
          via: PUERTA_DE_ENLACE
      nameservers:
        addresses:
          - DNS_1
          - DNS_2
```

Validar antes de aplicar, especialmente si la sesión es remota:

```bash
sudo netplan try
sudo netplan apply
ip -br address
ip route
```

Los valores de interfaz, IP, prefijo, gateway y DNS deben corresponder a la red real; no se copian literalmente los nombres del ejemplo.

4. Configurar SSH y UFW

Instalar las herramientas necesarias:

```bash
sudo apt install -y openssh-server ufw curl ca-certificates git jq gzip
sudo systemctl enable --now ssh
```

Permitir SSH antes de activar el firewall. Sustituir `RED_ADMIN` y `RED_USUARIOS` por las redes reales, por ejemplo una red con formato `192.168.1.0/24`.

```bash
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow from RED_ADMIN to any port 22 proto tcp
sudo ufw allow from RED_USUARIOS to any port 8000 proto tcp
sudo ufw allow from RED_ADMIN to any port 9090 proto tcp
sudo ufw enable
sudo ufw status verbose
```

No se abre el puerto 3306 de MySQL.

5. Instalar Docker Engine y Compose

Eliminar paquetes incompatibles si estuvieran instalados:

```bash
for pkg in docker.io docker-doc docker-compose podman-docker containerd runc; do
  sudo apt remove -y "$pkg"
done
```

Agregar el repositorio oficial:

```bash
sudo install -m 0755 -d /etc/apt/keyrings
sudo curl -fsSL https://download.docker.com/linux/ubuntu/gpg \
  -o /etc/apt/keyrings/docker.asc
sudo chmod a+r /etc/apt/keyrings/docker.asc

sudo tee /etc/apt/sources.list.d/docker.sources >/dev/null <<EOF
Types: deb
URIs: https://download.docker.com/linux/ubuntu
Suites: $(. /etc/os-release && echo "${UBUNTU_CODENAME:-$VERSION_CODENAME}")
Components: stable
Architectures: $(dpkg --print-architecture)
Signed-By: /etc/apt/keyrings/docker.asc
EOF

sudo apt update
sudo apt install -y docker-ce docker-ce-cli containerd.io docker-buildx-plugin docker-compose-plugin
sudo systemctl enable --now docker
sudo docker run --rm hello-world
docker compose version
```

Agregar el usuario administrativo al grupo Docker y volver a iniciar sesión:

```bash
sudo usermod -aG docker "$USER"
```

Pertenecer al grupo Docker otorga privilegios administrativos sobre el servidor; no se agrega a usuarios comunes.

6. Instalar Cockpit

```bash
sudo apt install -y cockpit
sudo systemctl enable --now cockpit.socket
systemctl is-active cockpit.socket
```

Cockpit queda disponible en `https://IP_SERVIDOR:9090` únicamente desde la red administrativa permitida en UFW.

7. Copiar el proyecto

Crear la ubicación de trabajo y copiar o clonar la versión de entrega:

```bash
sudo mkdir -p /srv/imsj
sudo chown "$USER":"$USER" /srv/imsj
cd /srv/imsj
git clone URL_DEL_REPOSITORIO Proyecto-IMSJ
cd Proyecto-IMSJ/backend
```

Si el proyecto se entrega mediante pendrive, copiar la carpeta completa a `/srv/imsj/Proyecto-IMSJ` conservando ambos frontends y el backend.

8. Configurar el entorno

```bash
cp .env.example .env
nano .env
```

Completar como mínimo:

```dotenv
APP_ENV=production
APP_BIND=0.0.0.0
APP_PORT=8000
APP_URL=http://IP_SERVIDOR:8000
FRONTEND_ORIGIN=http://IP_SERVIDOR:8000
DB_DATABASE=imsj
DB_USERNAME=imsj
DB_PASSWORD=CLAVE_SEGURA
DB_ROOT_PASSWORD=OTRA_CLAVE_SEGURA
```

Aplicar permisos:

```bash
chmod 600 .env
docker compose config --quiet
```

Las claves reales no se guardan en Git ni se muestran en capturas.

9. Iniciar el sistema

```bash
docker compose up -d --build
docker compose ps
docker compose logs --tail 100 app db
```

Comprobar desde el servidor:

```bash
curl -I http://127.0.0.1:8000/
curl http://127.0.0.1:8000/api/health
```

Desde otra computadora autorizada abrir:

```text
http://IP_SERVIDOR:8000/frontend-publico/
http://IP_SERVIDOR:8000/frontend-imsj/
```

10. Crear la primera cuenta

```bash
read -r -p "Cédula: " INITIAL_ADMIN_CEDULA
read -r -p "Nombre: " INITIAL_ADMIN_NOMBRE
read -r -s -p "Contraseña: " INITIAL_ADMIN_PASSWORD
echo
export INITIAL_ADMIN_CEDULA INITIAL_ADMIN_NOMBRE INITIAL_ADMIN_PASSWORD

docker compose exec \
  -e INITIAL_ADMIN_CEDULA \
  -e INITIAL_ADMIN_NOMBRE \
  -e INITIAL_ADMIN_PASSWORD \
  app php scripts/crear_admin.php

unset INITIAL_ADMIN_CEDULA INITIAL_ADMIN_NOMBRE INITIAL_ADMIN_PASSWORD
```

Las cuentas siguientes se crean desde el panel.

11. Configurar backups diarios

```bash
sudo mkdir -p /srv/backups/imsj
sudo chown "$USER":"$USER" /srv/backups/imsj
cd /srv/imsj/Proyecto-IMSJ/backend
chmod +x scripts/backup.sh scripts/restore.sh
./scripts/backup.sh /srv/backups/imsj
```

Verificar los hashes del backup generado:

```bash
cd /srv/backups/imsj/backup-FECHA
sha256sum -c SHA256SUMS
```

Programar una ejecución diaria a las 02:00:

```bash
crontab -e
```

```cron
0 2 * * * cd /srv/imsj/Proyecto-IMSJ/backend && BACKUP_RETENTION_DAYS=2 ./scripts/backup.sh /srv/backups/imsj >> /srv/backups/imsj/backup.log 2>&1
```

La retención de dos días corresponde a la VM base de 30 GB. Copiar cada backup válido a un medio externo protegido y conservar allí al menos siete copias diarias. Si se desea usar la retención local predeterminada de siete días del script, asignar 40-50 GB de disco. La copia externa no debe quedar montada permanentemente con permisos de escritura para todos los usuarios.

12. Probar la restauración

La prueba se realiza en otra carpeta y con otro nombre de proyecto Compose para evitar los volúmenes principales.

```bash
cp -a /srv/imsj/Proyecto-IMSJ /srv/imsj/Proyecto-IMSJ-restauracion
cd /srv/imsj/Proyecto-IMSJ-restauracion/backend
```

Editar `.env` y utilizar `APP_PORT=8001`, `APP_URL=http://IP_SERVIDOR:8001` y `FRONTEND_ORIGIN=http://IP_SERVIDOR:8001`. Permitir temporalmente el puerto 8001 solo desde la red administrativa.

```bash
export COMPOSE_PROJECT_NAME=imsj_restauracion
IMSJ_RESTORE_CONFIRM=YES ./scripts/restore.sh /srv/backups/imsj/backup-FECHA
docker compose ps
curl http://127.0.0.1:8001/api/health
```

Comprobar cuentas, contenidos, adjuntos, consultas y reservas. Registrar fecha, backup, hash, versión, resultado y responsable. Al terminar, detener el entorno de prueba sin tocar el principal.

13. Verificación después de reiniciar

```bash
sudo reboot
```

Después del reinicio:

```bash
systemctl is-active docker
docker compose -f /srv/imsj/Proyecto-IMSJ/backend/compose.yaml \
  --env-file /srv/imsj/Proyecto-IMSJ/backend/.env ps
curl http://127.0.0.1:8000/api/health
sudo ufw status verbose
```

Los contenedores deben iniciar automáticamente por su política `restart: unless-stopped`.

14. Evidencia de entrega

Guardar capturas o salidas de:

- `cat /etc/os-release` y `hostnamectl`;
- `ip -br address` e `ip route`;
- `sudo ufw status verbose`;
- `docker --version` y `docker compose version`;
- `docker compose ps`;
- portal y panel abiertos desde otro equipo;
- carpeta de backup, manifiesto y validación SHA-256;
- restauración aislada funcionando.

No declarar la instalación o la restauración como realizadas hasta obtener esta evidencia en Ubuntu Server 26.04 LTS.

03 / ÁREA DOCUMENTAL

Ciberseguridad

Del análisis de riesgos a la protección, verificación y respuesta a incidentes.

10 **DOCUMENTOS**

ordenados según el recorrido del proyecto

IMSJ

ANÁLISIS DE

Ciberseguridad

Plataforma Web Educación Vial IMSJ

PHP NATIVO | ANÁLISIS Y DISEÑO SEGURO

Versión actualizada	**20/10/2026**
Asignatura	Electiva Ciberseguridad
Estado	Versión final

Este documento describe la implementación vigente en PHP nativo, conserva el mapa de riesgos del proyecto e incorpora debajo el criterio utilizado para su escala.

1. Alcance del análisis

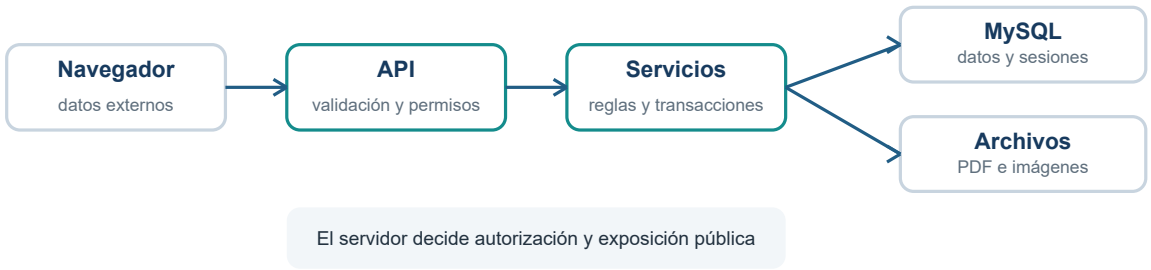
El análisis describe los activos, amenazas y controles de la versión PHP nativa y los relaciona con la evidencia disponible. Comprende el portal público, el panel IMSJ, la API, la base de datos, los archivos cargados y la infraestructura local Docker. La agenda y las reservas se evalúan como parte del alcance académico, aunque no formen parte de la entrega actual al cliente.

El análisis diferencia controles implementados, resultados registrados y límites de alcance. Las comprobaciones SAST, DAST, Nmap y Bash se documentan en sus informes específicos. La presencia de un control en el código no acredita por sí sola ausencia de vulnerabilidades; por eso cada resultado conserva su contexto y evidencia.

2. Activos y límites de confianza

Activo	Información o función que debe protegerse	Consecuencia de un incidente
Cuentas y contraseñas	Identidad, rol y acceso al panel y a reservas propias.	Suplantación y ejecución de operaciones no autorizadas.
Tokens de sesión	Acceso temporal a las operaciones de la cuenta.	Uso de una sesión robada hasta su vencimiento o revocación.
Noticias, materiales y FAQ	Integridad, aprobación, publicación y vigencia de la información.	Difusión de contenido falso, interno o desactualizado.
Consultas ciudadanas	Nombre, correo y mensaje.	Exposición de datos o uso de la bandeja para abuso y contenido malicioso.
Banco del simulador	Enunciados, gráficos, opciones y respuestas correctas.	Alteración educativa o exposición anticipada de la solución.
Reservas y franjas	Relación de ciudadano, horario y cupo.	Cancelación ajena, duplicación o exceso de capacidad.
Historial	Usuario, acción, elemento y fecha.	Pérdida de trazabilidad o atribución incorrecta de acciones.
Adjuntos y respaldos	PDF, imágenes, exportaciones y configuración de instalación.	Pérdida de información, descarga indebida o ejecución de archivos inseguros.

El navegador y sus datos se consideran entradas externas. Ocultar un botón no autoriza ni prohíbe una operación: la API debe comprobar la sesión y los permisos. La base y el almacenamiento se acceden desde el servidor; los archivos del backend fuera de `public` no deben publicarse como recursos estáticos.



3. Amenazas y efectos sobre el proyecto

Amenaza	Escenario relevante	Impacto técnico y sobre usuarios
Inyección SQL	Entradas manipuladas en acceso, filtros y operaciones de administración.	Lectura o modificación de cuentas, contenidos y datos de ciudadanos si una consulta concatena entradas sin control.
XSS almacenado o reflejado	Texto, enlaces o mensajes incorporados al DOM sin codificación contextual.	Ejecución en el navegador, redirección, alteración visual o robo del token accesible a JavaScript.
Fuerza bruta y robo de credenciales	Intentos automatizados, claves previsibles o engaño al personal.	Acceso a una cuenta y acciones atribuidas a su identidad.
Fallas de autorización	Invocar directamente una ruta administrativa o un identificador de otra cuenta.	Publicación sin permiso, lectura de información interna o cancelación de reservas ajenas.
Archivos inseguros	Carga de un archivo ejecutable, contenido distinto del tipo declarado o ruta manipulada.	Ejecución, exposición de archivos privados o consumo indebido de recursos.
Pérdida de integridad	Falla parcial entre SQL, historial y adjuntos, o solicitudes simultáneas por el último cupo.	Registros inconsistentes, archivos huérfanos o más reservas que capacidad.
Exposición de configuración	Publicación de `.env`, SQL, mensajes internos, logs o respaldos.	Filtración de claves y datos y acceso a servicios de la instalación.
Falta de recuperación	Pérdida de volumen o copia sin adjuntos, configuración o versión compatible.	Interrupción del servicio e imposibilidad de reconstruir su estado.

Mapa de riesgos

El mapa original se conserva y se interpreta sobre la implementación actual: backend en **PHP nativo, sin framework**, organizado por capas y con acceso a MySQL mediante PDO. La ubicación de los riesgos es una estimación cualitativa del equipo para priorizar revisiones; no sustituye una auditoría técnica ni una aceptación institucional del riesgo.

Código	Riesgo	Componente principal	Probabilidad	Impacto	Nivel	Justificación resumida
R1	Inyección SQL	Login, filtros y operaciones administrativas	Baja	Alto	Medio	El uso sistemático de PDO con consultas preparadas reduce la probabilidad, pero una regresión permitiría comprometer cuentas y datos.
R2	XSS almacenado	Noticias, materiales, FAQ y consultas	Media	Medio	Medio	Existen salidas seguras, aunque los usos de `innerHTML` y las URL construidas por el frontend requieren revisión contextual completa.
R3	Robo de credenciales o fuerza bruta	Acceso de personal y Directora	Alta	Alto	Alto	Bcrypt y el límite de intentos reducen ataques directos, pero no eliminan phishing, reutilización de claves ni robo del token accesible al navegador.
R4	Falla de control de acceso	API administrativa, contenidos y reservas	Media	Alto	Alto	La API verifica sesión, cuenta activa, rol y propiedad; un error en una ruta nueva o modificada tendría consecuencias amplias.

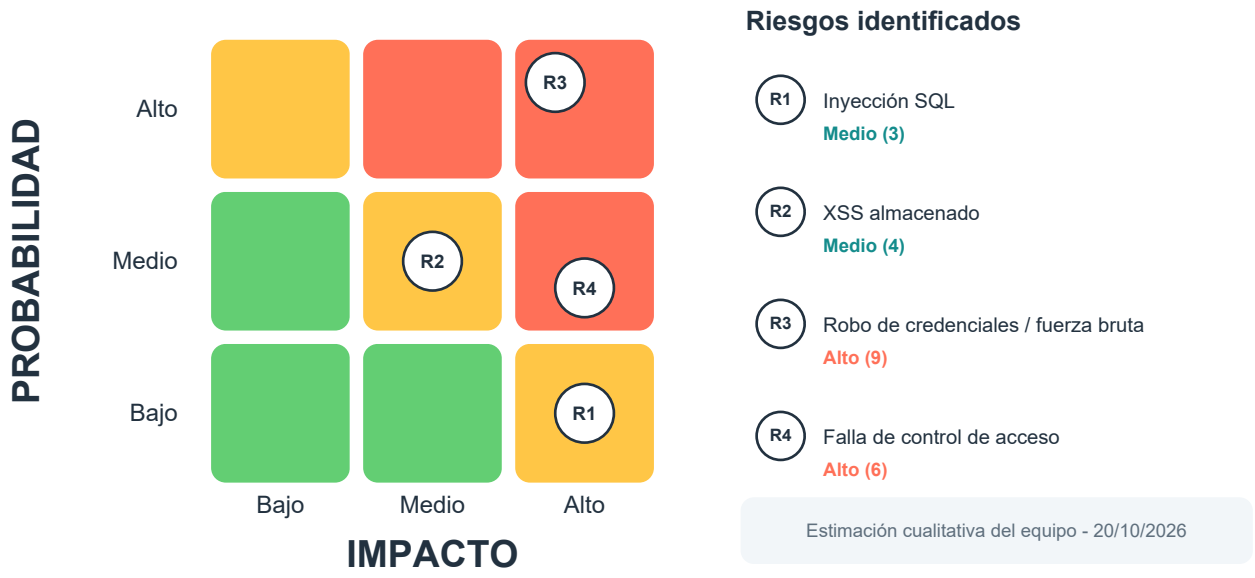


Figura 1. Mapa de riesgos del proyecto: probabilidad frente a impacto.

Criterio de escala del mapa. La probabilidad se valora como **Baja (1)** cuando el escenario exige condiciones excepcionales o los controles actuales reducen de forma clara su ocurrencia; **Media (2)** cuando el escenario es plausible y existe exposición o cobertura parcial; y **Alta (3)** cuando puede ocurrir con facilidad, depende también de factores humanos o los controles no bastan para prevenirlo. El impacto es **Bajo (1)** si el efecto es limitado, reversible y no compromete datos sensibles ni funciones críticas; **Medio (2)** si afecta temporalmente una función o un conjunto acotado de datos o usuarios; y **Alto (3)** si permite acceso privilegiado, exposición o alteración relevante de datos, publicación maliciosa o indisponibilidad significativa. El nivel se obtiene multiplicando probabilidad por impacto: **Bajo (1-2, verde)**, **Medio (3-4, amarillo)** y **Alto (6-9, rojo)**. La valoración fue realizada por el equipo del proyecto el 20/10/2026 y debe revisarse después de cada cambio relevante o nueva prueba de seguridad.

El mapa también conserva la relación con los componentes y efectos analizados originalmente:

Componente del sistema	Amenaza(s) asociada(s)	Impacto técnico	Impacto sobre usuarios
Login administrativo	Inyección SQL; robo de credenciales; fuerza bruta.	Omisión de autenticación, acceso a una cuenta y ejecución de acciones con permisos del personal.	Suplantación de identidad y atribución incorrecta de cambios en el historial.
Carga de contenidos	XSS almacenado; fallas de acceso; archivos inseguros.	Publicación o modificación no autorizada, almacenamiento de contenido malicioso y pérdida de integridad.	Información falsa, desactualizada o maliciosa desde un sitio identificado como oficial.
Consulta pública	XSS almacenado; exposición de contenido no publicado.	Ejecución en el navegador y visualización anticipada de contenido interno.	Redirecciones, contenido manipulado o acceso antes de su aprobación y vigencia.
Base de datos	Inyección SQL; acceso no autorizado.	Lectura, alteración o eliminación de cuentas, contenidos, consultas, reservas e historial.	Exposición de datos, pérdida de información pública o interrupción del servicio.

4. Controles presentes y límites

Área	Implementación disponible	Límite o evidencia adicional necesaria
Contraseñas	Hash bcrypt con costo 12 y `password_verify`; la salida del usuario omite el hash.	La política institucional de claves, recuperación y cuentas debe acordarse. El alta posterior de personal conserva una clave inicial fija.
Sesiones	Bearer opaco, secreto aleatorio de 32 bytes, hash SHA-256 y ocho horas de vigencia. Ingreso revoca sesiones previas; logout y desactivación revocan tokens.	`sessionStorage` es accesible a scripts del mismo origen; la prevención de XSS y HTTPS son necesarias en el entorno real.
Roles	Comprobación de cuenta activa y rol en cada operación protegida; Directora hereda acceso de personal y es la única que aprueba.	La asignación y revisión institucional de permisos no se deduce de las cuentas de demostración.
Intentos de acceso	Cinco intentos por minuto por IP y operación para login/registro, con contador y bloqueo de archivo compartido.	No es un limitador general de todas las rutas; varias instancias necesitan caché compartida.
SQL e integridad	PDO preparado, transacciones, claves foráneas y restricciones únicas. Reserva bloquea la franja antes de comprobar cupo.	La parametrización no sustituye los permisos y las reglas de negocio.
Entradas y errores	`Solicitud` valida JSON/multipart, tipos, tamaños, opciones, fechas, horas, cédulas y URL. Los errores internos no devuelven SQL o claves.	La validación del navegador es complementaria. Se debe revisar cada contexto de salida de HTML y URL.
Archivos	MIME/contenido, límites por recurso, nombres aleatorios y rutas restringidas fuera de `public`.	VIDEO usa URL externa; los proveedores y sus condiciones deben definirse para la operación institucional.
Publicación	Estados Borrador, Pendiente, Aprobado y Publicado; edición devuelve a borrador y noticias se filtran por vigencia.	Una aprobación técnica de contenido no es una aceptación del proyecto.
Auditoría	Operaciones administrativas guardan usuario, acción, fecha y elemento en la misma transacción de datos.	No conserva valores anterior/nuevo; cobertura total y retención están por acordar. La cancelación ciudadana elimina la reserva sin estado histórico.
Infraestructura	MySQL sin puerto del host, frontends montados en lectura y raíz Apache limitada a `public`.	La configuración local no incorpora dominio ni HTTPS de producción; falta evidencia final de hardening y recuperación.

5. Superficies específicas

Contenidos y consultas

Noticias, materiales y FAQ se administran con sesión y permisos. El portal solo debe consumir la representación pública. La bandeja de consultas contiene datos personales y su lectura requiere acceso de personal; el formulario público no expone su listado. La revisión de salida debe considerar los módulos que utilizan `innerHTML`, además de los que construyen nodos con `textContent`.

Simulacro

La consulta pública omite la respuesta correcta. La corrección obtiene la solución desde la base, sin aceptar del navegador una marca de respuesta verdadera. Las imágenes admitidas son JPG, PNG y WEBP de hasta 2048 KB. Debe comprobarse tanto la carga válida como el rechazo de contenido ejecutable y la descarga del recurso almacenado.

Agenda académica

La reserva se asocia a la cuenta del token. La transacción y el bloqueo impiden superar el cupo por solicitudes simultáneas, y la unicidad evita duplicación por ciudadano/franja. La ruta DELETE comprueba el propietario; personal recibe rechazo de rol y otra cuenta ciudadana no puede eliminar el registro. El borrado libera capacidad y no conserva un historial de cancelación.

Los listados solo muestran fechas vigentes; ese filtro de presentación no elimina los registros pasados ni define su conservación. La política de retención debe contemplar datos efectivamente guardados, no solo lo que la interfaz permite ver.

6. Evidencia final

La entrega reúne evidencia técnica de las tres etapas de Ciberseguridad:

- Análisis de amenazas, mapa de riesgos y controles aplicables.
- Semgrep con hallazgos y correcciones documentadas.
- OWASP ZAP y Nmap sobre el entorno local autorizado.
- Auditoría Bash de autenticación, permisos, entradas y archivos.
- Hardening de Apache/PHP y MySQL mediante Docker Compose.
- Registro de hallazgos y procedimiento de respuesta a incidentes.
- Términos y privacidad incluidos; los datos institucionales se completarán con información validada por la Intendencia.

7. Cierre

Las pruebas se realizaron sobre el entorno local autorizado y con datos de prueba. Los resultados describen el alcance evaluado y no afirman ausencia absoluta de vulnerabilidades. No se atacaron sistemas externos ni se utilizaron datos personales reales.

8. Referencias

- Requisitos, arquitectura, infraestructura y contrato de API.
- OWASP SQL Injection.
- OWASP XSS Prevention.
- OWASP Authentication y Authorization.
- OWASP Input Validation y Password Storage.
- OWASP Logging y File Upload.

INFORME DE SEGURIDAD

Informe de análisis estático de seguridad

Portal Vial y Educación Vial IMSJ

Fecha	20 de octubre de 2026
Herramienta	Semgrep OSS 1.180.0 con configuración automática
Alcance	144 archivos seguidos por Git en backend, frontends y documentación
Resultado bruto	11 coincidencias: 1 ERROR y 10 WARNING
Triage	1 debilidad confirmada repetida en 8 archivos y 3 alertas de backend mitigadas

El escaneo no confirmó una inyección ni un acceso arbitrario a archivos en el backend. La acción prioritaria es eliminar la dependencia remota sin verificación de integridad usada por ocho páginas públicas. Las alertas del backend deben conservarse como evidencia de revisión y pueden endurecerse para reducir ambigüedad en futuros análisis.

11	546	144	99,9 %
coincidencias	reglas ejecutadas	archivos analizados	líneas interpretadas

Equipo RC5

Clasificación interna | Entregable técnico

Resumen ejecutivo

Semgrep informó 11 coincidencias y las marcó como bloqueantes para su política de salida. La cifra no equivale a 11 vulnerabilidades explotables. Ocho coincidencias corresponden a una misma debilidad de suministro en páginas HTML y tres requieren interpretar controles del backend.

Resultado del triage	Coincidencias	Lectura
Debilidad confirmada	8	Script de unpkg sin atributo integrity en ocho páginas públicas
Mitigada por el código	2	Ruta de caché basada en hash y borrado restringido a UPLOAD_ROOT
No explotable en el flujo revisado	1	Comando de verificación CLI con argumentos escapados y archivos de un directorio fijo

Decisión recomendada

Antes de publicar el portal, hospedar localmente Lucide o fijar la versión con Subresource Integrity y crossorigin. Después, repetir Semgrep y conservar el JSON de revalidación. Las tres alertas del backend no justifican por sí solas bloquear la entrega, pero conviene refactorizar el verificador de sintaxis para evitar la invocación mediante shell.

Prioridad de trabajo

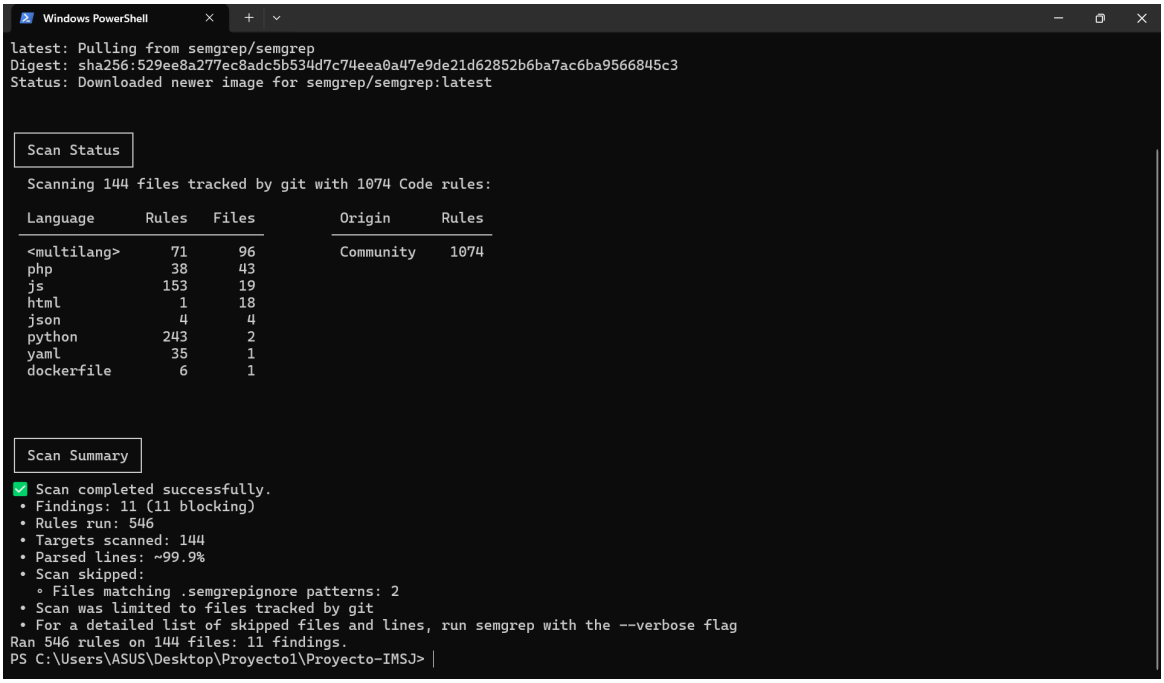
Orden	Acción	Criterio de cierre
1	Eliminar o verificar el script remoto en ocho HTML	Sin alertas missing-integrity y sin pérdida de iconos
2	Reemplazar passthru por una ejecución sin shell	El script verifica todos los PHP sin alerta exec-use
3	Documentar supresiones justificadas en Auth y Archivo	Excepción breve, localizada y asociada al control existente
4	Repetir el escaneo con salida fuera del repositorio	JSON sin error por autolectura y cobertura revisada

Alcance y método

El análisis se ejecutó con la imagen semgrep/semgrep y la configuración automática. La consola cargó 1.074 reglas comunitarias y aplicó 546 reglas compatibles a 144 archivos seguidos por Git. El reporte JSON identifica Semgrep OSS 1.180.0 y 11 resultados.

Lenguaje	Reglas mostradas	Archivos
Multilenguaje	71	96
PHP	38	43
JavaScript	153	19
HTML	1	18
JSON	4	4
Python	243	2
YAML	35	1
Dockerfile	6	1

Evidencia de ejecución



Captura 1. Resumen de la ejecución de Semgrep proporcionado con el análisis.

Cobertura y limitaciones

El resultado cubre el código que Semgrep alcanzó a analizar con las reglas aplicables. No sustituye pruebas dinámicas, revisión de configuración en ejecución, pruebas autenticadas ni análisis de dependencias. Un resultado sin alertas tampoco demostraría ausencia de vulnerabilidades.

Incidencia	Efecto	Tratamiento
sast-report.json produjo un error de sintaxis durante el escaneo	La redirección creó el archivo de salida dentro del volumen antes de que Semgrep terminara	Generar la salida fuera del repositorio o excluir ese nombre
Dockerfile tuvo análisis parcial entre las líneas 5 y 18	Parte de ese archivo pudo no recibir todas las reglas previstas	Revisar sintaxis y reanalizar el Dockerfile
Timeout de punto fijo en backend/public/index.php	Una regla de análisis de flujo no completó su evaluación	Repetir con mayor capacidad o una regla dirigida
Dos archivos ignorados y alcance limitado a Git	Archivos ignorados o no seguidos quedaron fuera	Revisar .semgrepignore y confirmar que el alcance sea intencional

Conclusión de cobertura. Los 11 resultados pueden analizarse, pero el informe no debe presentarse como una certificación integral del proyecto. La revalidación debe cerrar las incidencias de cobertura y demostrar la corrección del hallazgo confirmado.

Triage de hallazgos

ID	Regla y ubicación	Semgrep	Triage	Prioridad
SAST 01	missing-integrity en 8 páginas públicas	WARNING	Confirmado	Media
SAST 02	exec-use en backend/scripts/verificar.php:22	ERROR	No explotable en el flujo	Baja
SAST 03	unlink-use en backend/models/Archivo.php:80	WARNING	Mitigado	Baja
SAST 04	tainted-filename en backend/core/Auth.php:62	WARNING	Falso positivo	Informativa

Criterio aplicado

La severidad de Semgrep se conserva como dato de la herramienta. La prioridad del informe considera si la entrada es controlable por un atacante, qué validaciones se ejecutan antes del punto sensible y si el flujo está expuesto por HTTP o limitado a una utilidad local.

Distribución del resultado bruto

Severidad	Cantidad	Reglas
ERROR	1	php.lang.security.exec-use.exec-use
WARNING	10	tainted-filename, unlink-use y missing-integrity

SAST 01
Dependencia externa sin verificación de integridad

CONFIRMADO

Severidad de Semgrep: WARNING

Ocho páginas cargan la versión 0.468.0 de Lucide desde unpkg. La versión está fijada, pero las etiquetas script no incluyen el atributo integrity. Si el contenido remoto o su cadena de distribución fuese alterado, el navegador ejecutaría el JavaScript modificado con los permisos de la página.

Evidencia

Archivo	Línea	Recurso
frontend-publico/agenda.html	21	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/consulta.html	21	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/estudio.html	21	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/index.html	151	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/noticias.html	86	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/preguntas.html	21	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/prueba.html	32	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/renovagenda.html	25	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js

Clasificación

CWE-353 Missing Support for Integrity Check. OWASP A08 Software and Data Integrity Failures.

Corrección recomendada

Opción	Implementación	Observación
Preferida	Hospedar lucide.min.js dentro del proyecto y servirlo desde el mismo origen	Reduce la dependencia operativa del CDN
Alternativa	Agregar integrity con el hash del archivo exacto y crossorigin=anonymous	Actualizar el hash cuando cambie la versión

Validación

Abrir las ocho páginas, verificar que los iconos se rendericen y repetir Semgrep. El cierre exige cero coincidencias de missing-integrity o una excepción documentada si se adopta otra arquitectura.

Hallazgos del backend

SAST 02
Ejecución de un comando construido dinámicamente

NO EXPLOTABLE

Severidad de Semgrep: ERROR

La línea 22 usa passthru para ejecutar el verificador de sintaxis de PHP. Semgrep trata cualquier comando no constante como posible inyección. En este flujo, PHP_BINARY es una constante del intérprete, los archivos se enumeran bajo backend y tanto el binario como la ruta pasan por escapeshellarg. Además, el script termina si no se ejecuta por CLI. No se identificó una entrada HTTP o un argumento del usuario que alcance el comando.

```
passthru(escapeshellarg(PHP_BINARY) . ' -l ' . escapeshellarg($file->getPathname()), $status);
```

Riesgo residual y mejora

El uso de una cadena de shell mantiene una superficie innecesaria y dificulta el análisis automático. Reemplazarlo por proc_open con una lista de argumentos, o por una API de procesos que no invoque shell, conserva la función y elimina el patrón reportado.

SAST 03
Eliminación de archivo a partir de una ruta variable

MITIGADO

Severidad de Semgrep: WARNING

Archivo::delete recibe una ruta variable, pero rechaza URLs, resuelve la ruta real desde UPLOAD_ROOT, exige que permanezca dentro de ese directorio y confirma que el destino sea un archivo antes de llamar a unlink. Estos controles bloquean el recorrido de directorios que describe CWE-22 en el flujo revisado.

```
!unlink($resolved)
```

Riesgo residual y mejora

Conservar las comprobaciones juntas y agregar pruebas automatizadas con rutas ../, rutas absolutas, URLs y enlaces simbólicos. Si la alerta se suprime, hacerlo en la línea exacta e indicar que realpath y la comparación con UPLOAD_ROOT son el control compensatorio.

SAST 04
Nombre de archivo derivado de datos de la solicitud

FALSO POSITIVO

Severidad de Semgrep: WARNING

El nombre de la caché combina la operación y la IP, pero antes de crear el archivo aplica SHA-256. El resultado es una cadena hexadecimal de longitud fija. CACHE_ROOT proviene de la configuración del servidor y el código no realiza una solicitud de red, por lo que la clasificación SSRF de la regla no coincide con el comportamiento observado.

```
$file = fopen(CACHE_ROOT . '/' . $key . '.json', 'c+');
```

Tratamiento

Mantener el hash y la raíz de caché fija. Documentar una supresión localizada con la justificación anterior y una prueba que confirme que el nombre final solo contiene 64 caracteres hexadecimales seguidos de .json.

Plan de corrección y revalidación

Paso	Responsable sugerido	Trabajo	Evidencia
1	Frontend	Autohospedar Lucide o configurar SRI en ocho HTML	Diff y prueba visual
2	Backend	Eliminar la cadena de shell en verificar.php	Salida del verificador
3	Backend y QA	Agregar pruebas de rutas y nombre de caché	Pruebas automatizadas
4	QA	Repetir Semgrep y revisar errores de cobertura	Nuevo JSON y captura
5	Revisión interna	Comparar resultados y aprobar excepciones	Acta o registro de cierre

Comando de revalidación

```
$tempReport = Join-Path $env:TEMP 'imsj-sast-report.json'
docker run --rm -v "${PWD}:/src" semgrep/semgrep semgrep scan --config auto --exclude sast-report.json --json >
$tempReport
Copy-Item -LiteralPath $tempReport -Destination .\sast-report.json -Force
```

El archivo temporal evita que Semgrep intente analizar su propia salida mientras se está escribiendo. La exclusión mantiene el comportamiento correcto si ya existe una copia del JSON en el repositorio.

Criterios de cierre

Control	Condición de aceptación
Integridad de recursos	Cero alertas missing-integrity y páginas funcionales
Backend	Sin alerta exec-use o con excepción técnicamente justificada
Cobertura	Sin autolectura del JSON y con Dockerfile e index.php revisados
Trazabilidad	JSON, captura, commit y decisión de triage conservados

Conclusión

El hallazgo accionable del escaneo es la falta de verificación de integridad del script remoto en ocho páginas públicas. Las alertas de backend no muestran una vía de explotación en el código revisado, aunque una mejora en verificar.php facilitará el cierre automático. El informe debe actualizarse después de aplicar las correcciones y repetir el análisis.

Revalidación posterior a correcciones

Semgrep OSS se ejecutó nuevamente el 21/10/2026 sobre el árbol de trabajo derivado del commit **5f15b3b**. La ejecución terminó correctamente y produjo un JSON independiente para comparar los resultados antes y después de las correcciones.

11	6	0	546
coincidencias iniciales	coincidencias posteriores	missing-integrity restantes	reglas ejecutadas

Comparación y decisión

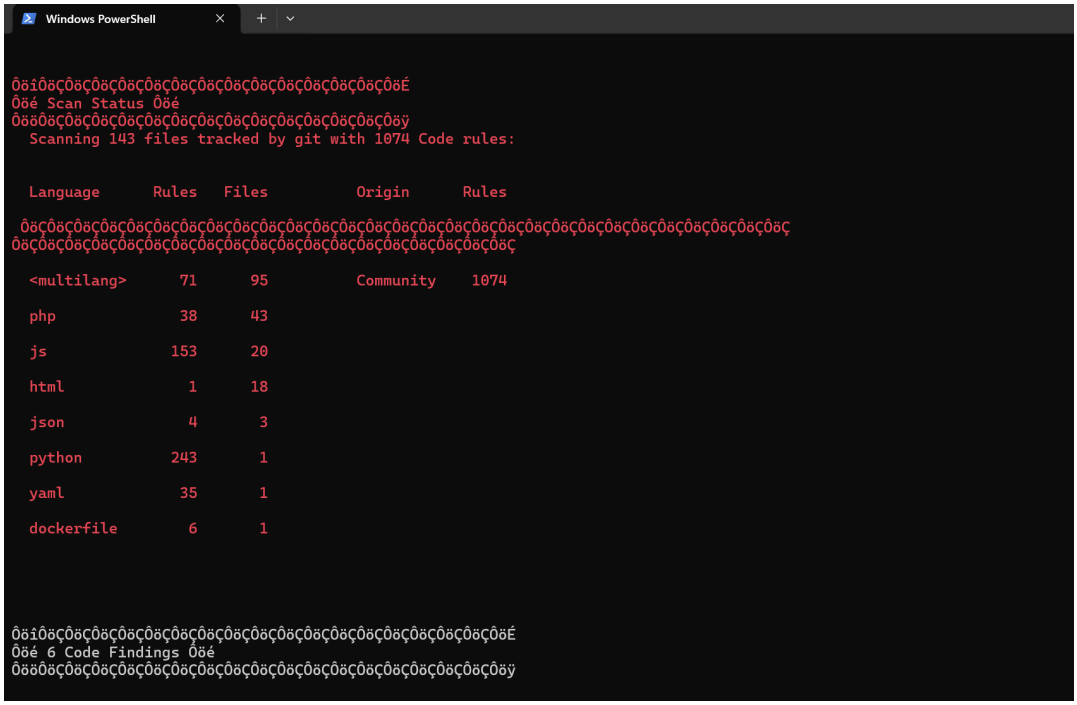
Control	Antes	Después	Decisión
Integridad de recursos	8 alertas por Lucide remoto sin integrity.	0 alertas; los iconos se sirven desde un archivo local.	Cerrado.
Ejecución de procesos	passthru con comando construido como texto.	proc_open recibe una lista de argumentos y no invoca un shell.	Mitigado; Semgrep conserva 1 alerta por el uso del sink.
Ruta de caché	1 alerta tainted-filename.	Permanece la coincidencia; la clave continúa reducida a SHA-256 y raíz fija.	Falso positivo documentado.
Borrado de archivos	1 alerta unlink-use.	Permanece la coincidencia; realpath y UPLOAD_ROOT restringen el destino.	Mitigado; mantener pruebas de rutas.
Formularios de acceso	No se informaba CSRF porque no declaraban POST.	3 alertas de una regla para plantillas Django.	No aplicable: HTML estático, API PHP y autenticación Bearer sin cookies.

Conclusión SAST

La debilidad confirmada de cadena de suministro quedó corregida. Las seis coincidencias posteriores no representan seis vulnerabilidades explotables: tres son la regla Django aplicada fuera de contexto, dos conservan controles compensatorios ya revisados y una corresponde a una utilidad CLI que ahora ejecuta PHP sin construir una línea de shell.

Evidencia y límites de cobertura

Captura 2. Resumen de la segunda ejecución de Semgrep proporcionada por el equipo.



Trazabilidad

Artefacto	SHA-256
informes-sast-post/semgrep-post.json	1A11FF607656121E675DE1EE7D31A0BCAA7BD6CD18B2A402ED27A87478FDDE59
informes-sast-post/semgrep-post-terminal.txt	F48B522056EB3C56A94DE8D0000C3432D4EDBC84792F7F5BAF20073CCFE66E63

Limitaciones

La ejecución registró 1 advertencia de análisis parcial sobre el Dockerfile. Además, Semgrep indicó que limitó el alcance a archivos seguidos por Git: el nuevo archivo local de iconos todavía no estaba versionado y el ajuste final del nombre de la configuración Apache ocurrió después de esta ejecución. El cierre formal debe identificar el commit final y, si se exige cobertura exacta de todo el corte, repetir Semgrep una vez versionados esos cambios.

INFORME DE HARDENING DE INFRAESTRUCTURA Y CONTENEDORES

Proyecto IMSJ - Portal vial y API REST

RESULTADO	APROBADO
Servicios	Apache/PHP y MySQL saludables
Endurecimiento	Usuarios no privilegiados, no-new-privileges, capacidades mínimas y raíz de solo lectura
Regresión	41 aprobadas, 0 fallidas, 2 omitidas, salida 0
Fecha	21 de octubre de 2026

Documento: IMSJ-CIB-HARD-2026-10-21

Versión evaluada: rama main, HEAD 5f15b3b9313d con cambios de hardening aún pendientes de asociación al commit final.

Responsable documental: equipo RC5. Alcance: entorno Docker local autorizado y datos de prueba.

1. Resumen ejecutivo

Se endurecieron los dos servicios Docker del proyecto IMSJ sin alterar su funcionalidad observable. La aplicación se ejecuta íntegramente como www-data; MySQL lo hace como mysql. Ambos contenedores impiden la elevación de privilegios, descartan capacidades Linux y utilizan una raíz de solo lectura. Apache conserva únicamente CAP_NET_BIND_SERVICE para escuchar en el puerto interno 80; MySQL no conserva capacidades adicionales.

Conclusión

Los controles quedaron incorporados al compose.yaml del proyecto. Los dos healthchecks finalizaron en estado healthy y la auditoría de regresión no registró fallos.

2. Objetivo y alcance

El objetivo fue reducir el impacto de una eventual explotación dentro de los contenedores y comprobar que las restricciones no impiden el arranque, la persistencia, los healthchecks ni los controles de seguridad de la API. Las pruebas se realizaron en un entorno Docker local autorizado con datos de prueba. El despliegue final se define para Ubuntu Server 24.04 LTS. No se atacaron sistemas externos.

3. Metodología

Paso	Actividad	Criterio de aceptación
1	Línea de base y healthchecks	app y db saludables; MySQL sin puerto publicado
2	Aplicación gradual de controles	Recrear un servicio por vez y conservar disponibilidad
3	Inspección de runtime	Usuario, capacidades, no-new-privileges y ReadonlyRootfs visibles
4	Regresión de API	Cero pruebas fallidas y salida 0
5	Arranque habitual	docker compose up -d conserva los controles

4. Matriz de controles aplicados

Control	Aplicación	MySQL	Resultado
Usuario no privilegiado	www-data	mysql (UID 999)	Cumple
no-new-privileges	Activo	Activo	Cumple
Capacidades Linux	DROP ALL; agrega NET_BIND_SERVICE	DROP ALL; no agrega	Cumple
Raíz de solo lectura	Activa	Activa	Cumple
Directorios temporales	/tmp, /run/apache2, /var/lock/apache2	/tmp, /var/run/mysqld	Cumple
Datos persistentes	uploads y cache en volúmenes	db_data en volumen	Cumple
Exposición de red	APP_BIND:APP_PORT -> 80	Sin publicación al host	Cumple

Configuración efectiva resumida

```
services:
  app:
    user: www-data
    security_opt: [no-new-privileges:true]
    read_only: true
    cap_drop: [ALL]
    cap_add: [NET_BIND_SERVICE]
    tmpfs: [/tmp, /run/apache2, /var/lock/apache2]

  db:
    user: mysql
    security_opt: [no-new-privileges:true]
    read_only: true
    cap_drop: [ALL]
    tmpfs: [/tmp, /var/run/mysqld]
```

Evidencia 1

Bloqueo de elevación de privilegios

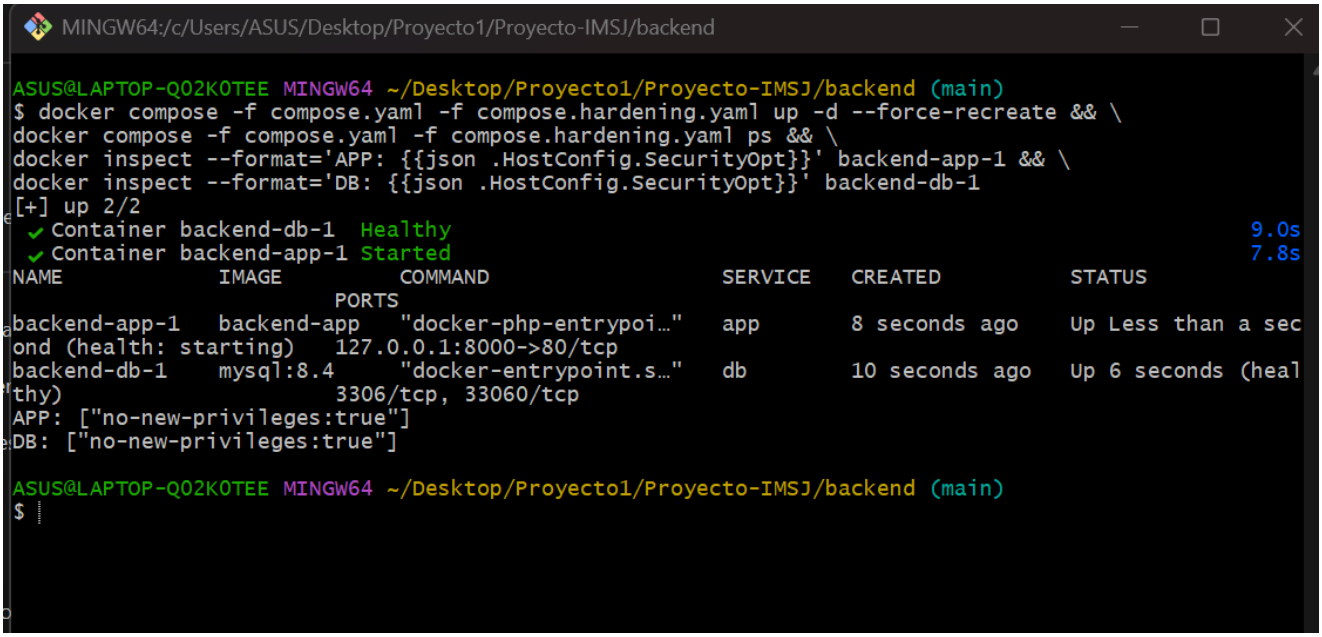


Figura 1. Primera aplicación del control security_opt en ambos servicios.

- La inspección devuelve no-new-privileges:true para app y db.
- Ambos servicios completan el arranque; la aplicación pasa a healthy segundos después, confirmado en la verificación siguiente.
- El control impide que procesos dentro del contenedor adquieran privilegios adicionales mediante binarios setuid o mecanismos equivalentes.

Evidencia 2

Usuario no privilegiado y capacidades mínimas en Apache

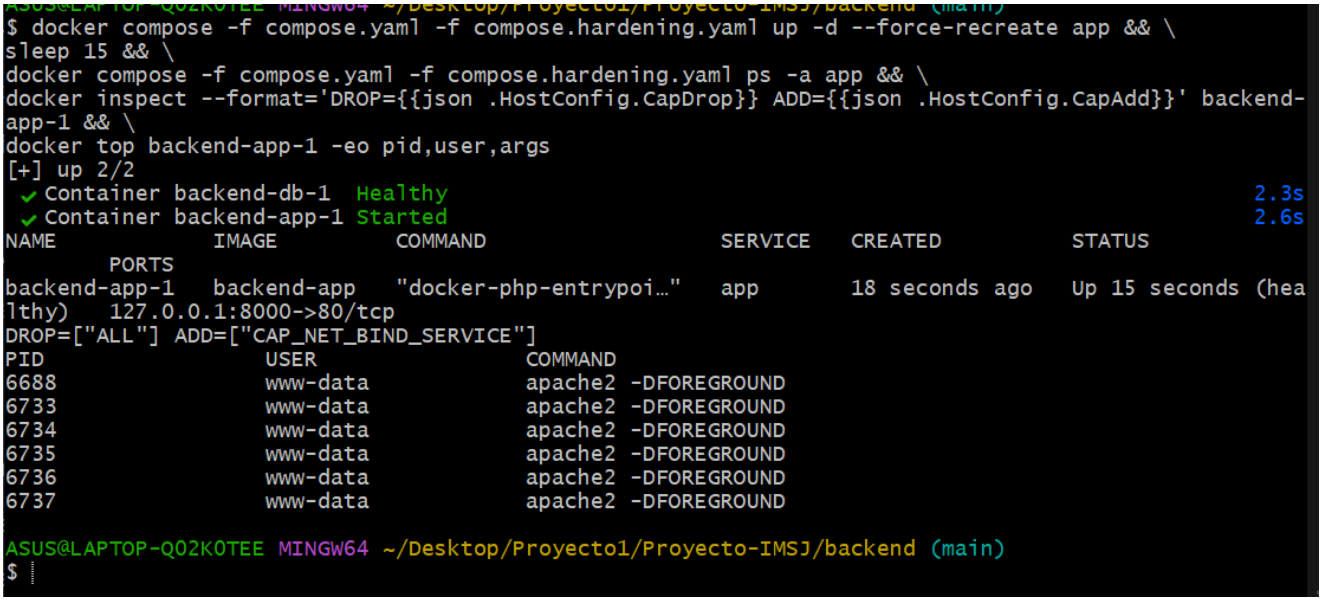


Figura 2. Estado de app después de reducir capacidades y ejecutar Apache íntegramente como www-data.

- El servicio app permanece healthy con todas las capacidades descartadas.
- Se agrega únicamente CAP_NET_BIND_SERVICE para conservar el puerto interno 80.
- Todos los procesos Apache observados se ejecutan como www-data; no queda un proceso maestro root.

Evidencia 3

Raíz de solo lectura y capacidades eliminadas en MySQL



Figura 3. Configuración efectiva del contenedor de base de datos.

- app y db aparecen healthy durante la misma verificación.
- MySQL informa READ_ONLY=true, DROP=[ALL] y ADD=null.
- El proceso mysqld utiliza UID 999, correspondiente al usuario mysql de la imagen.
- La base conserva escritura únicamente en su volumen de datos y en tmpfs temporales.

Evidencia 4

Revalidación funcional y de seguridad

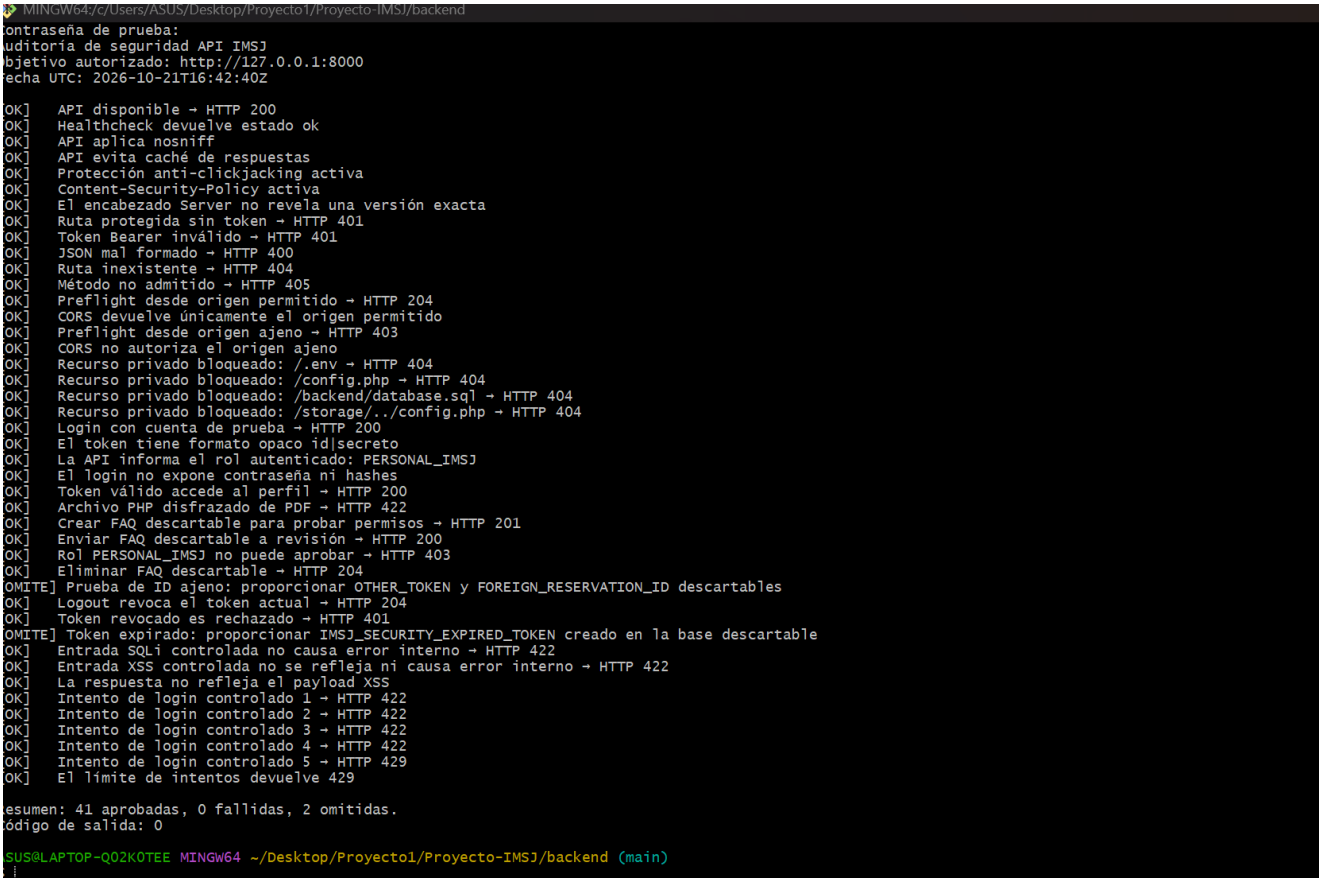


Figura 4. Auditoría Bash ejecutada nuevamente después del hardening.

- Resultado: 41 aprobadas, 0 fallidas y 2 omitidas; código de salida 0.
- La prueba incluye healthcheck, cabeceras, CORS, autenticación, rol PERSONAL_IMSJ, carga maliciosa, operaciones descartables, SQLi/XSS controladas y rate limiting.
- Las dos omisiones son token expirado e ID ajeno, ya acreditadas en la ejecución estricta anterior de 43 aprobadas, 0 fallidas y 0 omitidas.

Persistencia del hardening en Docker Compose

Los controles forman parte de backend/compose.yaml y se aplican cada vez que los servicios se crean con Docker Compose.

```
services:
  app:
    user: www-data
    security_opt: [no-new-privileges:true]
    read_only: true
    cap_drop: [ALL]
    cap_add: [NET_BIND_SERVICE]
  db:
    user: mysql
    security_opt: [no-new-privileges:true]
    read_only: true
    cap_drop: [ALL]
```

Figura 5. Controles persistentes en compose.yaml.

- La configuración se aplica con docker compose up -d.
- MySQL permanece sin puerto publicado en el host.

5. Requisito HTTPS para producción

La publicación del servicio se controla mediante APP_BIND y APP_PORT. En Ubuntu Server se expone únicamente el puerto requerido por UFW. Para producción, el tráfico externo debe terminar en un proxy inverso o balanceador con TLS 1.2 o superior, certificado válido y renovación automática.

Requisito	Decisión de despliegue
Exposición	Publicar solo 443/TCP en el proxy; mantener app y MySQL en red privada.
Redirección	Redirigir HTTP a HTTPS y evitar contenido mixto.
Certificado	Usar una autoridad confiable y automatizar renovación y alertas de vencimiento.
Cabeceras	Activar HSTS únicamente después de comprobar HTTPS en todo el dominio.
Origen	Ajustar APP_URL y FRONTEND_ORIGIN al dominio https:// definitivo.
Validación	Healthchecks, auditoría Bash y ZAP registrados en evidencias.

6. Riesgos residuales y limitaciones

• El informe valida el entorno local y no sustituye una revisión del proveedor de alojamiento, firewall, DNS, certificados ni copias de seguridad de producción.

• CAP_NET_BIND_SERVICE permanece en app para conservar el puerto interno 80. Es una concesión mínima y documentada; puede eliminarse si una imagen futura escucha en un puerto no privilegiado.

• Los volúmenes persistentes continúan siendo escribibles por diseño. Su protección depende además de permisos del host, respaldo, cifrado y control de acceso operacional.

• No se afirma ausencia total de vulnerabilidades; se informa únicamente el alcance y las pruebas descritas.

- Los controles quedan definidos en el compose.yaml incluido en la entrega.

7. Integridad de la evidencia

Elemento	SHA-256
backend/compose.yaml	8F917FD28FBC0173F6CFE5E61A5778FDAA54692FF212DA174E425ABB292D128B
output/security-api-hardening.txt	2A7C9084745A0F6C75DD4F041550FC859BDDF1BB2314D3B7147B3E3FC34DA0CE

IMSJ

RC5

INFORME DE SEGURIDAD

Análisis dinámico de seguridad (DAST)

Portal Vial y Educación Vial IMSJ

Fecha de ejecución	20 de octubre de 2026
Herramientas	OWASP ZAP 2.17.0 (baseline) y Nmap 7.98
Objetivo	Portal público local en http://host.docker.internal:8000/
Entorno	Docker local, Apache httpd 2.4.68, puerto 8000/tcp
Identificador de versión	Commit 5f15b3b

El escaneo no produjo fallos de política ni alertas de severidad alta. Sí identificó una superficie de endurecimiento pendiente: cabeceras de seguridad, carga de recursos externos sin integridad y una ruta posible de envío de credenciales por URL. La recomendación es corregir los puntos prioritarios y repetir el escaneo antes de publicar el portal.

33	14	0	53
URLs exploradas	reglas con alerta	fallos del baseline	controles aprobados

Equipo RC5

Clasificación interna | Entregable técnico

01 | LECTURA EJECUTIVA

Resumen y decisión

El resultado es aceptable para un entorno local de desarrollo, pero no constituye una aprobación de seguridad para producción. ZAP ejecutó un baseline pasivo y no autenticado: observó respuestas y configuración expuesta, pero no intentó explotar la aplicación ni recorrió el panel administrativo con sesión.

Señal	Resultado	Lectura correcta
Baseline ZAP	0 FAIL · 14 WARN · 53 PASS	No hubo reglas configuradas como fallo; permanecen advertencias que requieren triage.
Reporte JSON	17 entradas · 67 instancias	Las 14 reglas se desagregan por variantes (COEP/COOP/CORP y caché).
Severidad ZAP	3 reglas medias · 7 bajas · 4 informativas	No se registraron reglas altas; la prioridad final también considera contexto de negocio.
Nmap	8000/tcp abierto · Apache 2.4.68	La exposición coincide con el servicio esperado, pero revela versión del servidor.

Decisión recomendada

Estado	Condición
PUBLICACIÓN CONDICIONADA	Resolver las prioridades P1, repetir ZAP y conservar el reporte de revalidación.
Uso local/demostración	Permitido dentro del alcance autorizado y sin datos reales.
Producción institucional	No recomendada con este informe como única evidencia; faltan HTTPS, prueba autenticada, API y validación de correcciones.

Prioridades de cierre

- P1. Evitar cualquier fallback GET de los formularios de acceso y confirmar que las credenciales nunca aparecen en la URL.
- P1. Definir una CSP compatible con el portal, protección anti-clickjacking y nosniff en respuestas HTML/estáticas.
- P1. Hospedar localmente Lucide o fijar su versión con Subresource Integrity y crossorigin.
- P2. Ocultar versiones, completar cabeceras cross-origin y validar la política de caché por tipo de recurso.
- P2. Repetir el análisis con sesión, Client Spider y pruebas específicas de API en un entorno autorizado.

Alcance, método y límites

Alcance autorizado

Elemento	Detalle
Objetivo principal	http://host.docker.internal:8000/frontend-publico/
Origen adicional	http://host.docker.internal:8000/ (redirección al portal público)
Contenido explorado	33 URLs informadas por la ejecución del baseline.
Servicio revisado	127.0.0.1:8000 desde contenedor Nmap con red del host.
Fuera de alcance efectivo	Panel IMSJ autenticado, acciones con sesión, cobertura completa de API, fuerza bruta, lógica de negocio, base de datos y pruebas activas.

Procedimiento reproducible

1. Se creó el directorio de evidencia y se ejecutó ZAP Baseline dentro del contenedor oficial estable.
2. ZAP utilizó Automation Framework, spider de hasta un minuto y escaneo pasivo; guardó HTML y JSON.
3. Se ejecutó Nmap TCP Connect con detección de versión únicamente sobre el puerto 8000 local.

```
docker run --rm -v "${PWD}/informes-dast:/zap/wrk:rw" --add-host=host.docker.internal:host-gateway
ghcr.io/zaproxy/zaproxy:stable zap-baseline.py -t http://host.docker.internal:8000/frontend-publico/ -r
zap-report.html -J zap-report.json -I

docker run --rm --network host instrumentisto/nmap -sT -sV -p 8000 127.0.0.1
```

Límites de interpretación

- El parámetro -I evita tratar las advertencias como error de salida; no convierte los WARN en controles aprobados.
- El baseline es principalmente pasivo. No acredita ausencia de SQLi, XSS, fallas de autorización, CSRF ni vulnerabilidades de lógica.
- La aplicación fue analizada por HTTP local. TLS, HSTS y configuración del dominio real deben comprobarse en el entorno de publicación.
- La alerta “Modern Web Application” sugiere usar Client Spider para descubrir rutas dependientes de JavaScript.

Panorama de alertas

La tabla resume las 17 entradas del JSON. La prioridad propuesta no replica mecánicamente la severidad de ZAP: combina exposición, facilidad de corrección y efecto sobre credenciales o ejecución en navegador.

ID	Hallazgo ZAP	Riesgo	Inst.	Prioridad
10038	Content Security Policy (CSP) Header Not Set	Medio	5	P1
10020	Missing Anti-clickjacking Header	Medio	5	P1
90003	Sub Resource Integrity Attribute Missing	Medio	5	P1
10024	Sensitive Information in URL	Info	3	P1 contextual
10021	X-Content-Type-Options Header Missing	Bajo	5	P1
10036	Server version disclosure	Bajo	5	P2
10037	X-Powered-By disclosure	Bajo	2	P2
10017	Cross-Domain JavaScript Source File Inclusion	Bajo	5	P2
90004	COEP Header Missing or Invalid	Bajo	3	P2
90004	COOP Header Missing or Invalid	Bajo	3	P2
90004	CORP Header Missing or Invalid	Bajo	5	P2
10063	Permissions Policy Header Not Set	Bajo	5	P2
10044	Big Redirect Detected	Bajo	2	P3
10027	Suspicious Comments	Info	2	P3 / falso positivo
10109	Modern Web Application	Info	3	Cobertura
10049	Non-Storable Content	Info	4	Revisar
10049	Storable and Cacheable Content	Info	5	Revisar

Distribución por regla única

Nivel ZAP	Reglas	Instancias	Interpretación
Medio	3	15	Controles del navegador ausentes o incompletos.
Bajo	7	35	Endurecimiento, aislamiento de origen y divulgación de información.
Informativo	4	17	Cobertura, caché y señales que necesitan validación manual.

Controles del navegador

DAST-01	Content Security Policy no definida	MEDIO
Observación	ZAP detectó ausencia de CSP en cinco respuestas, incluidas la raíz, el portal, estudio, login y noticias.	
Impacto	Sin una política explícita, un XSS o recurso manipulado dispone de mayor libertad para cargar scripts, estilos o destinos externos.	
Acción recomendada	Definir CSP inicialmente en modo Report-Only, observar incompatibilidades y luego aplicar una política restrictiva. Evitar unsafe-inline cuando sea posible y limitar script-src a orígenes necesarios.	
Criterio de cierre	Las páginas HTML responden con una CSP efectiva, la interfaz conserva su funcionalidad y ZAP ya no informa 10038.	

DAST-02	Protección anti-clickjacking ausente	MEDIO
Observación	Cinco páginas no enviaron X-Frame-Options ni una directiva CSP frame-ancestors equivalente.	
Impacto	Un sitio externo podría embeber la interfaz y engañar a una persona para interactuar con controles superpuestos.	
Acción recomendada	Preferir CSP frame-ancestors 'none' o una lista institucional mínima. Agregar X-Frame-Options: DENY como compatibilidad si el portal no necesita ser embebido.	
Criterio de cierre	Las respuestas HTML bloquean el embeber no autorizado y ZAP ya no informa 10020.	

DAST-03	Recursos de terceros sin verificación de integridad	MEDIO
Observación	ZAP registró cinco instancias y el código carga Lucide desde unpkg. El análisis SAST existente ya había señalado el mismo patrón en ocho páginas.	
Impacto	Una alteración del recurso o de su cadena de entrega podría ejecutar JavaScript bajo el origen del portal.	
Acción recomendada	Opción preferida: alojar una copia aprobada dentro del proyecto. Alternativa: fijar versión, hash SRI y atributo crossorigin, verificando que el proveedor entregue contenido inmutable.	
Criterio de cierre	No quedan scripts externos sin integridad; ZAP 90003 y la regla SAST correspondiente desaparecen sin pérdida de iconos.	

Credenciales y cabeceras

DAST-04	Posible exposición de credenciales en URL	ALTA CONTEXTUAL
Observación	ZAP observó tres URL de login con parámetros cedula, password y password_confirm. Los formularios HTML no declaran método; JavaScript cancela el envío y usa POST, pero un fallo, bloqueo o carga incompleta del script deja disponible el comportamiento GET por defecto.	
Impacto	Las URL pueden persistir en historial, registros, herramientas de monitoreo o cabeceras Referer. Aunque los valores ZAP eran sintéticos, el patrón es relevante para credenciales reales.	
Acción recomendada	Declarar explícitamente method='post' en los tres formularios y una acción segura o fallback que no exponga secretos. Mantener el envío API por POST y probar el comportamiento con JavaScript deshabilitado o fallido.	
Criterio de cierre	Ninguna navegación, log ni captura contiene contraseñas en query string; ZAP 10024 desaparece y las pruebas negativas confirman que GET no procesa credenciales.	

DAST-05	X-Content-Type-Options ausente en contenido web	BAJO
Observación	Cinco respuestas públicas, incluido CSS e imagen, no devolvieron X-Content-Type-Options: nosniff. La API sí define esta cabecera en sus respuestas JSON y archivos.	
Impacto	Algunos navegadores pueden interpretar un contenido con un tipo distinto al declarado, ampliando el efecto de cargas o respuestas mal configuradas.	
Acción recomendada	Configurar la cabecera en Apache para portal y panel, sin limitarla a las respuestas del backend PHP. Confirmar tipos MIME correctos.	
Criterio de cierre	Todas las respuestas estáticas y dinámicas incluyen nosniff y ZAP ya no informa 10021.	

DAST-06	Versiones y tecnología expuestas	BAJO
Observación	Nmap identificó Apache httpd 2.4.68 y ZAP detectó Server y X-Powered-By en varias respuestas, incluidas páginas 404.	
Impacto	La información reduce el trabajo de reconocimiento de un atacante y facilita asociar vulnerabilidades conocidas a versiones visibles.	
Acción recomendada	Aplicar ServerTokens Prod, ServerSignature Off y expose_php=Off. Mantener parches del contenedor y verificar también respuestas de error.	
Criterio de cierre	Las respuestas no revelan versión ni X-Powered-By; Nmap identifica el servicio sin una versión innecesariamente precisa.	

Observaciones agrupadas

Grupo	Evidencia	Riesgo	Tratamiento recomendado
Aislamiento cross-origin	COEP 3, COOP 3 y CORP 5 instancias	Bajo	Definir políticas solo después de inventariar recursos, ventanas y documentos compartidos; probar compatibilidad del portal.
Permissions-Policy	5 respuestas sin cabecera	Bajo	Deshabilitar capacidades del navegador no utilizadas (por ejemplo cámara, micrófono y geolocalización) y habilitar únicamente las justificadas.
JavaScript de otro dominio	5 páginas con fuente cross-domain	Bajo	Resolver junto con DAST-03: recurso local o proveedor fijado, SRI y CSP.
Redirecciones grandes	2 respuestas 302	Bajo	Conservar redirecciones simples y sin cuerpo sensible. Validar que Location no dependa de entrada externa.
Caché	4 no almacenables y 5 almacenables	Info	Distinguir HTML público, archivos estáticos y respuestas con identidad. Aplicar no-store a datos sensibles y versionado/max-age a recursos públicos.
Comentarios sospechosos	2 coincidencias en api.js	Info	Triage manual: la evidencia corresponde a una frase en español que contiene la secuencia “Retira”; parece falso positivo de la regla TODO. Conservar como revisado.
Aplicación moderna	3 instancias	Info	No es una vulnerabilidad. Usar Client Spider para mejorar la cobertura de rutas controladas por JavaScript.

Relación con la configuración observada

- backend/apache.conf limita índices y publica únicamente las rutas previstas, pero no define todavía el conjunto de cabeceras del portal.
- backend/core/Response.php ya envía no-store y nosniff para JSON; la corrección debe extenderse a HTML, CSS, JavaScript, imágenes y errores de Apache.
- frontend-publico/js/login.js cancela el submit y frontend-publico/js/api.js usa POST; el HTML debe conservar una defensa segura incluso si ese JavaScript no se ejecuta.

Exposición de red

Activo	Resultado Nmap	Evaluación
127.0.0.1:8000/tcp	open · http · Apache httpd 2.4.68	Servicio esperado en el entorno local. No se evaluaron otros puertos ni exposición externa.

Corrección y revalidación

Orden	Acción	Responsable sugerido	Evidencia de cierre
1 · P1	Asegurar POST/fallback de los formularios y eliminar credenciales de URL.	Frontend + backend	Prueba con JS activo/inactivo; logs e historial sin secretos; ZAP 10024 ausente.
2 · P1	Aplicar CSP, anti-clickjacking y nosniff en Apache.	Infraestructura	Cabeceras verificadas en 200, 302, 404 y API; interfaz sin regresiones.
3 · P1	Eliminar dependencia remota o agregar SRI/crossorigin.	Frontend	ZAP/SAST limpios para integridad y carga cross-domain.
4 · P2	Ocultar versiones y X-Powered-By.	Infraestructura	ZAP 10036/10037 ausentes; Nmap sin versión detallada.
5 · P2	Definir Permissions-Policy, políticas cross-origin y caché.	Arquitectura + infraestructura	Matriz de compatibilidad y nueva ejecución sin alertas no aceptadas.
6 · Cobertura	Ejecutar Client Spider y sesión de prueba sobre panel/API.	Seguridad / QA	Reporte autenticado, rutas cubiertas, usuarios de prueba y límites documentados.

Guion mínimo de revalidación

- Ejecutar la misma línea base contra el mismo corte de código y conservar HTML, JSON, consola y fecha.
- Comparar por identificador de regla: nuevo, persistente, corregido o aceptado con justificación.
- Comprobar manualmente cabeceras en 200, redirecciones y errores; revisar que CSP no rompa iconos, navegación ni formularios.
- Confirmar que login y registro no generan query strings con claves, aun si JavaScript no carga.
- Añadir escaneo autenticado de panel/API con cuentas de rol acotado y datos sintéticos.

Criterio de aceptación propuesto

Condición	Umbral
Hallazgos P1	0 abiertos
Alertas medias nuevas	0, salvo aceptación explícita documentada
Credenciales en URL	0 instancias y prueba negativa aprobada
Regresiones funcionales	0 en navegación, login, registro e iconos
Trazabilidad	Commit, fecha, comandos, reportes y capturas conservados

08 | EVIDENCIA

Ejecución del baseline ZAP

La captura registra la creación del directorio, descarga de la imagen oficial estable, inicio del Automation Framework, total de 33 URLs y controles PASS iniciales.

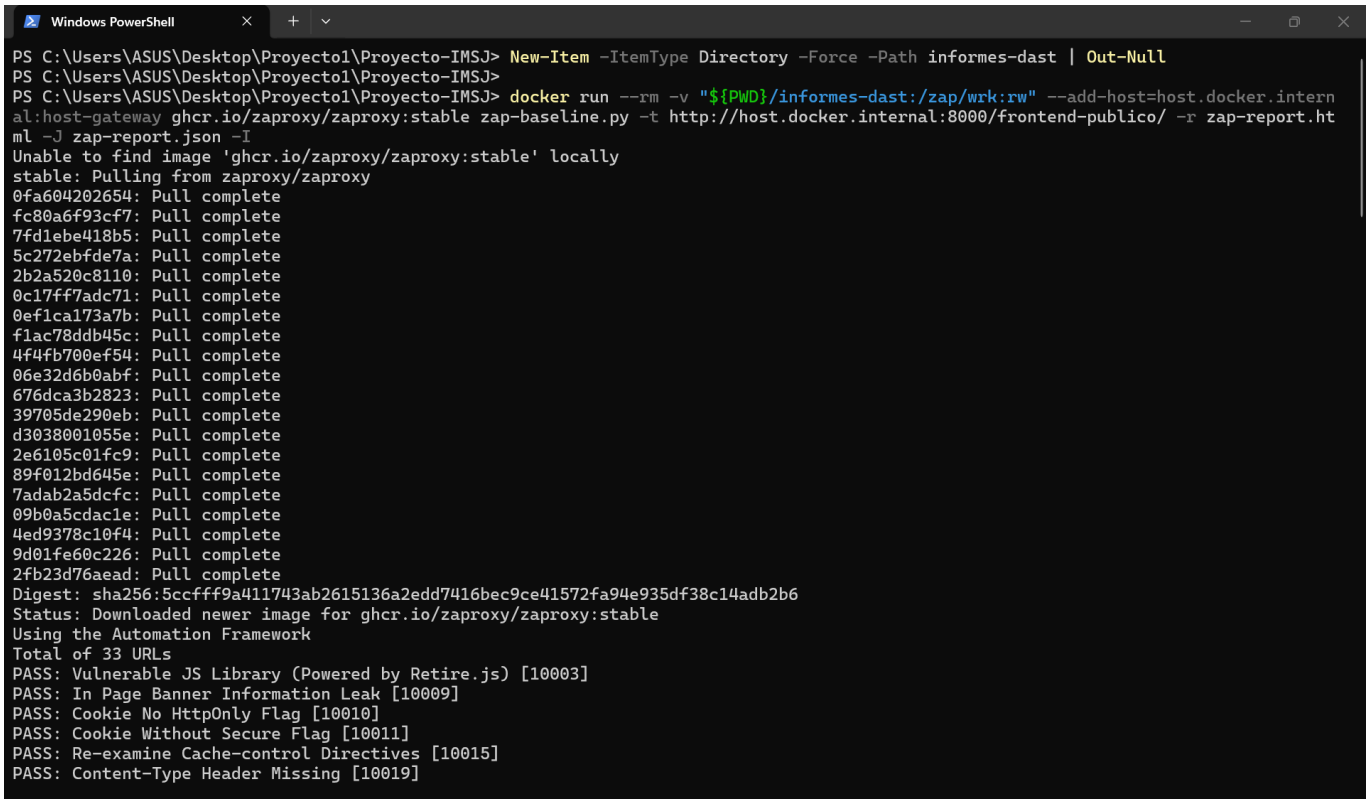


Figura 1. Inicio y progreso del escaneo ZAP Baseline, 20/10/2026.

Dato verificable	Valor
Imagen	Captura de pantalla 2026-10-20 170835.png
Comando	zap-baseline.py con salida HTML y JSON
Objetivo	http://host.docker.internal:8000/frontend-publico/
Contexto	Contenedor con host.docker.internal resuelto mediante host-gateway

09 | EVIDENCIA

Alertas y resumen del baseline

La salida final muestra ejemplos de políticas ausentes y el resumen consolidado: 0 FAIL, 14 WARN y 53 PASS. Ese resultado se corresponde con las 14 reglas únicas registradas en el JSON.

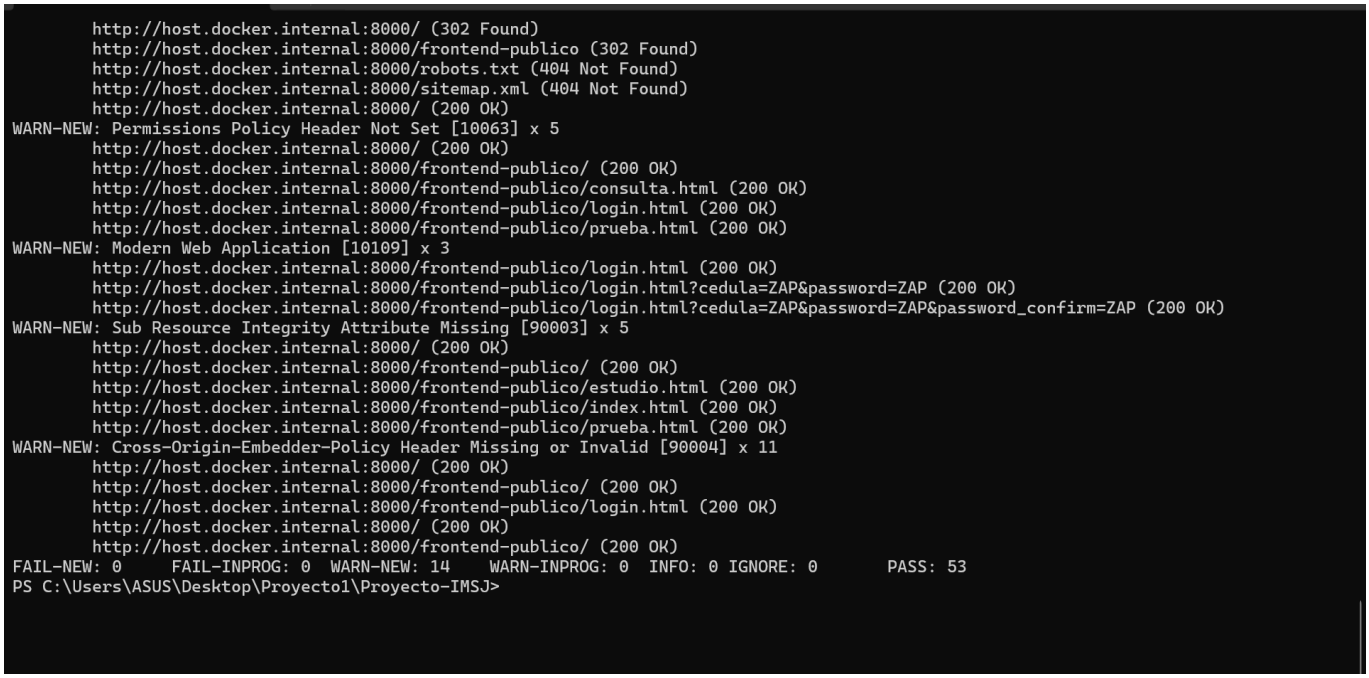


Figura 2. Tramo final del baseline y resumen de resultados, 20/10/2026.

Indicador	Resultado
FAIL-NEW / FAIL-INPROG	0 / 0
WARN-NEW / WARN-INPROG	14 / 0
INFO / IGNORE / PASS	0 / 0 / 53
Lectura	El baseline terminó sin fallos de política, pero requiere triage y revalidación de advertencias.

Reconocimiento Nmap y procedencia

Nmap confirmó que el host local estaba activo y que el puerto previsto publicaba HTTP mediante Apache. El análisis se limitó expresamente a 8000/tcp.

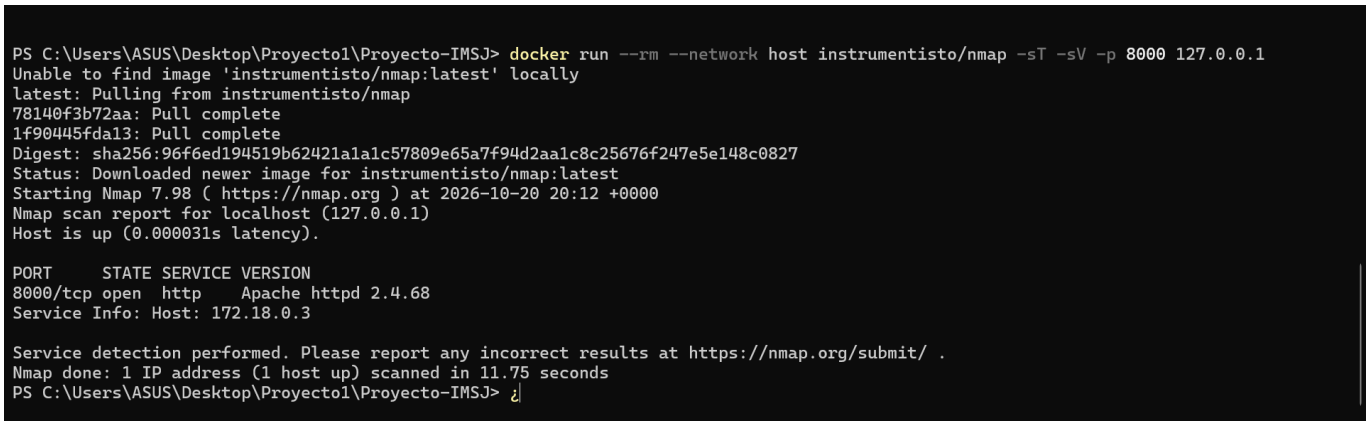


Figura 3. Detección de servicio en 127.0.0.1:8000, 20/10/2026.

Campo	Resultado
Host	localhost (127.0.0.1), activo
Puerto	8000/tcp open
Servicio	http
Versión detectada	Apache httpd 2.4.68
Duración informada	11,75 segundos

Integridad de los artefactos fuente

Archivo	SHA-256
zap-report.json	2F7FE678713736987E4A62582A2FC79A2F193EF0262FD6250580D03CDB9EBFF4
zap-report.html	7BD21A6FE2B7E45D8FCC427CEF4775D4D8604C65DBA92BC3F860668B9BB9FD16
nmap-report.txt	3CE3FF369040DD970C539DD70D7369BE4979B08F930938D99A784FDE8DBA8F96

11 | CIERRE

Conclusiones y referencias

Conclusión

El DAST confirmó una superficie local coherente con el diseño esperado y no registró fallos de política ni hallazgos ZAP de severidad alta. Sin embargo, evidenció controles de navegador y endurecimiento que deben completarse. La condición más delicada es la posibilidad de que los formularios recurran a GET si el JavaScript no intercepta el envío; su corrección es pequeña y reduce un riesgo desproporcionado sobre credenciales.

El informe no afirma que la aplicación esté libre de vulnerabilidades. Para cerrar el ciclo se necesita aplicar las medidas P1, repetir el baseline y ampliar la cobertura a rutas autenticadas, panel, API y navegación dinámica. La publicación institucional también requiere HTTPS y la configuración real del dominio.

Referencias técnicas

Referencia	Uso en este informe
OWASP ZAP 2.17.0 · reporte tradicional JSON/HTML	Fuente primaria de alertas, instancias, severidad y confianza.
ZAP Baseline Scan	Interpretación del escaneo pasivo, WARN/FAIL y límites de cobertura.
OWASP Secure Headers Project	CSP, anti-clickjacking, nosniff, políticas cross-origin y permissions policy.
MDN Web Docs · Subresource Integrity	Tratamiento de recursos externos con integrity y crossorigin.
Nmap 7.98	Identificación del puerto y versión del servicio local.
Código del proyecto · commit 5f15b3b	Validación contextual de formularios, cliente API y configuración Apache.

Artefactos conservados

- informes-dast/zap-report.html — reporte navegable generado por ZAP.
- informes-dast/zap-report.json — fuente estructurada utilizada para el triage.
- informes-dast/nmap-report.txt — salida textual del reconocimiento de servicio.
- Capturas de ejecución incorporadas en las páginas 9 a 11 de este informe.

FIN DEL INFORME

Revalidación posterior a correcciones

OWASP ZAP Baseline y Nmap se ejecutaron nuevamente el 21/10/2026 contra el contenedor reconstruido desde el árbol de trabajo del proyecto. La verificación previa confirmó CSP, anti-clickjacking, nosniff, políticas cross-origin, Permissions-Policy y caché diferenciada.

14	4	0	63
reglas con alerta iniciales	reglas con alerta posteriores	fallos de política	controles aprobados

Controles corregidos

Hallazgo inicial	Tratamiento comprobado	Estado
CSP y anti-clickjacking	Content-Security-Policy con frame-ancestors y X-Frame-Options: DENY.	Cerrado
Script externo sin integridad	Lucide fue sustituido por iconos SVG locales.	Cerrado
Credenciales en URL	Los tres formularios declaran POST; no aparecieron query strings con claves.	Cerrado
nosniff y políticas del navegador	Se añadieron X-Content-Type-Options, COOP, COEP, CORP y Permissions-Policy.	Cerrado
Divulgación tecnológica	X-Powered-By se elimina y Nmap informa Apache httpd sin versión.	Cerrado
JavaScript de terceros	No quedan scripts externos en el portal revisado.	Cerrado

Decisión posterior

Los hallazgos prioritarios P1 del baseline inicial quedaron cerrados. El resultado posterior fue 0 FAIL, 4 WARN y 63 PASS. Las advertencias restantes se sometieron a triage y no muestran una vía de explotación confirmada en el alcance pasivo y no autenticado ejecutado.

Triage de advertencias restantes

El JSON posterior contiene 5 entradas, 12 instancias y cuatro identificadores de regla únicos. La diferencia se debe a que ZAP representa dos decisiones de caché bajo el mismo identificador 10049.

Regla	Evidencia posterior	Clasificación del equipo
10202 - Ausencia de token anti-CSRF	3 formularios de login/registro.	No aplicable al flujo revisado: la API no autentica con cookies, exige JSON y usa token Bearer en sessionStorage. Los formularios son una defensa POST si falla JavaScript.
10027 - Comentarios sospechosos	2 instancias en api.js; evidencia: 'etira del navegador...'.	Falso positivo lingüístico por la palabra 'Retira'; no contiene secretos, tareas pendientes ni información operativa.
10109 - Aplicación web moderna	1 señal por scripts del login.	Informativa. Justifica Client Spider para ampliar cobertura; no requiere corrección.
10049 - Caché	5 respuestas no almacenables y 1 CSS cacheable.	Comportamiento esperado: HTML y errores usan no-store; CSS público usa max-age=3600 y no contiene datos personales.

Nmap posterior

Objetivo	Resultado	Lectura
host.docker.internal:8000	open - http - Apache httpd	Único puerto incluido en el alcance; la versión 2.4.68/2.4.69 ya no se divulga.

Límite que permanece

Esta revalidación confirma el baseline público y el reconocimiento del puerto 8000. No sustituye una prueba autenticada del panel, Client Spider, auditoría específica de la API ni pruebas activas de lógica de negocio. Esas actividades deben mantenerse separadas y ejecutarse solo con cuentas y datos de prueba.

Evidencia posterior

Figura 4. Resumen final de OWASP ZAP: 0 FAIL, 4 WARN y 63 PASS.

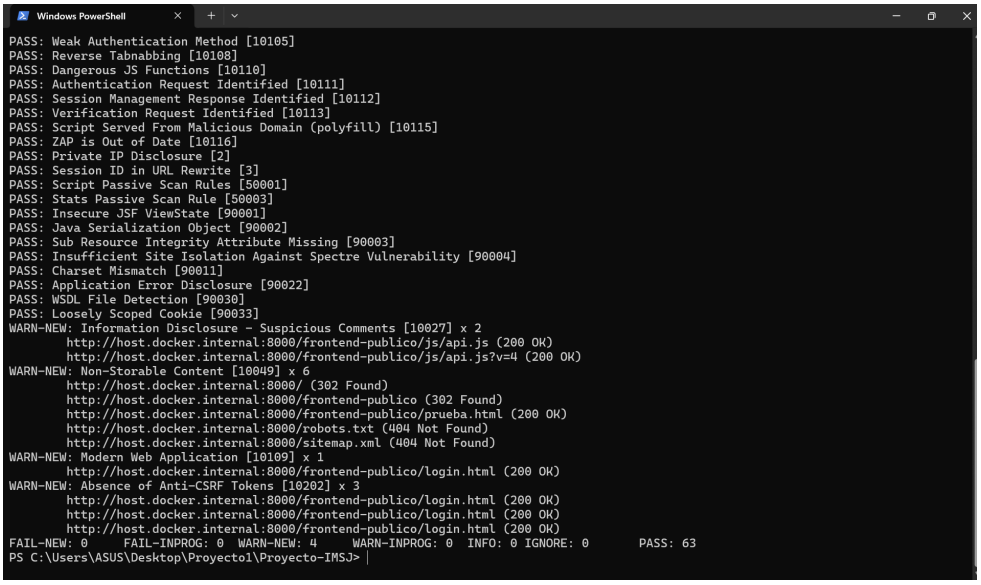
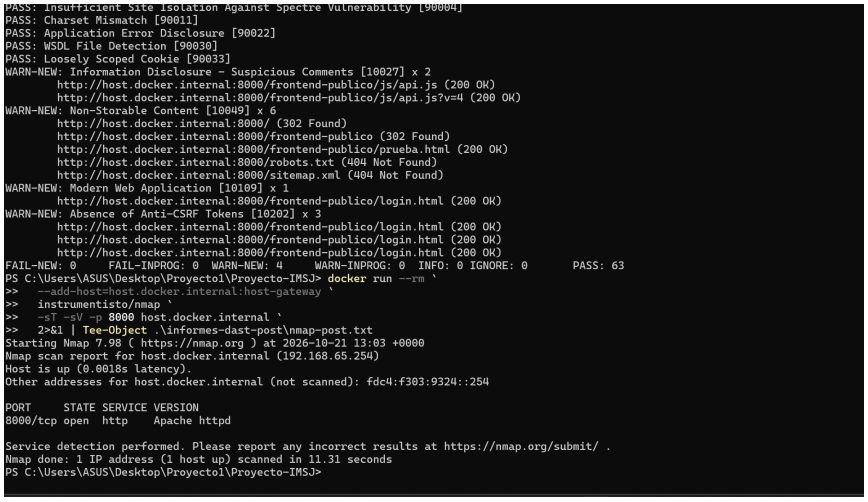


Figura 5. Nmap confirma el puerto 8000 y oculta la versión exacta de Apache.



Integridad de artefactos posteriores

Artefacto	SHA-256
zap-report-post.json	316C4AE7D043A11A9F6BC21A3FC4A3A12AFA12E7F54FB13E23DFA16BDCD54F30
zap-report-post.html	4FA956EEB6DB097F18BBEBB6FF6350B2ECC757A87D3DBCAD392A0C1D4B750E31
zap-post-terminal.txt	9831E979C6DDDDB785AB92357717E87FF56F2074397E8A7F270818CCA1764FB5
nmap-post.txt	11CEC12C79378F827037A061A73CFDAABE7BF80008E77A33A982C2C64B41D7F1

INFORME FORMAL DE AUDITORÍA BASH

Seguridad de la API REST del Portal Vial IMSJ

Proyecto	Proyecto IMSJ - Portal Vial
Fecha de ejecución	21 de octubre de 2026 (UTC registrada por el script)
Objetivo autorizado	http://127.0.0.1:8000 - entorno local Docker
Herramienta principal	backend/tests/security_api.sh con Bash y curl
Versión documental	1.0 - evidencia de cierre técnico
Identificación del código	Rama main; base Git 5f15b3b; snapshot local identificado además mediante hashes SHA-256

Resultado de aceptación: 43 pruebas aprobadas, 0 fallidas, 0 omitidas y código de salida 0.

1. Resumen ejecutivo

Se ejecutó una auditoría automatizada de seguridad sobre la API REST del Proyecto IMSJ en un entorno local expresamente autorizado. La validación combinó controles sin autenticación, sesiones válidas e inválidas, perfiles PUBLICO_GENERAL, PERSONAL_IMSJ y DIRECTORA, datos descartables y casos negativos diseñados para confirmar que la API rechaza operaciones inseguras de forma controlada.

43	0	0	0
Aprobadas	Fallidas	Omitidas	Código de salida

1.1 Objetivo

Obtener evidencia reproducible de que los controles principales de la API funcionan ante solicitudes válidas y maliciosas controladas, y que una ejecución incompleta o con fallos produce un código distinto de cero.

1.2 Alcance y límites

Incluido	Fuera de alcance
API local en 127.0.0.1:8000; autenticación y sesiones; autorización por rol; CORS; cabeceras; archivos; rutas privadas; SQLi/XSS; rate limiting; IDOR de reservas; limpieza de datos.	Infraestructura productiva, HTTPS público, ingeniería social, denegación de servicio sostenida, dispositivos de usuarios y servicios de terceros.

Todas las cédulas visibles en las capturas son identificadores ficticios de prueba. Las contraseñas se introdujeron de forma oculta y no se conservaron en el informe.

2. Metodología y controles

El script realiza peticiones HTTP con curl, compara el código obtenido con el esperado, inspecciona respuestas y encabezados, cuenta resultados y finaliza con estado no cero ante una falla. En modo estricto también falla si queda una prueba omitida. Las operaciones de escritura se limitaron a registros descartables eliminados al finalizar.

Área	Comprobaciones principales	Criterio de aceptación
Disponibilidad	API y healthcheck	HTTP 200 y estado ok
Cabeceras	nosniff, caché, anti-clickjacking, CSP y Server	Controles presentes; sin versión exacta
Autenticación	Sin token, token inválido, válido, revocado y expirado	401 para sesiones no válidas; 200 para sesión válida
Autorización	Panel por rol, aprobación y reserva ajena	403 por rol insuficiente; 404 para recurso ajeno
Entradas	JSON inválido, SQLi y XSS controlados	400/422; sin 500, eco de payload ni ejecución
Archivos	PHP presentado como PDF	422 y ausencia de ejecución
CORS	Origen permitido y origen ajeno	204 permitido; 403 ajeno; origen único
Exposición	.env, config.php, SQL y traversal	404 sin contenido privado
Abuso	Intentos repetidos de login	429 dentro del límite configurado

2.1 Preparación controlada

- Objetivo limitado a la instancia local autorizada; no se realizaron pruebas contra sistemas externos.
- Credenciales solicitadas interactivamente y contraseña oculta en terminal.
- FAQ, usuarios, tokens, franja y reserva creados exclusivamente para comprobar permisos y propiedad.
- Los registros descartables se eliminaron y se verificó que no permanecieran usuarios ni franjas de la preparación final.
- El modo estricto IMSJ_SECURITY_REQUIRE_FULL=1 exigió cero omisiones para aceptar la ejecución final.

3. Resultados y trazabilidad

Ejecución	Rol / propósito	Aprobadas	Fallidas	Omitidas	Salida	Interpretación
security-api-publico.txt	PUBLICO_GENERAL	32	0	4	0	Cobertura del ciudadano; omisiones esperadas por rol
security-api-directora.txt	DIRECTORA	37	0	3	0	Carga maliciosa y 429 confirmados
security-api-personal.txt	PERSONAL_IMSJ	35	0	3	0	Flujo descartable y 403 de aprobación
security-api-final.txt	Aceptación estricta	43	0	0	0	Cobertura completa; resultado final válido

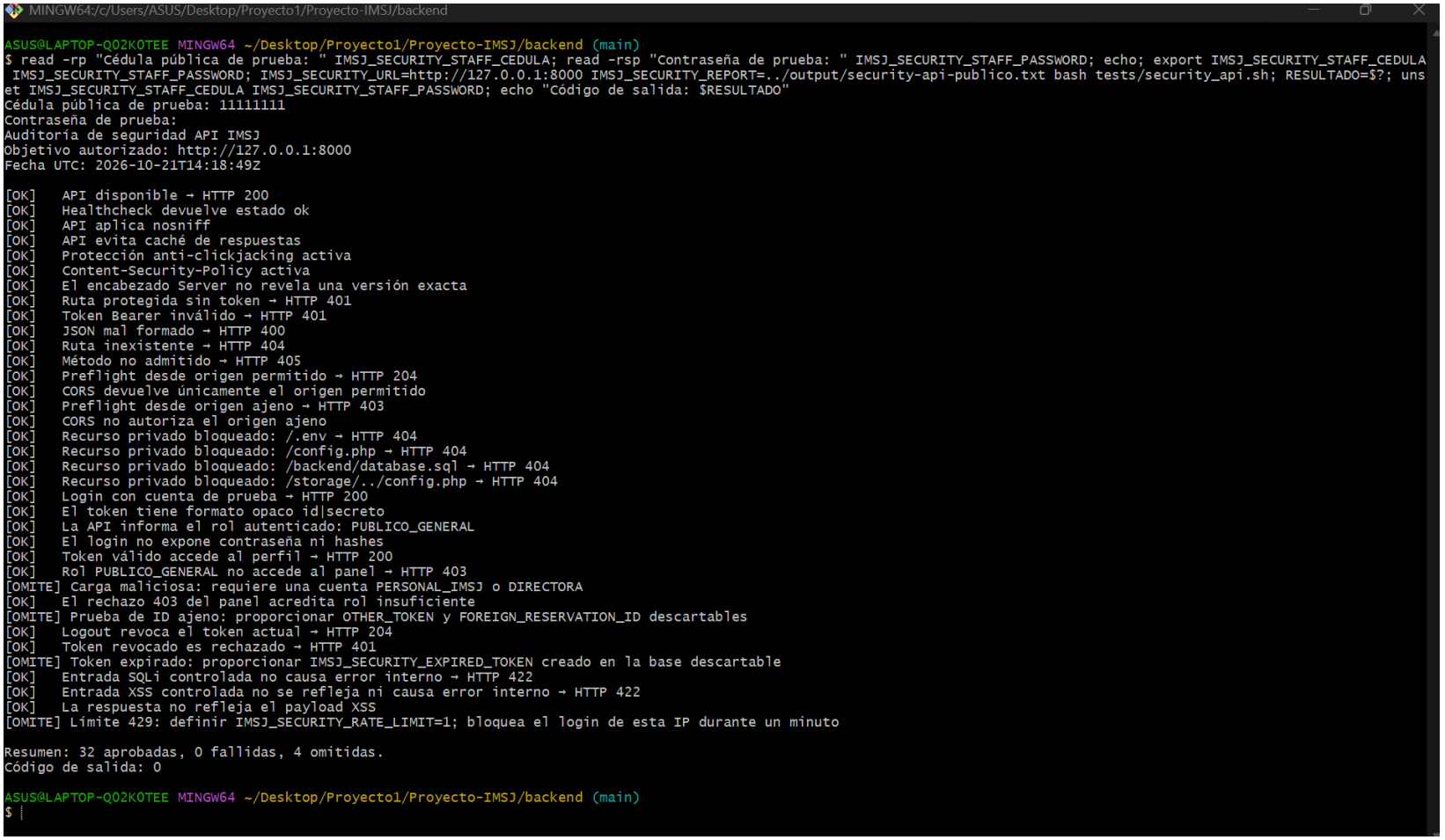
3.1 Interpretación

- No se confirmó ninguna falla de seguridad dentro del alcance automatizado de la ejecución estricta final.
- La respuesta 404 ante una reserva de otro usuario evita revelar su existencia y bloquea la cancelación ajena.
- Los tokens revocado y expirado fueron rechazados con 401; el token válido accedió al perfil con 200.
- El archivo PHP disfrazado de PDF fue rechazado con 422, validando que la extensión declarada no basta para aceptar una carga.
- La cuenta PERSONAL_IMSJ pudo preparar contenido, pero recibió 403 al intentar una acción reservada a DIRECTORA.
- El quinto intento controlado activó 429, confirmando el límite de solicitudes de autenticación.

3.2 Incidencia de ejecución no atribuible a la API

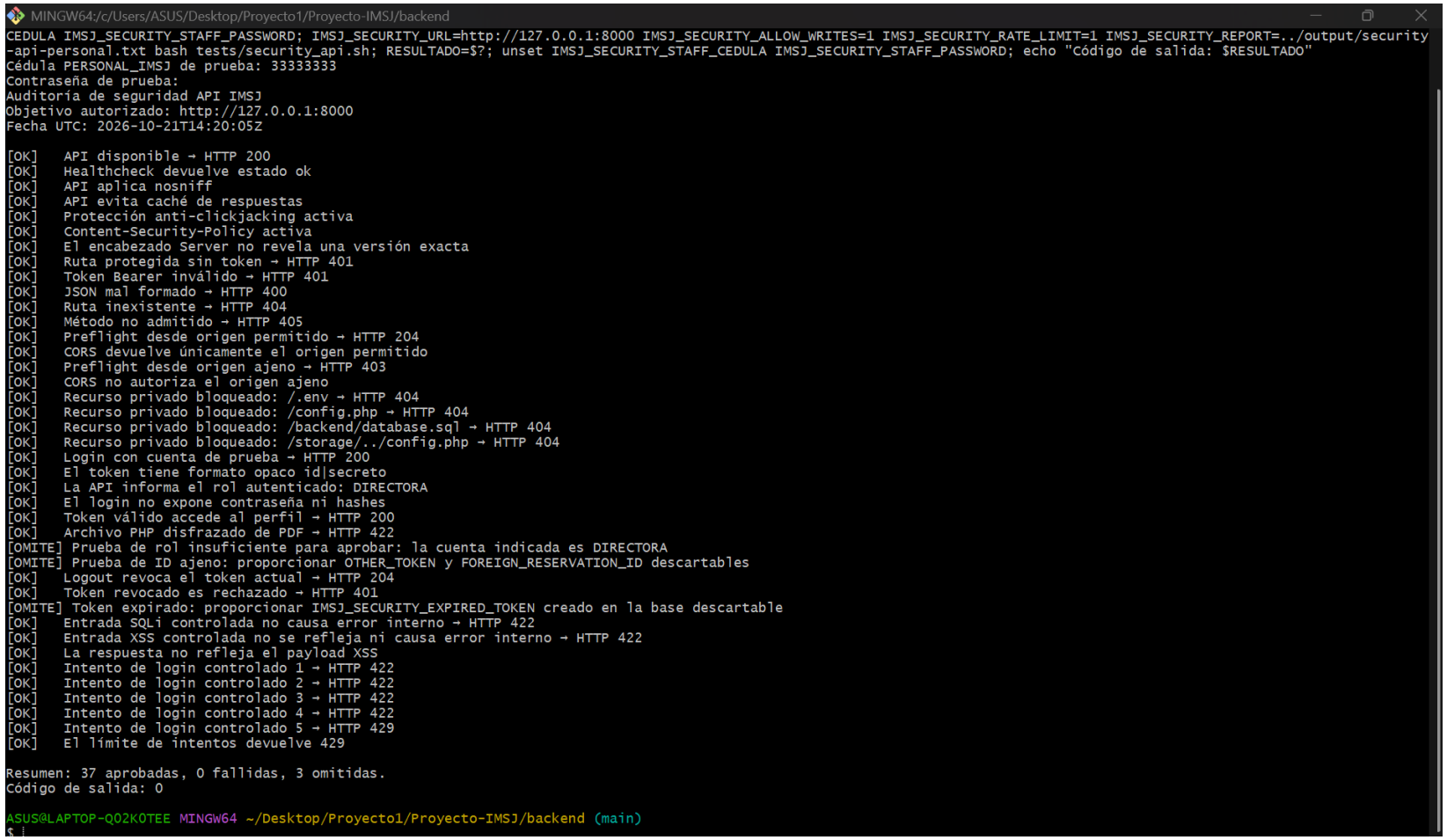
Durante la preparación de la evidencia completa, una primera cadena de consola no separó correctamente tres identificadores devueltos por MySQL. El modo estricto detectó la omisión del caso IDOR y terminó con código 2. Se corrigió el separador de la preparación, se recrearon los datos descartables y se repitió toda la auditoría. La aceptación se basa exclusivamente en la repetición final 43/0/0 con código 0.

Evidencia 1 - Perfil PUBLICO_GENERAL



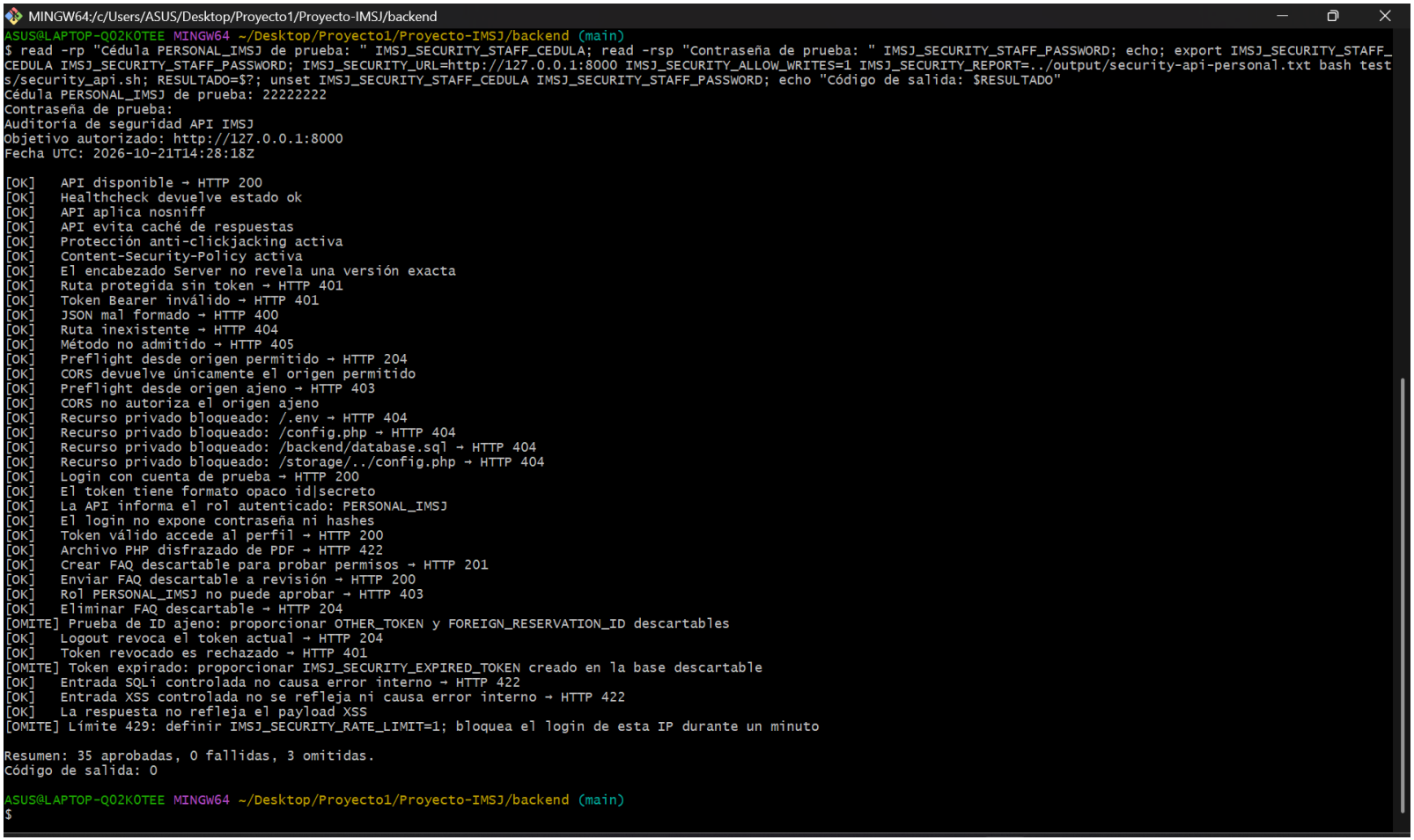
Ejecución autenticada con rol ciudadano: 32 pruebas aprobadas, 0 fallidas y salida 0. Los casos omitidos corresponden a controles que requieren otro rol o preparación específica.

Evidencia 2 - Perfil DIRECTORA



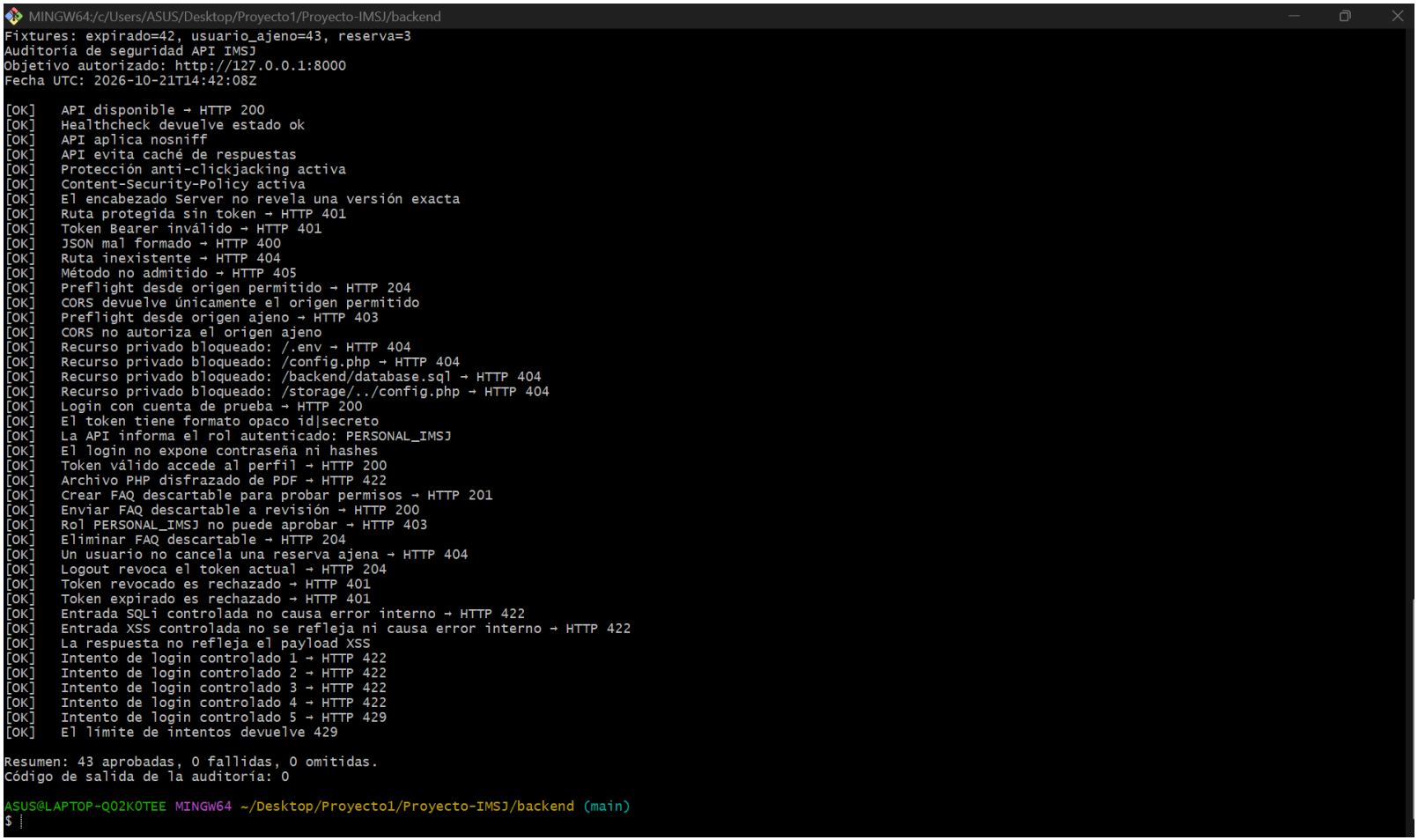
Ejecución con rol DIRECTORA: 37 pruebas aprobadas, 0 fallidas y salida 0. Se observa el rechazo de un archivo PHP presentado como PDF y el límite HTTP 429.

Evidencia 3 - Perfil PERSONAL_IMSJ



Ejecución con rol PERSONAL_IMSJ: 35 pruebas aprobadas, 0 fallidas y salida 0. Incluye creación y eliminación de una FAQ descartable y rechazo 403 al intentar aprobarla.

Evidencia 4 - Ejecución estricta final



Cierre de aceptación: 43 pruebas aprobadas, 0 fallidas, 0 omitidas y código de salida 0. Incluye token expirado, token revocado, reserva ajena, carga maliciosa y límite de intentos.

4. Integridad de la evidencia

Artefacto	SHA-256
backend/tests/security_api.sh	24f4854e64186eea009f900368bfd8f8fd2d265e399e53ed5a3cb8aed544714d
output/security-api-final.txt	e9e884a49368782da1c4e08b346b97291da03549d17b81f8c7504e507ae7798e

5. Limitaciones

- El informe documenta una ejecución local; no acredita la configuración TLS/HTTPS de un despliegue productivo.
- Las pruebas automáticas reducen riesgo, pero no demuestran ausencia absoluta de vulnerabilidades.
- Las ejecuciones parciales por rol contienen omisiones previstas; la conclusión técnica se apoya en la ejecución estricta final sin omisiones.
- El snapshot evaluado parte del commit 5f15b3b e incluye cambios locales; antes de la entrega debe asociarse esta evidencia al commit o tag definitivo.

6. Conclusión

La auditoría Bash de seguridad de la API REST IMSJ cumple su criterio técnico de cierre. La ejecución final verificó todos los controles programados sin fallas ni omisiones y produjo código de salida 0. Las respuestas observadas fueron coherentes con la política de autenticación, autorización, validación de entradas, protección de archivos, CORS y limitación de intentos.

DICTAMEN: APROBADO dentro del alcance local autorizado y sujeto a vincular la evidencia con la versión final entregada.

Elaborado por	Revisado por	Fecha de aprobación
Equipo Proyecto IMSJ	_____	_____

DOCUMENTO 25 | CIBERSEGURIDAD

Registro consolidado de hallazgos y controles

Fuente: registro_hallazgos.md | Versión 1.0 | Fecha 26/10/2026

Proyecto: Educación Vial IMSJ - Portal Vial. **Corte documental:** 21/10/2026.

1. Fuentes y alcance

Fuente	Alcance y referencia
Semgrep 1.180.0	JSON posterior y salida de terminal.
ZAP 2.17.0	Baseline de `http://host.docker.internal:8000`; JSON y terminal.
Nmap 7.98	Registro de 8000/tcp, 21/10/2026 a las 13:03 UTC.
Auditoría Bash	Resultado final, 21/10/2026 a las 14:42:08 UTC.
Integración HTTP/MySQL	192 comprobaciones, 21/10/2026 a las 14:47:36 UTC.

El registro separa los avisos de las herramientas del análisis de su contexto y de los resultados de pruebas. Las severidades WARNING y ERROR pertenecen al formato de Semgrep; el riesgo de ZAP utiliza su escala propia.

2. Análisis estático

El JSON de Semgrep contiene seis resultados y un diagnóstico de análisis parcial.

ID	Aviso registrado	Ubicación del informe	Análisis del código consultado
HS-01	tainted-filename; WARNING	core/Auth.php:62	El contador genera el nombre mediante SHA-256 de operación e IP, agrega `.json` y lo ubica bajo CACHE_ROOT. La entrada no se utiliza como URL ni como nombre de ruta directo.
HS-02	unlink-use; WARNING	models/Archivo.php:80	La eliminación descarta URL remotas, resuelve las rutas con realpath y exige que el archivo permanezca bajo UPLOAD_ROOT antes de llamar a unlink.
HS-03	exec-use; ERROR	scripts/verificar.php:23	El rango señalado corresponde a proc*open con un arreglo de argumentos: PHP*BINARY, -l y la ruta de un PHP encontrado bajo backend. El archivo exige ejecución CLI. El análisis considera ese origen de argumentos y las condiciones de acceso al script.
HS-04	django-no-csrf-token; WARNING	Login.html:33	Regla de plantillas Django aplicada al formulario de ingreso ciudadano de una aplicación PHP/JavaScript.
HS-05	django-no-csrf-token; WARNING	Login.html:48	Misma regla aplicada al registro ciudadano.
HS-06	django-no-csrf-token; WARNING	Login.html:71	Misma regla aplicada al ingreso administrativo.
HS-07	PartialParsing; diagnóstico	Dockerfile:5-18	El analizador informa una lectura parcial del archivo; la evaluación de contenedores se complementa con Compose, salud y auditoría HTTP.

Fuentes del análisis: Auth, Archivo, verificador CLI, formularios, cliente de acceso y Dockerfile.

En HS-03, exec-use identifica la regla de la herramienta. La ubicación del aviso coincide con la llamada proc_open del verificador. Los hashes de integración identifican ese archivo; la revisión del contexto contempla argumentos separados, ejecución CLI y acceso de escritura al árbol de código.

Control de revisión SAST	Referencia
JSON con los seis avisos	semgrep-post.json.
Fuente actual identificada por hashes	integracion-final.json.
Tratamiento propuesto de HS-03	Conservar el verificador CLI con argumentos separados; restringir escritura del código y revisar el aviso al modificar la ejecución de procesos. No se declara corregido ni falso positivo por decisión humana.

3. Análisis dinámico

El JSON de ZAP registra la generación del informe el 21/10/2026 a las 13:03:26, versión 2.17.0. Su campo de fecha no incluye zona horaria.

ID	Tipo de alerta	Riesgo de ZAP	Instancias	Contexto de evaluación
HD-01	Ausencia de token anti-CSRF	Medio, código 2	3	Formularios de la pantalla de acceso. El cliente JavaScript envía JSON y usa Bearer explícito para las operaciones autenticadas.
HD-02	Comentarios sospechosos	Informativo, código 0	2	Detección pasiva de texto en las respuestas.
HD-03	Aplicación web moderna	Informativo, código 0	1	Identificación de una interfaz con comportamiento JavaScript.
HD-04	Contenido no almacenable	Informativo, código 0	5	Respuestas con instrucciones de caché observadas por el análisis.
HD-05	Contenido almacenable en caché	Informativo, código 0	1	Recurso que puede conservar el navegador según sus cabeceras.

El resumen de terminal registra **0 FAIL, 4 WARN y 63 PASS**. Esos contadores son categorías del baseline; el JSON organiza sus resultados por tipo de alerta e instancia.

La configuración de Apache establece `no-store` para HTML y permite caché de una hora para recursos estáticos. La respuesta de API establece las cabeceras de sus respuestas. La auditoría Bash comprueba CSP, nosniff, anti-clickjacking y ausencia de caché en API.

La alerta CSRF se interpreta según la forma real de enviar credenciales y las operaciones públicas de login, registro y consultas. La coincidencia con una regla de Django o la existencia de un Bearer se analizan junto con ese flujo. El baseline público conserva su propio alcance, distinto de una exploración autenticada del panel.

4. Exposición y contenedores

Nmap registra Apache HTTP abierto en 8000/tcp en el objetivo local utilizado para la prueba. Compose permite definir la dirección y el puerto mediante `APP_BIND` y `APP_PORT`, y mantiene MySQL sin puerto publicado en el host.

Control	Configuración o prueba
Cuenta de aplicación	www-data.
Cuenta de base	mysql.
Sistema de archivos raíz	Solo lectura en ambos servicios.
Escalamiento de privilegios	no-new-privileges en ambos servicios.
Capacidades	Se descartan todas; app agrega NET*BIND*SERVICE.
Escritura	Volúmenes persistentes y temporales tmpfs declarados.
Separación de publicación	Raíz PHP en public; alias de frontends de solo lectura.
Rutas privadas	La auditoría rechaza .env, config.php, SQL y recorrido fuera de storage con 404.

5. Controles revalidados mediante API

Grupo	Evidencia concreta
Sesiones	Token válido, inválido, revocado y vencido; ocultamiento de contraseña y hashes.
Roles	PERSONAL_IMSJ recibe 403 al intentar aprobar una FAQ pendiente.
Propiedad	Una cuenta no puede cancelar una reserva ajena; respuesta 404.
Archivos	Un PHP presentado como PDF se rechaza con 422.
Entradas	JSON mal formado 400; entradas SQLi/XSS controladas 422 y sin reflejo del payload XSS.
CORS	Preflight permitido 204; origen ajeno 403 y sin autorización CORS.
Métodos y rutas	Método no admitido 405; ruta inexistente 404 en los casos evaluados.
Rate limit	La secuencia de acceso controlada alcanza 429.
Transacciones	La integración provoca un fallo de auditoría y comprueba rollback del material y limpieza del PDF nuevo.

La ejecución API final registra 43 aprobadas sin fallos ni omisiones. La integración registra OK para sus 192 comprobaciones. Los controles ejecutados se conservan junto a los avisos automáticos y a las condiciones institucionales del checklist.

6. Reflexión ética

Las pruebas documentadas apuntan al entorno local del proyecto. La suite de integración exige una base aislada y utiliza registros sintéticos. La auditoría distingue operaciones de lectura y opciones de escritura, y su resultado identifica los escenarios ejecutados y omitidos.

Los registros que se comparten deben conservar fecha, alcance, versión y resultado, evitando publicar secretos o datos de personas reales. La revisión de una alerta debe atender a la ruta de datos y a la posibilidad de reproducirla. El texto del análisis conserva los contadores originales para que otra persona pueda contrastarlos.

Los controles de la aplicación y los procedimientos del organismo se complementan: dominio HTTPS, retención, contacto y operación posterior deben definirse antes de publicar el sistema.

7. Referencias

Informe SAST, informe DAST, auditoría Bash, hardening, plan e informe de pruebas, respuesta a incidentes y reflexión ética.

DOCUMENTO 26 | CIBERSEGURIDAD

Procedimiento técnico de respuesta a incidentes

Fuente: respuesta_incidentes.md | Versión 1.0 | Fecha 26/10/2026

Proyecto: Educación Vial IMSJ - Portal Vial. **Fecha:** 21/10/2026. **Entorno descrito:** instalación local con Docker Compose.

1. Objetivo

Organizar la detección, contención, análisis y recuperación de incidentes que afecten al portal, panel, API, base o adjuntos. El procedimiento utiliza la infraestructura y las herramientas presentes en el repositorio.

2. Coordinación y registro

Función del equipo	Referente
Coordinación del proyecto y backend	Tomás Cabrera.
Testing, documentación y registro de resultados	Juan Robaina.
Base de datos y comprobación de integridad	Gabriela Romero.
Interfaces públicas e internas	Verónica Romero y Juan Corrales.
Referente del cliente	Inspector de Tránsito.
Organismo administrador posterior	Intendencia de San José.
Contacto operativo institucional	Interlocución con el Inspector durante el proyecto; designación de función técnica al transferir.
Canal institucional de incidentes	Condición de transferencia: canal autorizado por la Intendencia; coordinación de proyecto con líder/co-líder.
Puesta en producción	La Intendencia definirá el canal y la función técnica responsable de incidentes.

En cada intervención se identifica a la persona que ejecutó la acción, la hora y el resultado. Las decisiones sobre aceptación o cambios del producto se registran en las reuniones del equipo y del referente.

3. Detección y clasificación

Situación	Señales	Primera comprobación
Indisponibilidad	Portal sin respuesta, error HTTP o contenedor unhealthy.	Estado de app/db y logs recientes.
Acceso irregular	Cuenta desconocida, cambios inesperados o sesión que pierde acceso.	Historial, estado de cuenta y validez del token.
Integridad	Registros o adjuntos ausentes, duplicados o inconsistentes.	Relaciones SQL, conteos y archivo asociado.
Publicación indebida	Contenido inesperado visible en el portal.	Estado, vigencia, autor y acciones de aprobación/publicación.
Carga sospechosa	Archivo inesperado o rechazo de tipo/tamaño.	Tipo real, ruta y operación que lo recibió.
Intentos repetidos	Respuestas 429 o reiteración de solicitudes inválidas.	IP del acceso, operación e intervalo de logs.

Para ordenar la intervención, atender primero a exposición de datos, acceso no autorizado y pérdida de integridad; después a indisponibilidad y fallos de alcance limitado. Un aviso automático se contrasta con su contexto y evidencia antes de determinar el impacto.

4. Preservación inicial

1. Registrar fecha, zona horaria, URL, pantalla u operación afectada y mensaje recibido.
2. Identificar la versión del código y el proyecto Compose que ejecuta la instalación.
3. Obtener estado de servicios y logs antes de reiniciar.
4. Conservar una copia protegida de esos registros y de los archivos involucrados.
5. Identificar si hay escrituras en curso y decidir la contención según el impacto.

Desde `backend`, estos comandos consultan el estado:

```text
docker compose ps -a
docker compose logs --timestamps --tail 200 app db
```

Los logs pueden contener datos operativos. La copia de trabajo debe tener acceso restringido. Las capturas para documentación conservan el mensaje y ocultan credenciales y datos personales.

5. Contención

Acceso de una cuenta

Si se conserva un acceso administrativo válido, revisar la cuenta involucrada. La operación **Quitar acceso** desactiva personal y revoca sus sesiones. El sistema impide quitar el propio acceso; la intervención debe preservar una cuenta administrativa legítima.

Un nuevo login reemplaza los tokens anteriores de la misma cuenta; logout revoca el token utilizado. Si se sospecha compromiso del servidor o de sus credenciales, tratar también la infraestructura y la configuración protegida.

Contenido público

Para una publicación incorrecta, registrar primero su identificador y estado. El personal puede utilizar **Retirar** para volver a borrador y revisar la información. La corrección recorre nuevamente la revisión, aprobación y publicación.

Compromiso o escritura insegura

Cuando sea necesario interrumpir las solicitudes para preservar datos, detener el servicio de aplicación del proyecto afectado:

```text
docker compose stop app
```

La base conserva su volumen. Mantener los registros y coordinar cualquier acceso SQL directo. La recuperación utiliza la configuración y los volúmenes identificados, conservando una copia del estado afectado para el análisis.

6. Análisis y corrección

1. Reconstruir la secuencia a partir de logs, historial y versión del código.
2. Precisar módulo, cuenta, datos y archivos afectados.
3. Contrastar el comportamiento con requisitos, permisos y contrato API.

4. Reproducir la causa en un entorno aislado con datos sintéticos.
5. Preparar la corrección y su comprobación específica.
6. Revisar el impacto sobre sesiones, esquema y archivos antes de aplicar la versión.

La auditoría administrativa conserva actor, acción, tipo, elemento y fecha. Para estudiar los valores anteriores se utilizan las copias y los registros disponibles; el historial actual no almacena una comparación completa de valores anteriores y posteriores.

7. Recuperación

El procedimiento de reconstrucción y restauración utiliza el respaldo del proyecto, la base de datos, los archivos cargados y la configuración protegida. La restauración se ensaya en un destino aislado antes de reemplazar una instalación de uso.

Comprobar antes de reabrir:

- Cuenta administrativa legítima y permisos por rol.
- Portal, API y servicios saludables.
- Consistencia de relaciones y conteos de datos.
- Descarga de adjuntos y estado de publicaciones.
- Consultas, franjas y reservas.
- Resultado de la prueba que reproduce el incidente y de los escenarios afectados.

Conservar el identificador del respaldo y las evidencias de la validación. La reapertura se registra con fecha, responsable y resultado.

8. Instrucciones para el registro de cada incidente

Esta ficha describe qué registrar ante una intervención; no documenta un incidente ocurrido.

Campo	Valor
Identificador	Asignar un código único con fecha y secuencia de intervención.
Detección y zona horaria	Registrar fecha y hora con zona America/Montevideo y el origen del aviso.
Versión y entorno	Registrar commit, proyecto Compose y equipo afectado.
Operación o componente	Identificar portal, panel, endpoint, base o adjunto involucrado.
Impacto y datos afectados	Describir alcance confirmado, cuentas, registros y disponibilidad.
Persona a cargo de la intervención	Identificar a quien ejecuta cada acción, bajo coordinación técnica.
Evidencia inicial	Conservar logs y capturas protegidos antes de modificar el estado.
Contención y hora	Registrar acciones de contención y hora efectiva de cada una.
Causa identificada	Relacionar causa comprobada con evidencia; separar hipótesis de resultados.
Corrección aplicada	Identificar cambio, configuración y versión que corrige la causa.
Respaldo y destino de recuperación	Registrar nombre, SHA-256, commit compatible y destino aislado.
Pruebas y resultados	Anotar casos ejecutados, resultados y archivos de evidencia.
Comunicación y decisión	Registrar interlocutor, decisión y autorización de reapertura cuando corresponda.
Reapertura y seguimiento	Registrar fecha, responsable, comprobaciones posteriores y cierre.

9. Referencias

Inventario de infraestructura, reconstrucción, manual de usuario, hallazgos y verificación.

Términos y condiciones del Sistema de Educación Vial IMSJ

Condiciones de acceso y uso aplicables en la República Oriental del Uruguay

Versión	Última actualización
1.1	22 de octubre de 2026

Estos términos regulan el acceso y el uso del Sistema de Educación Vial IMSJ, incluidos el portal informativo, las pruebas de práctica, la gestión de cuentas y el servicio de reservas. Al crear una cuenta o utilizar una función que exija aceptación, la persona usuaria declara haber leído estas condiciones y la Política de Privacidad.

Identificación y alcance del servicio

El Sistema es administrado en el marco institucional de la Intendencia de San José, a través de la Sección Tránsito. La denominación IMSJ identifica al portal y a sus funciones de educación vial y gestión de servicios.

El Sistema permite consultar noticias, materiales de educación vial, preguntas frecuentes y pruebas de práctica; también permite registrarse, autenticarse y reservar franjas disponibles. Las funciones administrativas están limitadas al personal autorizado.

Aceptación y registro

La aceptación se presenta mediante una acción afirmativa. El Sistema puede conservar la versión aceptada, la fecha, la hora y el identificador de la cuenta para acreditar dicha aceptación. La navegación por contenidos públicos no implica consentimiento para finalidades ajenas a la prestación del servicio.

Si la persona no acepta estas condiciones, puede consultar los contenidos públicos que no requieran cuenta, pero no puede utilizar las funciones para las que la aceptación sea necesaria.

Registro y seguridad de la cuenta

- La información proporcionada debe ser verdadera, exacta y mantenerse actualizada.
- La cédula, las credenciales y los tokens de acceso son personales y no deben compartirse.
- Cualquier uso no autorizado debe comunicarse mediante los canales institucionales publicados en el Sistema.
- Las cuentas del personal solo pueden utilizarse mientras exista autorización institucional vigente.
- Una cuenta puede bloquearse ante riesgo de fraude, acceso no autorizado o incumplimiento de estas condiciones.

Reservas y disponibilidad

Las reservas están sujetas a la disponibilidad y capacidad de cada franja. La confirmación electrónica acredita que el Sistema registró la solicitud, pero no amplía cupos ni modifica los requisitos administrativos aplicables.

Las cancelaciones se gestionan desde la cuenta de la persona usuaria. La disponibilidad se actualiza según las reservas vigentes y las reglas operativas del servicio.

Contenido educativo

Los materiales y las pruebas de práctica tienen finalidad educativa. Sus resultados no habilitan para conducir, no reemplazan los procedimientos oficiales ni garantizan la aprobación de evaluaciones teóricas o prácticas.

Uso permitido y conductas prohibidas

La persona usuaria debe utilizar el Sistema de forma lícita y respetuosa. Queda prohibido:

- Acceder o intentar acceder a cuentas, datos, funciones o áreas administrativas sin autorización.
- Interferir con la disponibilidad, automatizar solicitudes abusivas o eludir controles de seguridad.
- Cargar archivos maliciosos, manipular identificadores o utilizar el Sistema para fraude o suplantación.
- Redistribuir contenidos protegidos fuera de los usos autorizados por la ley o por sus titulares.
- Utilizar datos obtenidos del Sistema para finalidades incompatibles con aquellas informadas.

Propiedad intelectual

Los textos, imágenes, marcas, materiales y demás elementos pertenecen a sus respectivos titulares. El acceso concede un permiso personal, limitado y revocable para el uso informativo y educativo. Las licencias específicas indicadas en cada material prevalecen sobre esta regla general.

Enlaces y servicios de terceros

El Sistema puede incluir enlaces a sitios o contenidos de terceros. Cada tercero administra sus contenidos y sus tratamientos de datos. La persona usuaria debe revisar las condiciones y políticas correspondientes antes de utilizarlos.

Continuidad y cambios del servicio

La administración procurará mantener el Sistema disponible y seguro. Puede realizar mantenimiento, corregir errores o suspender temporalmente funciones cuando sea necesario para proteger la información o la continuidad del servicio.

Responsabilidad

Cada parte responde por los daños que le sean imputables conforme a la normativa aplicable. Estas condiciones no excluyen derechos inderogables ni limitan responsabilidades que la ley no permita limitar. La administración no responde por fallas atribuibles exclusivamente a la conexión, el dispositivo o la conducta de la persona usuaria, sin perjuicio de las medidas razonables de seguridad y continuidad que correspondan.

Protección de datos personales

El tratamiento de datos personales se rige por la Política de Privacidad del Sistema, la Ley N.º 18.331, sus modificativas y su normativa reglamentaria.

Modificación de estos términos

Estas condiciones pueden actualizarse para reflejar cambios legales, funcionales o de seguridad. La nueva versión indicará su fecha de vigencia. Los cambios sustanciales se comunicarán antes de su aplicación y, cuando corresponda, se solicitará una nueva aceptación.

Ley aplicable y solución de controversias

Estos términos se rigen por el derecho de la República Oriental del Uruguay. Las controversias se someten a las autoridades y tribunales competentes, sin restringir los mecanismos administrativos, de protección de datos o de defensa del consumidor que puedan corresponder.

Contacto

Las consultas sobre el uso del Sistema, las reservas o estas condiciones pueden presentarse mediante los canales institucionales publicados por la Intendencia de San José y los medios de contacto habilitados dentro del propio Sistema.

Política de privacidad del Sistema de Educación Vial IMSJ

Información sobre el tratamiento de datos personales en Uruguay

Versión	Última actualización
1.1	22 de octubre de 2026

Esta política explica qué datos personales trata el Sistema de Educación Vial IMSJ, para qué los utiliza, con quién puede compartirlos, cómo los conserva y de qué manera pueden ejercer sus derechos las personas titulares. Se aplica al portal, las cuentas, las reservas, las funciones administrativas y los registros técnicos asociados.

Responsable del tratamiento

La administración del tratamiento corresponde a la Intendencia de San José, a través de la Sección Tránsito, en el marco de las funciones ofrecidas por el Sistema. Las solicitudes vinculadas con datos personales pueden presentarse mediante los canales institucionales publicados en el portal o por los medios oficiales de la Intendencia.

Datos personales tratados

Categoría	Datos comprendidos	Origen
Cuenta ciudadana	Cédula de identidad, identificador interno, contraseña almacenada mediante hash, rol y estado.	Persona titular y operación del Sistema.
Personal IMSJ	Nombre, cédula, rol, estado y datos de autenticación.	Institución y persona autorizada.
Reservas	Usuario, franja, fecha, hora, tipo de atención y fecha de creación.	Solicitud de la persona y agenda institucional.
Historial administrativo	Usuario actuante, acción, tipo e identificador del elemento, fecha y hora.	Uso de funciones administrativas.
Seguridad y acceso	Tokens, eventos de autenticación y registros técnicos como fecha, hora, IP o errores.	Generación automática durante el uso.
Comunicaciones	Datos incluidos por la persona en consultas o solicitudes.	Persona titular o representante.

El Sistema no solicita datos sensibles en sus formularios ordinarios. No deben incluirse datos de salud, origen racial o étnico, opiniones políticas, convicciones religiosas o morales, afiliación sindical o vida sexual en campos libres.

Finalidades y bases jurídicas

Finalidad	Datos principales	Base jurídica
Crear y administrar cuentas	Cédula, contraseña, rol y estado.	Prestación del servicio, función pública y consentimiento cuando corresponda.
Autenticar y proteger el acceso	Credenciales, token y registros de seguridad.	Seguridad del servicio, cumplimiento legal y responsabilidad proactiva.
Gestionar reservas	Cuenta, franja, fecha, hora y tipo.	Solicitud de la persona y gestión del servicio público.
Administrar contenidos y personal	Nombre, cédula, rol e historial de acciones.	Relación funcional, control interno y seguridad.
Prevenir y responder incidentes	Registros técnicos y de auditoría.	Obligaciones de seguridad y protección de datos.
Atender derechos y reclamos	Identidad, solicitud y antecedentes necesarios.	Cumplimiento de obligaciones legales.

Información obligatoria y consecuencias

Los campos obligatorios son necesarios para crear una cuenta, autenticarla o registrar una reserva. La negativa a proporcionar la cédula o los datos de la reserva impide utilizar esas funciones, pero no limita el acceso a contenidos públicos que no los requieran.

Destinatarios y encargados

Pueden acceder a los datos únicamente el personal autorizado de la Intendencia de San José, los proveedores que operen infraestructura o soporte por cuenta de la institución y las autoridades que los requieran conforme a una norma u orden válida. Los encargados deben mantener confidencialidad, seguridad y uso limitado a la finalidad encomendada.

Los datos personales no se venden ni se utilizan para publicidad ajena al servicio. Cualquier comunicación para una finalidad diferente requiere una base jurídica independiente y la información previa correspondiente.

Transferencias internacionales

Los datos se mantienen en la infraestructura asignada al Sistema. Si un servicio de alojamiento, respaldo, correo o soporte implicara una transferencia al exterior, se verificará el nivel de protección del destino y se aplicarán las autorizaciones o garantías exigidas por la normativa uruguaya.

Criterios de conservación

Información	Criterio de conservación
Cuenta y perfil	Mientras la cuenta permanezca activa y durante el período necesario para atender derechos y obligaciones legales.
Reservas	Durante el tiempo necesario para gestionar la agenda, respaldar la atención y resolver reclamos.
Historial administrativo	Durante el período necesario para trazabilidad, control interno y seguridad.
Token de acceso	Hasta ocho horas, cierre de sesión o revocación, según ocurra primero.
Registros técnicos	Durante un período proporcional a las necesidades de detección de incidentes y diagnóstico.
Solicitudes de derechos	Durante el tiempo necesario para documentar la respuesta y acreditar el cumplimiento.

Una vez cumplida la finalidad, los datos se eliminan, anonimizan o bloquean cuando una obligación legal exija conservarlos únicamente para atender responsabilidades.

Medidas de seguridad

El Sistema aplica medidas técnicas y organizativas proporcionales al riesgo para proteger la confidencialidad, integridad y disponibilidad de la información. Entre ellas se incluyen:

- Contraseñas almacenadas mediante hash y control de intentos de acceso.
- Separación de funciones por rol, tokens con vencimiento y revocación de sesiones.
- Validación de entradas, consultas preparadas y registro de acciones administrativas.
- Cifrado en tránsito mediante HTTPS y gestión de secretos fuera del código fuente.
- Acceso de mínimo privilegio, copias de seguridad y procedimientos de respuesta a incidentes.

Derechos de las personas titulares

La persona titular puede solicitar información sobre el tratamiento, acceder a sus datos y, cuando corresponda, pedir su rectificación, actualización, inclusión o supresión. También puede oponerse o impugnar valoraciones automatizadas en los casos previstos por la normativa.

La solicitud se presenta mediante los canales institucionales publicados en el Sistema e incluye la información necesaria para acreditar identidad y localizar los datos. El acceso se brinda gratuitamente en los intervalos legales y la respuesta se proporciona dentro del plazo máximo de cinco días hábiles.

Revocación del consentimiento

Cuando el tratamiento se base en consentimiento, este puede revocarse por el mismo canal utilizado para ejercer derechos. La revocación no afecta la licitud del tratamiento anterior ni impide conservar información cuando exista otra obligación legal que lo justifique.

Datos de menores de edad

Cuando una persona menor de edad utilice una función que requiera cuenta, el tratamiento se limita a los datos necesarios para prestar el servicio. La información debe presentarse en lenguaje comprensible y debe verificarse la intervención de representantes cuando corresponda.

Vulneraciones de seguridad

Ante un incidente que afecte datos personales se activan los procedimientos de contención, análisis y mitigación. Cuando la vulneración incida en la protección de los datos, se comunica a la URCDP dentro del plazo máximo de 72 horas desde que sea conocida y se informa a las personas afectadas cuando exista un riesgo significativo para sus derechos.

Cambios a esta política

La política puede actualizarse por cambios legales, técnicos o funcionales. La versión vigente indica su fecha. Los cambios que alteren finalidades, destinatarios o bases jurídicas se informan antes de aplicarse y, si corresponde, requieren un nuevo consentimiento.

Reclamos ante la autoridad

Si una persona considera que sus derechos no fueron atendidos, puede presentar una consulta o denuncia ante la Unidad Reguladora y de Control de Datos Personales. La información y los trámites están disponibles en gub.uy/urcdp.

DOCUMENTO 29 | CIBERSEGURIDAD

Reflexión ética

Fuente: reflexion_etica.md | Versión 1.0 | Fecha 26/10/2026

Las pruebas de seguridad se realizaron únicamente sobre el entorno local autorizado del proyecto IMSJ y con datos de prueba. No se atacaron sistemas externos ni se intentó acceder a información ajena.

Los resultados de herramientas como Semgrep, OWASP ZAP y Nmap se analizaron dentro del contexto del sistema. Una alerta automática no demuestra por sí sola una vulnerabilidad, y la ausencia de alertas tampoco garantiza seguridad absoluta.

Las evidencias deben conservar la fecha, el alcance y el resultado de cada prueba, sin publicar contraseñas, tokens ni datos personales. Los hallazgos se comunican al equipo para corregirlos y volver a comprobar el comportamiento afectado.

El objetivo de estas actividades fue reducir riesgos y mejorar el proyecto, respetando la privacidad de las personas y los límites acordados para la evaluación.